데이터 분석을 위한 싸이썬 및 상용 클라우드 서비스를 활용한 애플리케이션 운영 (보안관제 실무)

2026.10

SK 쉴더스

목차

1. 교육과정 소개
   1-1. 강사 소개
   1-2. 교육 내용

2. 보안관제의 이해
   2-1. 보안관제 개념
   2-2. 보안관제 업무 개요
   2-3. 보안관제 구성요소
   2-4. 보안관제 업무 절차

3. 보안관제 기술
   3-1. 보안관제 탐지/방어기술
   3-2. 탐지패턴 활용

4. 보안관제시스템
   4-1. 보안솔루션 분류
   4-2. 방화벽(F/W)
   4-3. IPS/IDS
   4-4. DDoS 대응 솔루션
   4-5. 웹방화벽(WAF)
   4-6. NAC
   4-7. Anti-Virus
   4-8. 기타 보안솔루션

목차

5. 보안관제 실무

2-1. 사이버보안관제센터

2-2. 보안관제 사업 수행 조직

5-3. 보안관제 사업 수행 업무

5-4. 훈련지원

5-5. 정보공유

5-6. 보안관제시스템 성능관리

5-7. 산출물

5-8. 비정상 트래픽 티켓팅

5-9. 보안관리시스템(ESM)

5-10. SIEM (Security Information & Event Management)

5-11. SOAR (Security Orchestration, Automation and Response)

목차

6. AI + SOAR 보안관제 업무

6-1. 보안관제 업무 생산성 혁신이 필요한 이유

6-2. AI + SOAR

6-3. AI + SOAR 적용 사례

1. 교육과정 소개

1-1. 강사 소개

1-2. 교육 내용



What?

여러분이 보안관제를 시작하면
무엇을 하여야 할까요?

반드시 해야 할 사항

1. 투입된 기관 또는 기업의 네트워크 구성도

2. 구성도에 포함된 보안관제시스템 목록

3. 관제대상은 어디까지 인가?

4. 보안관제센터와 연관된 부서 및 업체는 어디인가?

5. 보안관제 업무 범위는?

6. 관제업무 시 작성할 보고서 종류는?

7. 보안관제 조원들의 특성을 알고 배울점은 배워라.



Don’t

여러분이 보안관제를 하면서
하지 말아야 할 것은?

SK 쉴더스

하지 말아야 할 사항

1. 초심을 잃지 말라!

2. 자기 계발에 게을리 하지 말라!

3. 고객사에 대해 너무 궁금해 하지 말라!

4. 회사와 타인이 알아서 해줄 것이라 판단하지 말라!

5. 근무지가 좋은 곳을 물리적 주변 여건으로 생각하지 말라!

6. 보고서 작성 시 나만 생각하지 말라!

7. 본인의 이력서를 너무 지저분하게 만들지 말라!

2. 보안관제의 이해

보안관제의 중요성

민감 정보 접근 가능한 열쇠, 관리 소홀로 문제 키워
단순한 ID 구조·퇴사자 권한 방치 등 여러 요인 맞물려



서울 송파구 쿠팡 본사 전경 (사진=쿠팡)

출처 ITdaily http://www.itdaily.kr/news/articleView.html?idxno=237105cc

2. 보안관제의 이해

보안관제의 중요성

회사의 전반적인 내부 보안 체계가 제대로 운영됐느냐에 대한 질문으로 계속 이어질 수밖에 없다"고 강조



쿠팡의 탐지 체계가 ▲접속 위치 기반 분석 ▲휴면·탈퇴 계정 조회 감시 ▲행위 기반 탐지 등 체계를 갖추지 않았다

사이버 공격 및 보안 위협을 실시간으로 파악하고 적시성 있게 신속하게 대응하기 위해서는 보안관제 체계를 구축·운영하는 것이 중요

출처 바이라인 네트워크 https://byline.network/2025/12/3-363/

SK 쉴더스

2. 보안관제의 이해

2-1. 보안관제의 개념

◆ 보안관제의 정의에대한 논의

◆ 보안관제(Security Monitoring / Security Monitoring & Control)

R. Bejtlich	• 네트워크 트래픽도구를 이용하여 24시간 서버와 네트워크를 통해 통신한 방대한 데이터에서 잠재적인 침임자의 공격시도를 구명하는 일련의 행위 • 이 과정에서 분석된 내용을 토대로 불명확했던 침입시도를 규정하는 일련의 행위
한국산업보안협회	• 정책 위반 또는 침입으로부터 시스템과 네트워크 자원의 손상을 막기 위해 모든 시스템을 실시간으로 모니터링하여 즉각 대응할 수 있도록 하는 일련의 활동
국가정보보안 기본 지침 / 국가정보원	• 사이버 공격을 실시간으로 즉시 탐지 및 분석, 대응하는 일련의 활동

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ 보안관제의 시작

국내 보안관제는 1999년 9월부터 안랩코코넛이 민간업체를 대상으로 보안관제서비스 사업 시작

국내 국가·공공기관에 대한 보안관제 업무는 2002년 12월 금융결제원에서 18개 시중은행에 대한 보안관제를 위해 설치한 금융 ISAC으로 시작

2003년 1.25 인터넷 대란을 계기로 국가사이버안전센터가 정식 출범

현재는 국가사이버안보센터를 비롯 각 중앙행정기관이 설립한 분야별 보안관제센터 및 각 개별 기관별로 운영중인 단위보안관제센터 등이 있음.

2. 보안관제의 이해

2-1. 보안관제의 개념

보안관제란 조직의 정보기술 자원 및 보안 시스템을 안전하게 운영하기 위하여 사이버 공격 정보를 탐지 및 분석하여 대응하는 일련의 업무와 사전예방 및 관제시스템 운영에 관한 업무를 말한다.



과거

단순 모니터링 수준으로 인식

현재

모니터링 + 분석·대응을 위한 고도의 전문 기술 요구

※ 사이버 공격과 위협이 지능화·고도화 되면서 광의의 보안관제 개념이 일반적인 개념으로 인식

- ☞ **협의의 개념 : 모니터링, 즉 사이버공격을 탐지하는 활동**
- ☞ **광의의 개념 : 모니터링과 콘트롤, 즉 탐지·분석·대응까지 포함하는 일련의 활동**
- ☞ **보안관제 : Security Monitoring, Security Monitoring & Control**
- ☞ **관제 : 국가나 공항 따위에서 필요에 따라 강제적으로 관리하여 통제하는 일**

2. 보안관제의 이해

2-1. 보안관제의 개념

보안관제의 정의를 정리하면



정보통신망 및 정보시스템에서 발생되는
사이버 공격 및 보안 위협 이벤트를
24시간 365일 모니터링하여 위협을 탐지하고
이를 분석하여 대응하는 일련의 활동

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제 근거 및 표준**

보안관제 관련 법적 근거	정보보호 표준
▪국가사이버안전관리규정 제10조의2(보안관제센터의 설치·운영) ▪보안관제 전문업체지정 등에 관한 공고 ▪국가전산망 보안관제지침 ▪정보통신망법 제48조의2, 3, 4 ▪정보통신기반보호법 제16조1항 ▪전자금융거래법 제21조의 2,3,4,5	▪KISA-ISMS 제12장 침해사고 관리 ▪ISO 27001 제9장 정보보호 사고관리 ▪NIST(미국-국립표준기술원) Cybersecurity Framework(2014), Risk Management ▪OCTAVE(Operationally Critical Threat, Asset, and Vulnerability Evaluation)-카네기멜론 ▪SEI(Software Engineering Institute) 프로그램

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제센터의 설치·운영에 관한 법적 근거**

제10조의2(보안관제센터의 설치·운영)

① 중앙행정기관의 장, 지방자치단체의 장 및 공공기관의 장은 사이버공격 정보를 탐지·분석하여 즉시 대응 조치를 할 수 있는 기구(이하 "보안관제센터"라 한다)를 설치·운영 하여야 한다.

-중략-

③ 보안관제센터를 설치·운영하는 기관의 장은 보안관제센터의 운영에 필요한 전담직원을 상시 배치하여야 한다.

④ 보안관제센터를 운영하는 기관의 장은 필요한 경우에는 미래창조과학부장관이 지정하는 보안관제전문업체의 인원을 파견 받아 보안관제 업무를 수행하도록 할 수 있다.

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ 보안관제 전문기업

- 목적

- 국가사이버안전관리규정 제10조의2에 따른 국가 공공기관 보안관제 센터 운영을 지원할 보안관제 전문기업 지정
  (시행일 : 2011년 07월 01일)

- 사업내용

- 보안관제 전문기업 지정 심사 및 사후관리 지원
- 보안관제 전문기업 지정제도 개선

- 근거

- 국가사이버안전관리규정 제10조의2 (대통령훈령 제316호)
- 보안관제 전문기업 지정 등에 관한 공고(과학기술정보통신부 공고)
  (지정기관 : 과학기술정보통신부, 수행기관 : 한국인터넷진흥원)

- 기본 운영방향

- 공공기관 보안관제 서비스 품질을 제고함과 동시에 시장 진입장벽이 되지 않도록 지정 요건은 필요 최소한도로 설정 (경쟁 촉진을 통한 양질의 보안관제 서비스 제공 유도)
- 다만, 공공부문은 민간에 비해 침해사고 발생 시 피해규모가 크고 광범위함을 감안하여 사후관리를 강화 (매년 1회 실시)

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ 보안관제 전문기업(24개 기업 / 2026년 기준)



2. 보안관제의 이해

2-1. 보안관제의 개념

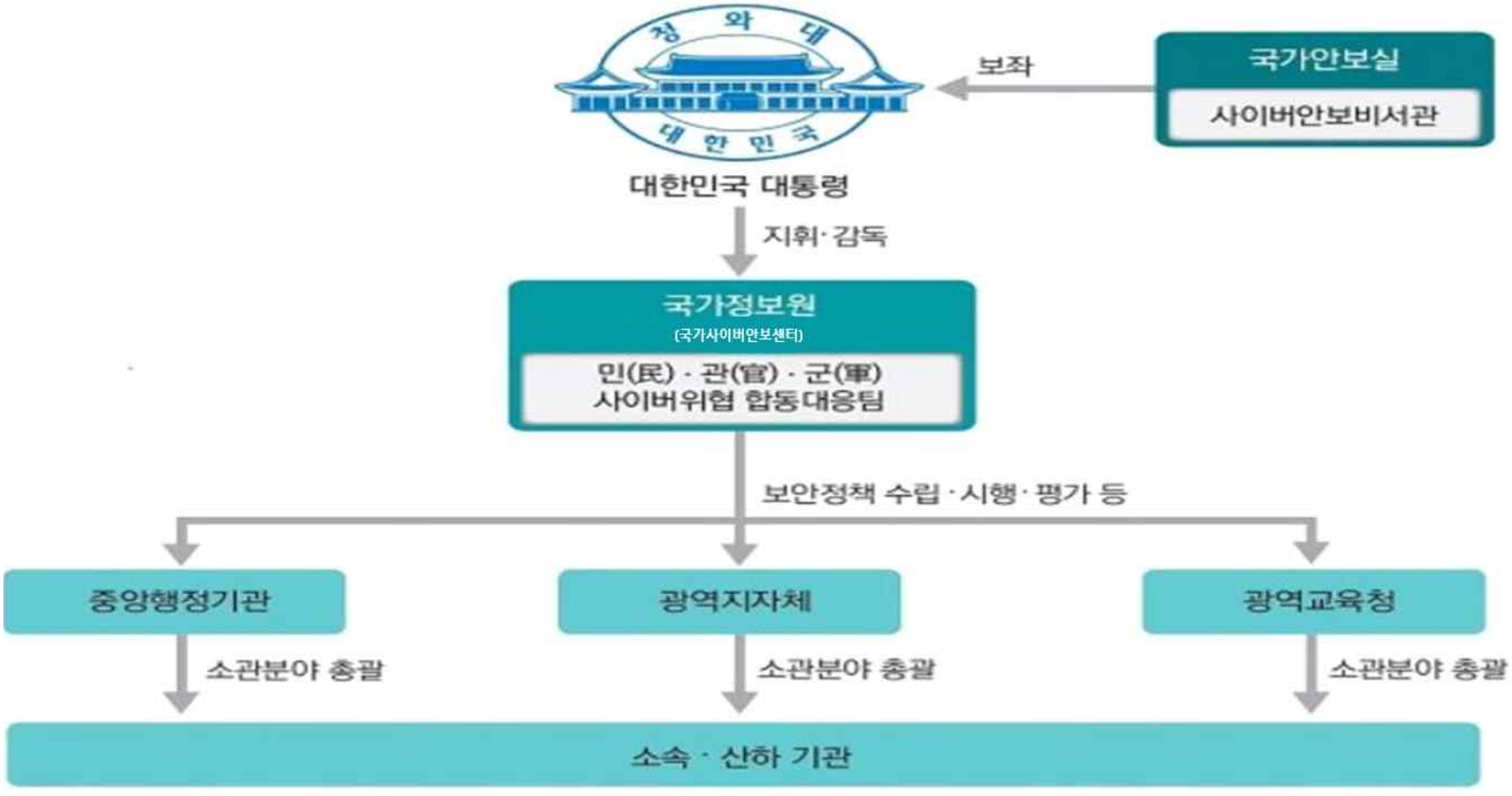
☞ SK 쉴더스 보안관제 레퍼런스(50개 사이트)



2. 보안관제의 이해

2-1. 보안관제의 개념

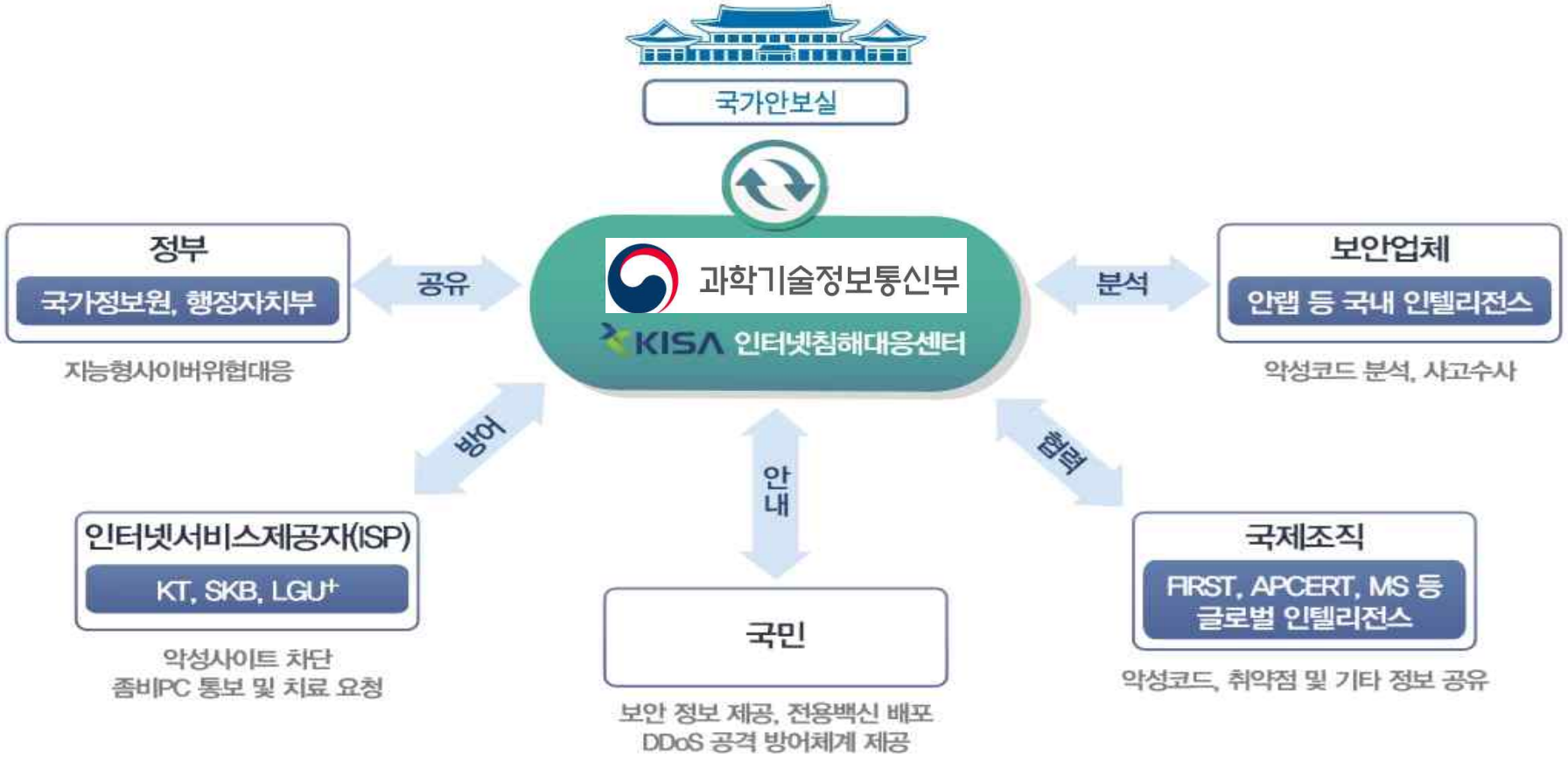
☞ 국가 사이버 안보 수행 체계



2. 보안관제의 이해

2-1. 보안관제의 개념

☞ 민간 정보통신 서비스 분야 침해사고 대응 공조체계



2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **국내 분야별 보안관제센터 역할 및 기능**

구분	국가사이버안보센터	인터넷침해대응센터	각부문별 사이버안전센터
목적	· 국가차원에서 사이버공격에 대한 종합적이고 체계적인 대응을 수행	· 국내 민간 전산망 정보보호 - 침해사고 예방을 위한 기술지원 - 실질적인 침해사고 대응 및 분석, 피해복구 기술 지원	· 사이버위협으로부터 보안전문인력에 의해 예방, 탐지, 대응활동을 통하여 정부 및 기관의 주요정보 자산을 보호
주요 업무	· 국가사이버안전 정책 총괄 - 국가사이버안전 정책 기획·조율 - 국가사이버안전 제도·지침 수립 - 민·관·군 정보공유체계 구축 및 운영 · 사이버 위기 예방활동 - 각급기관 전산망 보안 컨설팅 및 안전측정 - 사이버위기 대응훈련 - 정보보안 관리실태 평가 · 사이버공격 탐지활동 - 24X365 각급기관 보안관제 - 단계별 사이버위기 경보발령 · 사고조사 및 복구지원 활동 - 해킹사고 발생 시 사고조사 및 원인 규명 - 사이버위기 대책본부 구성·운영	· 전산망 보호침해사고 예방활동 - 침해사고 예방을 위한 기술지원 - 전산망 보안 기술 지침 개발 및 보급 · 침해사고 처리 지원 - 침해사고의 접수 - 전산망 보안 침해사고 진단 분석 지원 · 국제 사고대응 활동 참여를 위한 창구 제동 - FIRST 활동 참여 - FIRST 제공 정보의 공유	· 관제운영 - 24X365 실시간 관제 - 보안 침해사고 탐지/대응 - 보안시스템 운영 및 보안관리 · 침해사고 분석 및 대응 - 침해사고 예방 및 대응 - 보안관제를 통한 침해사고 대응 - 사고 분석 전문도구를 이용한 원인 분석 - 침해사고 복구지원 및 대응 보고서 · 보안점검 - 보안가이드라인 제공 - 서버, 네트워크, 홈페이지 취약점 진단

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **참고자료 - 사이버위기경보단계**

구분	공공	민간
	사이버위기경보(국가사이버안보센터)	인터넷침해사고경보(인터넷침해대응센터)
심각	· 국가적 차원에서 네트워크 및 정보시스템 사용 불가능 · 침해사고가 전국적으로 발생했거나 피해 범위가 대규모인 사고 발생 · 국가적 차원에서 공동 대처 필요	· 국내 인터넷 전 분야에 소통 장애 발생 · 주요정보통신기반시설의 피해로 인하여 대국민 서비스 지장 발생 · 민간 부분 전반에 인터넷 사용 불가능 · 국가적 차원에서 공동 대처해야 할 필요성이 있는 상황
경계	· 복수 정보통신서비스 제공자(ISP망 : 기간망 장애 또는 마비) · 침해사고가 다수 기관에서 발생했거나 대규모 피해로 발전될 가능성 증가 · 다수 기관의 공조 대응 필요	· 복수 ISP망 또는 주요정보통신기반시설의 피해 발생 · 해킹 및 신종위협으로 주요기업 및 포털, 연구소 등의 민간부문에 중대한 피해 발생 · 웜·바이러스, 해킹 등 침해 사고로 민간부문에 대규모 피해 발생 · 상황 해결을 위해 민간 각 분야의 협조 및 공동 대응이 필요한 상황
주의	· 일부 네트워크 및 정보시스템 장애 · 침해사고가 일부 기관에서 발생했거나 다수 기관으로 확산될 가능성 증가 · 국가 정보시스템 전반에 보안 태세 강화 필요	· 웜·바이러스, 해킹 등으로 국지적 피해 발생 · 국지적으로 인터넷 소통 장애, 인터넷 관련 서비스에 장애가 발생되거나 매우 우려가 되는 경우 · ISP/IDC, 일반 사용자, 기업 등의 긴급대응 및 보안 태세 강화가 필요

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **참고자료 - 사이버위기경보단계**

구분	공공	민간
	사이버위기경보(국가사이버안보센터)	인터넷침해사고경보(인터넷침해대응센터)
관심	· 웜·바이러스, 해킹 기법 등에 의한 피해발생 가능성 증가 · 해외 사이버공격 피해가 확산되어 국내 유입 우려 · 사이버 위협 징후 탐지 활동 강화 필요	· 위험도가 높은 웜· 바이러스, 취약점, 해킹 기법 및 공격 코드 출현으로 인해 피해 가능성 증대 · 해외에서 침해사고 확산 또는 일부 국내유입 및 확산 가능성 증대 · 국내 인터넷 이상 트래픽 발생 가능성 증대
정상	· 전 분야 정상적인 활동 · 위험도 낮음 웜·바이러스 발생 · 위험도 낮은 해킹 기법, 보안취약점 발표	· 국내 민간 분야 인터넷 정상 소통 · 인터넷 소통 및 사용에 지장이 없음 - 웜·바이러스 등 악성코드 출현 탐지 - 신규 보안 취약점 또는 해킹 기법 등 발표 · 위험도가 낮은 국지성 이상 트래픽 발생 가능성 존재

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **참고자료 – 사이버위기경보단계별 대응**

구분	대응 내용
정상	· 전 분야 정상적인 활동 상태로 위험도가 낮은 웜·바이러스가 발생되고 있는 상황
관심	· 위험도가 높은 웜·바이러스가 출현, 국내 인터넷 트래픽 폭주가 예상될 때 발령 - 사이버공격 등 이상 징후 또는 사고 발생 시 즉시 초동 조치를 취하고 각 부문 사이버안전센터에서는 국가사이버안보센터에 관련사항 통보 - 국가사이버안보센터에서 제공하는 보안권고문은 일정수준 이상의 위험성이 있는 웜·바이러스, 보안취약점, 해킹 기법 등 사이버 위협 요소에 대한 특성과 적절한 대응방법을 제공하고 있어 이에 따라 보호대책 이행 - 해외에서 피해가 확산되는 경우 사이버 위협의 국내 유입가증성이 높아짐에 따라 지속적 감시 - 라우터의 ACL. 설정 내용과 스위치, 침입차단시스템의 IP, 포트에 대한 허용 및 차단 규칙 확인 - 서비스 포트를 허용할 때는 서비스를 제공하는 특정 포트만을 허용하도록 설정하였는지 점검 - SIEM, TMS, IPS 등 보안장비의 공격 탐지 패턴 및 보안정책 정보를 확인하고 새로운 보안취약점에 대한 탐지 패턴을 등록 및 확인
주의	· 관심 경보에서 피해상황이 없다가 국지적, 부분적으로 웜·바이러스 및 해킹 사고로 피해가 발생한 상황으로 피해가 발행하면 처음으로 발령되는 단계 - 위기대처 및 사고 대응을 위하여 평시에 침해사고대응팀 운영계획을 수립 유지 - 침해사고대응팀을 비상소집 실시 및 준비태세 유지 - 업무 체계도에 따른 연락체계 확인 및 갱신(담당자 및 유지보수업체) - 침입탐지/차단/방지시스템 등을 이용하여 공격대상시스템, 서비스 포트번호 등에 대한 모니터링 강화 - 이메일이나 웹을 통해 악성코드에 감염된 경우 침입탐지/차단시스템, 이메일 서버 및 클라이언트 프로그램, 웹 프록시 서버 등에 차단규칙을 추가 - 특정 소프트웨어 배포를 통해 악성코드에 감염된 경우 해당 소프트웨어를 삭제하고 추가 설치 금지

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **참고자료 – 사이버위기경보단계별 대응**

구분	대응 내용
경계	· 복수 ISP망 또는 주요정보통신기반시설의 피해 발생 및 웜·바이러스, 해킹 등 침해사고로 민간부문에 대규모 피해 발생으로 발령 - 피해가 예상되거나 피해상황 추이에 따라 침해사고 대응팀을 투입하여 즉각적인 시스템 복구 및 피해확산 차단조치 - 서비스거부공격에 대한 이상 징후를 포착한 경우 정보보안담당자는 신속하게 라우터, 침입차단시스템 등의 차단규칙을 재설정하여 공격의 진행 차단 또는 대피소로 DNS 변경 후 공격 트래픽 우회시켜 서비스 정상화 - 데이터베이스 및 중요 서버의 자료를 백업하여 네트워크가 단절된 안전한 곳에 보관 - 악성코드, 취약점, 공격도구 등에 대한 분석정보에 따른 공격대상 시스템의 IP 또는 서비스 포트번호의 차단 상태 수시 확인 - 피해발생 가능성이 높은 네트워크를 대상으로 물리적인 케이블 분리 등의 단절 시행 여부 검토 및 필요시 기관장의 승인 하에 단절
심각	· 국가 전체적으로 통신망 두절 및 국가적인 차원에서 공동 대처가 필요한 경우의 단계, 전쟁 발생과 같이 물리적인 파괴로 인한 경우로 볼 수 있음. - 침해사고 대응팀 추가 증편, 비상근무 등 즉각적인 대응 태세에 돌입 - 피해가 발생할 기관의 정보보안 담당자는 사고와 관련된 데이터, 백업, 로그 관리 등 사고조사 및 복구에 필요한 자료 제공 - 침해사고대응팀은 유관기관(국정원, KISA 등)의 합동조사 및 복구지원팀 활동을 지원하며, 연락체계 유지 - 기관 내 PC 사용을 최소화하여 잠재적인 사고를 미연에 방지 - 서비스거부공격 및 웜 발생을 확실하게 예상하거나 내부 시스템 및 네트워크에 대규모 피해확산을 예상할 경우 기관장이 승인을 받고 즉각적으로 물리적인 케이블 분리 등을 통해 피해대상 네트워크를 단절

2. 보안관제의 이해

2-1. 보안관제의 개념

- **보안관제의 목표**
- PC 및 정보통신망을 통해 처리·유통되거나 저장되는 정보에 대한 **기밀성, 무결성, 가용성**을 보장하는것



- 처리 · 유통 중이거나 저장된 자료/정보가 비인가자에게 유출되지 않도록 하는것
- 설령 유출되더라도 자료/정보의 내용을 확인할 수 없도록 하는 것

부적절한 공개 · 노출로부터 보호하는 것

2. 보안관제의 이해

2-1. 보안관제의 개념

- **보안관제의 목표**
- PC 및 정보통신망을 통해 처리·유통되거나 저장되는 정보에 대한 **기밀성, 무결성, 가용성**을 보장하는것



- 비인가자에 의해 저장되거나 변경 또는 삭제되지 않도록 하는 것
- 인가자라 하더라도 부당한 방법으로 저장하거나 변경 또는 삭제되지 않도록 하는 것

변조 · 파괴로부터 보호하는 것

2. 보안관제의 이해

2-1. 보안관제의 개념

- **보안관제의 목표**
- PC 및 정보통신망을 통해 처리·유통되거나 저장되는 정보에 대한 **기밀성, 무결성, 가용성**을 보장하는것



- 인가자가 정보자산에 접근 또는 사용하려는 시점이 허용된 범위 이내라면 지체없이 접근 · 사용할 수 있도록 정상적인 상태로 유지하는 것

지연 · 거부 · 마비로부터 보호하는 것

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ 보안관제 기본원칙

무중단의 원칙

사이버 공격을 실시간으로 신속하게 탐지 / 차단 하기 위해서 24시간 365일 중단 없이 보안관제 업무를 수행

전문성의 원칙

보안관제업무 수행을 위해서는 사이버공격 탐지시스템 등 보안관제에 필요한 시스템과 함께 정보시스템 및 네트워크 이론을 포함한 프로그램 분석, 포렌식, 해킹기술 등 다양한 방면에 전문지식과 경험, 노하우를 가진 전문 인력이 매우 중요

정보공유의 원칙

범 국가차원에서 사이버 공격을 철저하게 탐지 / 차단 / 대응 하기 위해서는 관계 법령에 위배되지 않는 범위 내에서 보안관제 관련 정보가 신속하게 공유

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제 목적**



2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제 유형**

보안관제는 보안관제 업무를 수행하는 장소와 주체를 기준으로 분류하면 원격관제, 파견관제, 자체관제, 하이브리드관제로 분류하였고, 최근에는 클라우드 관제까지 확대됨.

구분	내용	
원격 관제	개념	관제서비스업체에서 보안관제에 필요한 관제시스템을 구비하고 대상기관 침입차단 시스템 등 보안장비 중심으로 보안 이벤트를 중점적으로 상시 모니터링하고 침해사고 발생 시 긴급 출동하여 대응 조치하는 서비스 형태임
	대상	일반 기업, 포탈 업체 등
	특징	- 일부 단위 보안시스템의 운영 및 관리를 위탁하는 방식 - 통합보안 관제시스템 및 관제인력이 원격에 위치함 - 제한적인 범위의 보안시스템 위탁
	장점	- 파견관제에 비해 저렴한 단가 인력 관리에 대한 부담이 없음 - 별도의 회선 구축 없이 인터넷망을 통한 관제
	단점	- 한정된 서비스 제공 - 파견관제와 같은 사이트에 특화된 관제 서비스의 어려움 발생 - 침해/장애 발생시 즉각적인 조치가 어려움 (통보는 가능하나 조치 인력 수급 필요)

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제 유형**

구분	내용	
파견 관제	개념	관제 대상기관이 자체적으로 보안관제시스템을 구축하고 보안관제 전문업체로부터 전문인력을 파견 받아 침해/장애 발생 시 즉각적인 관제업무를 수행하는 형태임
	대상	공공분야, 금융권
	특징	- 자체 구축한 보안관제시스템의 운영 및 관리를 위탁하는 방식 - 전문인력이 대상기관에 파견되어 관제업무 수행 - 조직전반 및 산하기관 보안관제 체제 구축 수행
	장점	- 고객사에 특화된 관제서비스 제공 가능 - 고객사 정보보호담당자와 관제 인력간의 원활한 의사소통 가능 - 침해/장애 발생 시 즉각적인 조치가 가능 - 업무 연속성 및 효율성 증대 - 고객사의 현황에 대한 명확한 이해로 추후 사이트의 확장 및 시스템 구성변경 지원 가능
	단점	- 인력 관리 필요 (휴무 및 교체 등) - 높은 단가

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제 유형**

구분	내용	
자체 관제	개념	보안관제시스템 및 전문인력을 자체적으로 구축하고 운영하는 형태임
	대상	국정원, 경찰청 등 대규모 통신사
	특징	- 자체 보안관제시스템의 운영 및 관리를 자체적으로 수행 - 기관 자체 정규직, 계약직 보안인력을 통한 관제 업무 수행
	장점	- 내부기밀유지 및 신속한 사고처리에 우수 - 정보보안 관련 기술을 보유할 수 있음 - 보안관제 업무와 관련해 연속성 보장
	단점	- 전문성의 결여로 수행 품질이 낮아질 수 있음 - 과도한 초기 투자의 예측 어려움 - 최신 보안기술/동향 정보 확보의 어려움 - 보안 솔루션 운영에 대한 부담 - 보안 전문가 양성의 어려움

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제 유형**

구분	내용	
하이브리드 관제	개념	원격과 파견관제의 장점을 고루 합한 서비스, 보안 기업의 통합보안관제센터에서 확보한 위협 정보를 원격으로 제공하여 파견관제의 한계점을 보완
	대상	금융기관 등
	특징	- 원격관제 + 파견관제 또는 원격관제 + 자체관제의 형태 - 필요한 시간(주로 야간, 휴일)에만 원격관제 형태로 관제업무 수행
	장점	- 원격관제의 장점과 파견관제의 장점을 융합 - 파견인력을 통한 의사소통 및 사이트에 특화된 정책 수립 - 침해/장애 시 파견 인력을 통한 선 조치 이후 원격관제팀과의 공조 가능 - 사이트의 구성 변경, 정책 수립 등 지원
	단점	- 파견 인력의 등급에 따른 서비스의 퀄리티 편차 발생 - 파견 인력에 대한 관리 필요(휴무 및 교체)

2. 보안관제의 이해

2-1. 보안관제의 개념

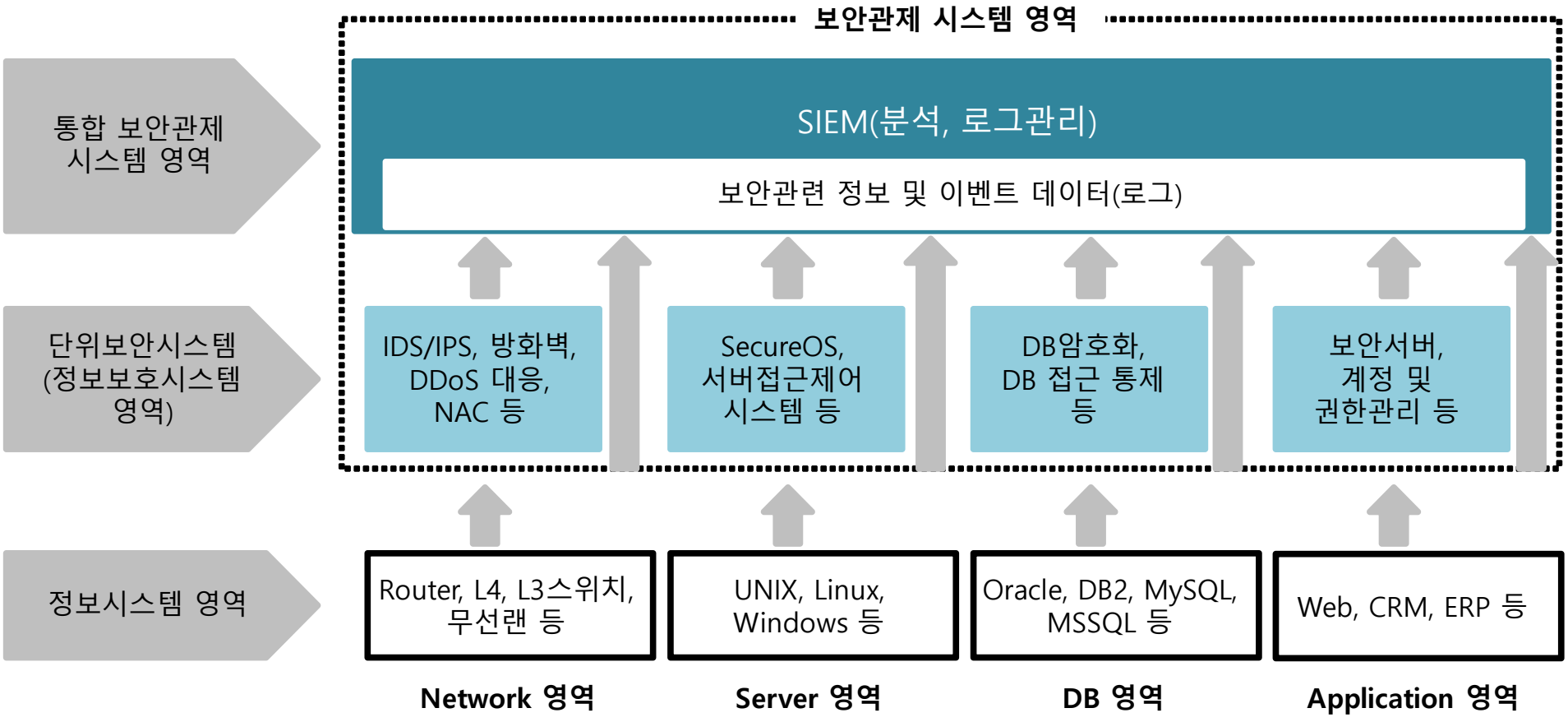
☞ **보안관제 유형**

구분	내용	
클라우드 관제	개념	서버와 DB 등 IT 자원을 인터넷 접속을 통해 사용하는 클라우드 환경에 대한 관제, 기업은 클라우드 내에서 일어나는 보안 위협을 모니터링하여 온프라미스 환경과 동일하게 보안관제 서비스를 받을 수 있음.
	대상	금융기관 등
	특징	- 보안관리 영역에 대한 직접 관리 부담을 줄이고, 모니터링 요원, CERT 등 관제전문인력이 제공하는 보안관제서비스를 제공받을 수 있다
	장점	- 로컬에 장비 설치 및 유지보수가 필요 없음 - 다양한 레퍼런스 기반으로 고객사 환경에 적합한 유동적으로 보안관제 환경을 구축 가능 - IT기술 발달로 최적화된 보안 장비를 고객사의 니즈에 최적화된 보안장비 구축 - 클라우드 글로벌 데이터 센터 보안 관제 서비스 제공 가능
	단점	- 관제 대상 및 업무 이해가 어려움. - 리스크가 매우 큼. - 고객의 비즈니스를 이해해야 하는 어려움

2. 보안관제의 이해

2-1. 보안관제의 개념

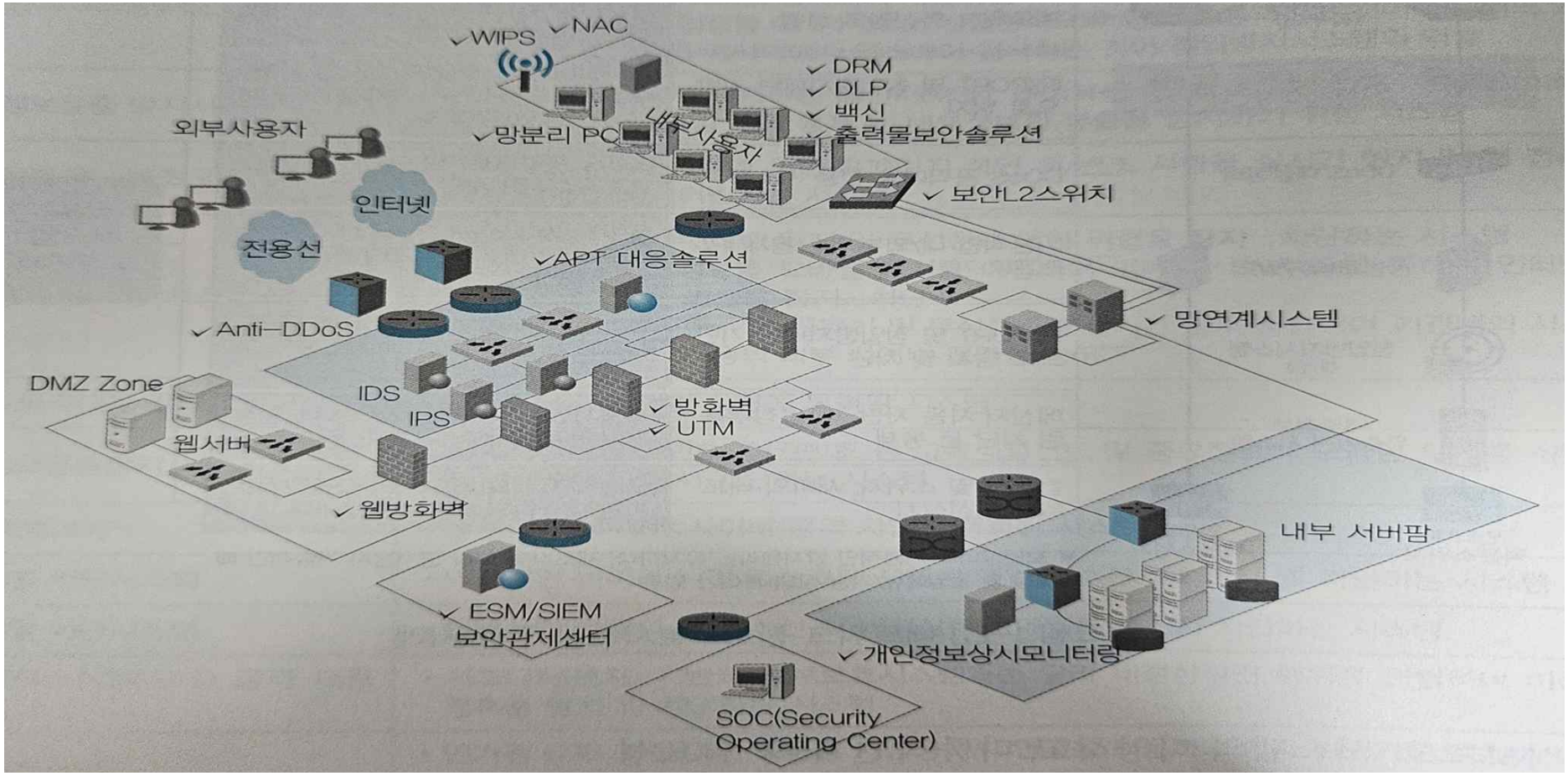
☞ **보안관제 시스템 구성 개념**



2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **영역별 정보보호시스템 구성**



2. 보안관제의 이해

2-1. 보안관제의 개념

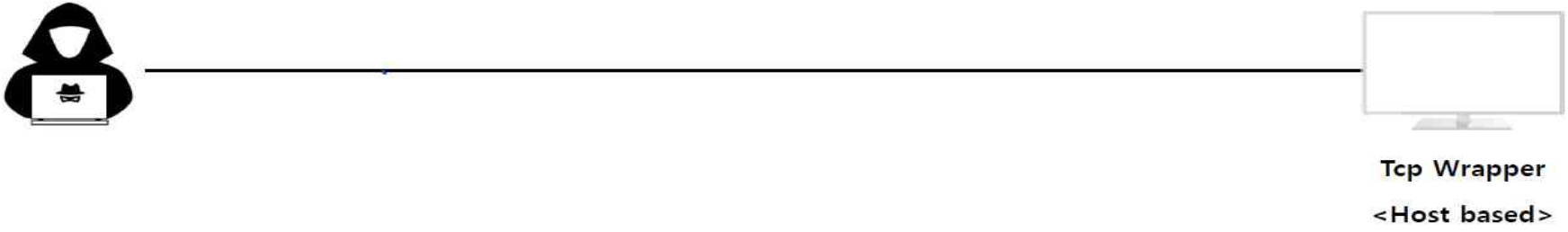
☞ 보안관제 패러다임의 세대별 변화



2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **1980년대 보안**



- 서비스를 대상으로 공격
- 서비스, 데몬, 프로세스를 방어하기 위해 TCP Wrapper 사용
- 최초의 바이러스(Brain, Elk Cloner) 등장, 최초의 백신 등장, 트로이목마 공격의 성행

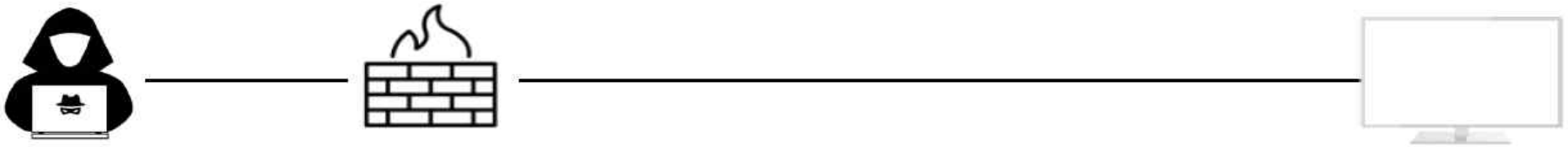
==========

- 호스트 기반의 공격, 방어
- 공격자의 IP기반으로 접근 차단 위주의 방어전략
- 서비스의 접근을 방어!

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **1990년대 보안**



1세대 방화벽(L4)

Packet Filter F/W

- 호스트 기반의 보안을 극복, 인터넷의 보급(1990년대)
- 더 쉽고 빠르게 악성프로그램을 전파 가능, 컴퓨터의 가격이 저렴해지면서 보급률↑
- 네트워크의 빠른 발전, 서비스 기반의 3~4계층의 패킷 필터링 기반 방화벽이 고안

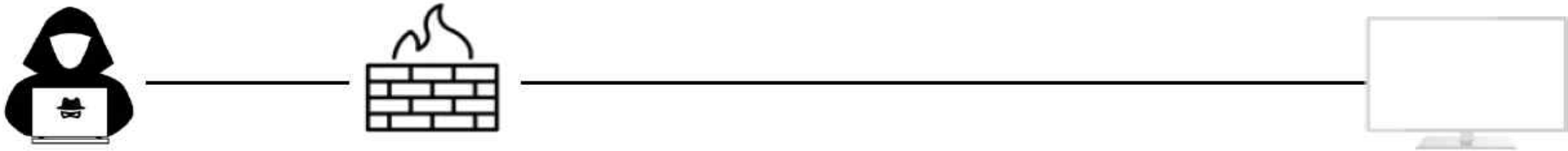
==========

- 네트워크 기반의 공격, 방어
- IP, PORT기반의 Inbound, Outbound 정책 필터링

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **1990년대 보안**



2세대 방화벽(L4)

Stateful Inspection F/W

- Inbound, Outbound 정책의 문제점을 개선, 세션 검사가 가능한 Stateful F/W 등장
- 패킷 기반 → 세션 기반
- 넷스케이프의 등장, BBS 기반의 해킹 포럼이 웹 상에서 공유되기 시작
- 1990년대 초~중반 이메일 등 웹 서비스의 발전과 보급

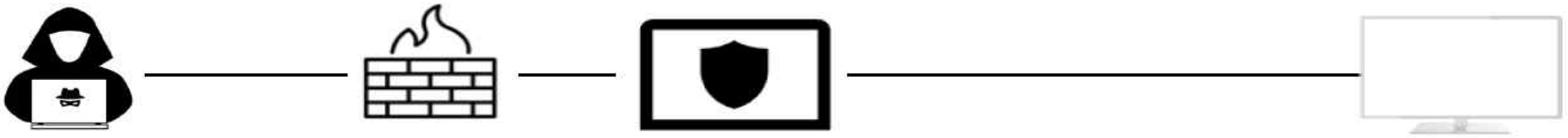
==========

- 한계점 : 패킷의 4계층까지만 필터링, Application 계층은 검증하지 않음
- 세션 기반의 방화벽 → 대규모 세션을 발생시켜 공격 → DDoS공격의 발전

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **2000년대 보안**



3세대 방화벽(L7)

Application F/W = IDS(Intrusion Detection System)

- 비정형 데이터를 탐지하기 위해 정규 표현식을 사용
- IP, PORT 대신 정규 표현식 기반의 정책 사용 → 오탐과 미탐의 발생
- 해당 공격의 검증이 필요해짐(이상징후 발생 → Alert) → 전문가의 검증

==========

- 대규모 DDoS, 개인정보 유출공격이 유행
- Application의 종류가 다양해지면서 취약점이 증가, 공격하기 시작 → 익스플로잇

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **2000년대 보안**



- Zero day attack 등 알려지지 않은 공격이 많아지고, 공격 발전 속도가 빨라짐.
- 공격의 탐지와 동시에 실시간으로 차단 → 자동적인 사고 대응(사람의 개입↓)
- OS, Application Log, API 등 비 정상행위 발생시 실시간 차단

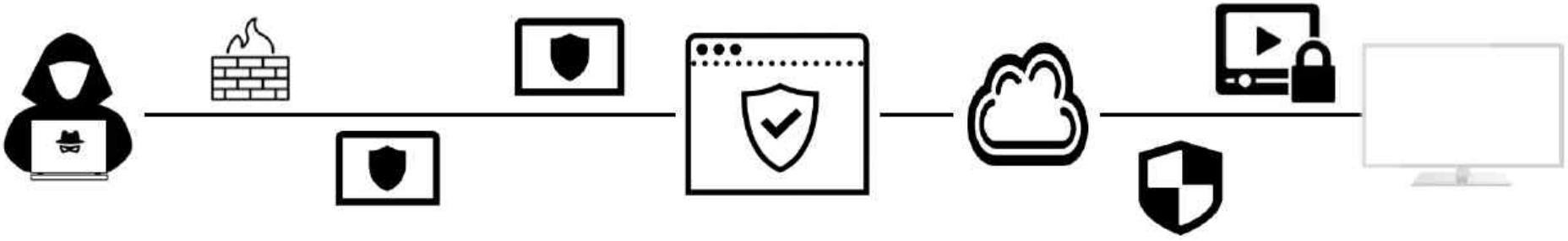
==========

- 공격방식의 발전에 따라 방어체계가 발전한다는 대표적인 사례(IDS의 한계점, 보완필요성)
- 방어체계가 발전하여 다시 공격방식의 발전이 이루어짐 → APT 공격

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **2010년대 보안**



- APT 공격의 발전(침투 → 탐색 → 수집 → 유출)
- 공격자들의 목적, 사상이 발전하면서 해킹그룹이 만들어지고, 오랜 시간동안 공격을 수행
- 다양한 공격 방식을 조합하여 보안장비를 무력화하며 침투를 수행
- 단발적인 공격이 아닌 장기간(년 단위...)

==========

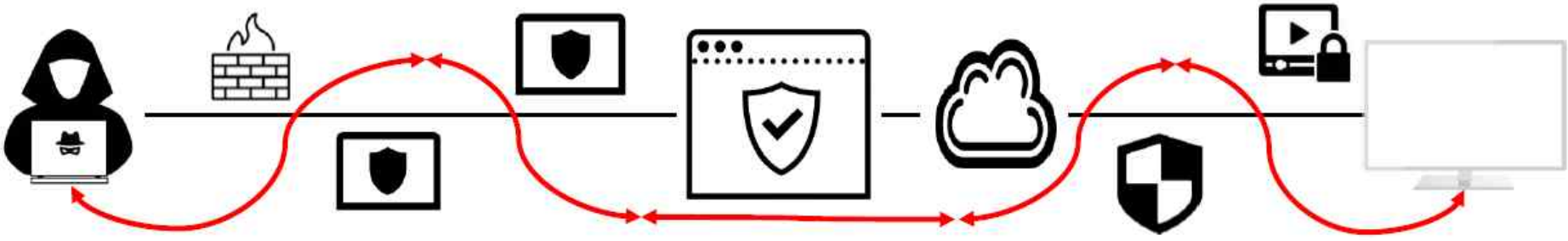
=

- WAF, DRM, DLP, CDR 등등
- SIEM, CTI...

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **2010년대 보안**



- APT 공격의 발전(침투 → 탐색 → 수집 → 유출)
- 공격자들의 목적, 사상이 발전하면서 해킹그룹이 만들어지고, 오랜 시간동안 공격을 수행
- 다양한 공격 방식을 조합하여 보안장비를 무력화하며 침투를 수행
- 랜섬웨어, 타겟형 공격, 공급망공격

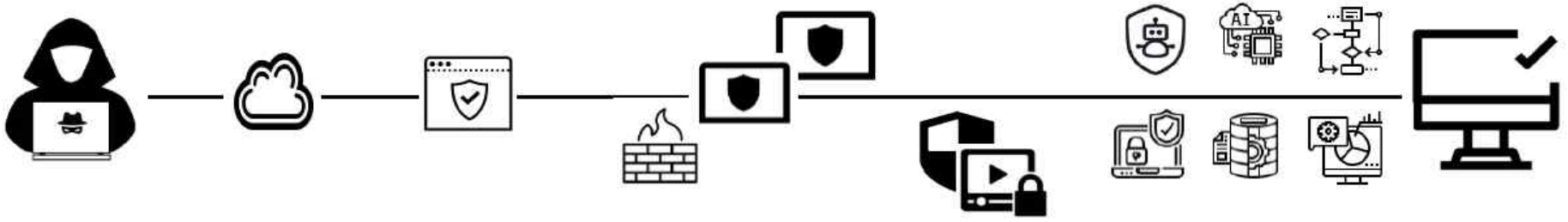
==========

- WAF, DRM, DLP, CDR 등등
- 샌드박스 기반의 APT 공격 방어

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **현재**



- 다시 한번 호스트 단위의 보안 집중(기술력의 발전 → 빅데이터, AI...)
- 완벽한 보안은 불가능
- 인프라 공격, 사이버전쟁, 국가단위 해킹공격, 대규모 공격
- MaaS(Mobility as a Service), RaaS(Ransomware as a Service)...

==========

- EDR, XDR, EPP...
- SOAR, Machine Learning, AI...

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **관제시스템에 따른 분류**

- 네트워크에 대한 유해 트래픽 등 네트워크 공격에 대한 모니터링

: 네트워크를 통해 발생하는 사이버 위협에 대해 침입탐지시스템(IDS), 침입방지시스템(IPS), 침입차단시스템(Firewall), 위협관리시스템(TMS) 등을 이용하여 네트워크 유해 트래픽, 홈페이지 공격, 서버/네트워크 장비에서의 악성코드 발생 등 분야별로 사이버 보안관제를 수행

- 웹 공격에 대한 모니터링

: 웹방화벽(WAF)의 탐지로그와 웹서버의 웹로그를 분석하여 웹 공격 유무를 실시간으로 모니터링하고, IDS와 방화벽의 로그를 비교 분석하여 공격을 탐지하기도 함.

- 서버 및 네트워크 장비에 대한 공격 모니터링

: 서버나 네트워크 장비에서 발생하는 장애 혹은 비정상적 상황에 대해 서버관리시스템, 네트워크 관리시스템을 통해 수집된 정보와 보안솔루션에 발생된 정보의 연관성을 조사하여 사이버공격을 조사

- 사용자 컴퓨터 모니터링

: 사용자 컴퓨터에서 악성코드에 의해 외부 인터넷상으로 트래픽이 나간다면 네트워크 접근통제시스템(NAC), APT 시스템, 백신 등을 통해 트래픽을 모니터링함

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **통합 보안관제 시스템을 이용한 보안관제**

- 다수의 시스템으로부터 수집된 정보를 종합적으로 분석하는 통합 보안관제 시스템을 이용하는 방법
- 주로 ESM에 방화벽, IDS, WAF 등 보안장비에서 발생하는 이벤트를 종합적으로 수집/분석하여 신속하게 공격을 탐지
- 최근에는 기존 ESM을 통한 모니터링 뿐만 아니라 내부적인 보안정책 준수, 응용시스템 및 클라이언트 단말에서 생성되는 이벤트 및 로그 분석까지 포함하는 전체 정보시스템 관제를 위해 주로 SIEM (Security Information and Event Management)을 구축하여 연동함.

: 서버나 네트워크 장비에서 발생하는 장애 혹은 비정상적 상황에 대해 서버관리시스템, 네트워크 관리 시스템을 통해 수집된 정보와 보안솔루션에 발생된 정보의 연관성을 조사하여 사이버공격을 조사

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제 인력의 역할**

구분	역할
주간 보안관제 주요업무	- 실시간 모니터링 업무 수행 - 탐지 이벤트 분석업무 수행 - 일일뉴스, 보안이벤트 보고서 작성 - 일일보고, 주간보고서 작성(초안) - 월간보고, 연간보고 자료작성 - 기타 지원업무 작성
야간,주말, 휴일 보안관제 주요업무	- 실시간 모니터링 업무 수행 - 탐지 이벤트 분석업무 수행 - 야간, 주말, 휴일 근무일지 작성 - 일일보고 / 주간보고서 작성 완료 - 해킹 시도 시 CERT 발동

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제 인력의 역할**

구분	역할
보안관제담당자 역할	-보안관제 조직 관리 -보안관제 관련 의사결정 산출물에 관한 검토 -보안관제 범위, 품질, 일정, 위험요소 등 전반 관리 -기타 보안관제를 위해 필요한 업무
전문 업체 관제인력의 역할	-24시간 365일 보안관제 서비스 제공 -최신 정보보호 관련 정보 수집· 전파 -보안관제 대상 정보시스템 보안관제 연계 시 업무지원 -보안관제 대상 보안이벤트 모니터링,추이 파악 -보안관제 이벤트의 정합성에 대해 주기적으로 검토 및 개선 -일일,주간,월간,반기,연간 등 보안관제 보고서 작성 -보안관제 대상 중 외부 공격영역 서버 취약점 진단

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제 전문업체가 갖추어야 할 기본 스펙**

구분	역할
관제시간	- 24 *365 실시간 보안관제 - 평일 주간 : 전문 인력상주 - 평일 야간 휴일 : 제안업체 실시간 원격 관제
관제방법	- Firewall, IDS, IPS, DDoS, 좀비탐지 솔루션 등 로그(이벤트)를 종합적으로 분석하여 불법 침해 여부 및 공격방법 등을 탐지 - 정기(일/월) 및 비정기 관제보고서 제공
침해사고대응	- 주요 해킹 시도 및 해킹사고 발생 시 담당자에게 구두, 전화, SMS 등으로 즉시 통보하고 해킹 방법 분석 및 추적 등의 침해사고 대응방안 제공 - 내/ 외부 주요 공격 해킹사고 발생 시 보안관제 제공 - 최신 해킹패턴,보안기술,보안동향 등을 정보수집 및 제공
서비스품질 (SLA)	- 제공 서비스의 품질측정을 위한 평가항목, 목표기준, 지표분석 방법 및 가중치 등을 포함하는 SLA(Service Level Agreement : 서비스수준협약) 안 을 제출하여야 함. - 보안관제,대응,분석 등은 사전 정의된 SLA 및 대응매뉴얼에 따라 응하여야 함

2. 보안관제의 이해

2-1. 보안관제의 개념

☞ **보안관제 전문업체가 갖추어야 할 기본 스펙**

구분	역할
보안관제 인력	- 투입 인력은 미래창조과학부 공고 제2014-089호 (2013. 6. 17)「보안관제 전문업체 지정 등에 관한 공고」에서 정하는 기술인력의 자격기준에 따름 - 보안시스템 및 정보보호시스템 운영 등의 경험 을 보유하고,침해사고 발생 시 긴급대응이 가능하여 야 함 - 보안관제, 보안사고 대응 등의 보안관제 전반적인 업무를 수행 - 정기적으로 시행되는 사이버공격 대응 모의 훈련을 지원하여야 함 - 일일/ 월간, 비정기 보안관제 보고서,최신 보안 뉴스 동향 보고서를 제공하여야 함 - 사업 수행 품질저하 현상이 발생하는 경우,투입 인력 교체를 요구할 수 있으며 수행사의 합리적인 사유가 없을 경우 당사의 요구사항을 수용하여야 함 - 투입인력의 사고,이직,휴가 및 교육 등 업무수행 이 불가한 경우를 대비한 대체 인력 구성 및 원활 한 업무수행 방안을 제시하여야 함 - 투입인력 교체 시 당사의 허가를 득한 후 사전 한 달 이상 업무 인수인계 후 교체하여야 함(단,동 이상의 인력으로 교체)

2-2. 보안관제 업무 개요

☞ 보안관제 수립 절차

- 1단계 : 환경분석

  위험/공격유형별 이벤트 탐지, 정보시스템 현황(네트워크, 서버, 앱, PC), 과거 침해사고 발생 현황 분석

- 2단계 : 체계수립

  침해시도유형(패턴) 정의 및 최적화, 블랙리스트 등록, 경고 메일 발송, 보안관제 및 정보보호 시스템 유지보수, 월간 보안관제 보고에 대한 절차와 조직별 역할 정의

- 3단계 : 보안관제 운영

  보안관제시스템에서 발생되는 이벤트에 대해 모니터링하고 공격을 탐지, 공격이 탐지된 경우 공격자의 IP, 차단 등 긴급 대응조치를 취한 후 미리 수립된 대응 절차에 따라 관련 부서에 통보하고 해당 공격관련 시스템의 영향도와 취약점을 분석

  주간/월간 보안관제 보고 등 정해진 기간의 사이버공격 탐지 및 대응 등 운영결과 보고

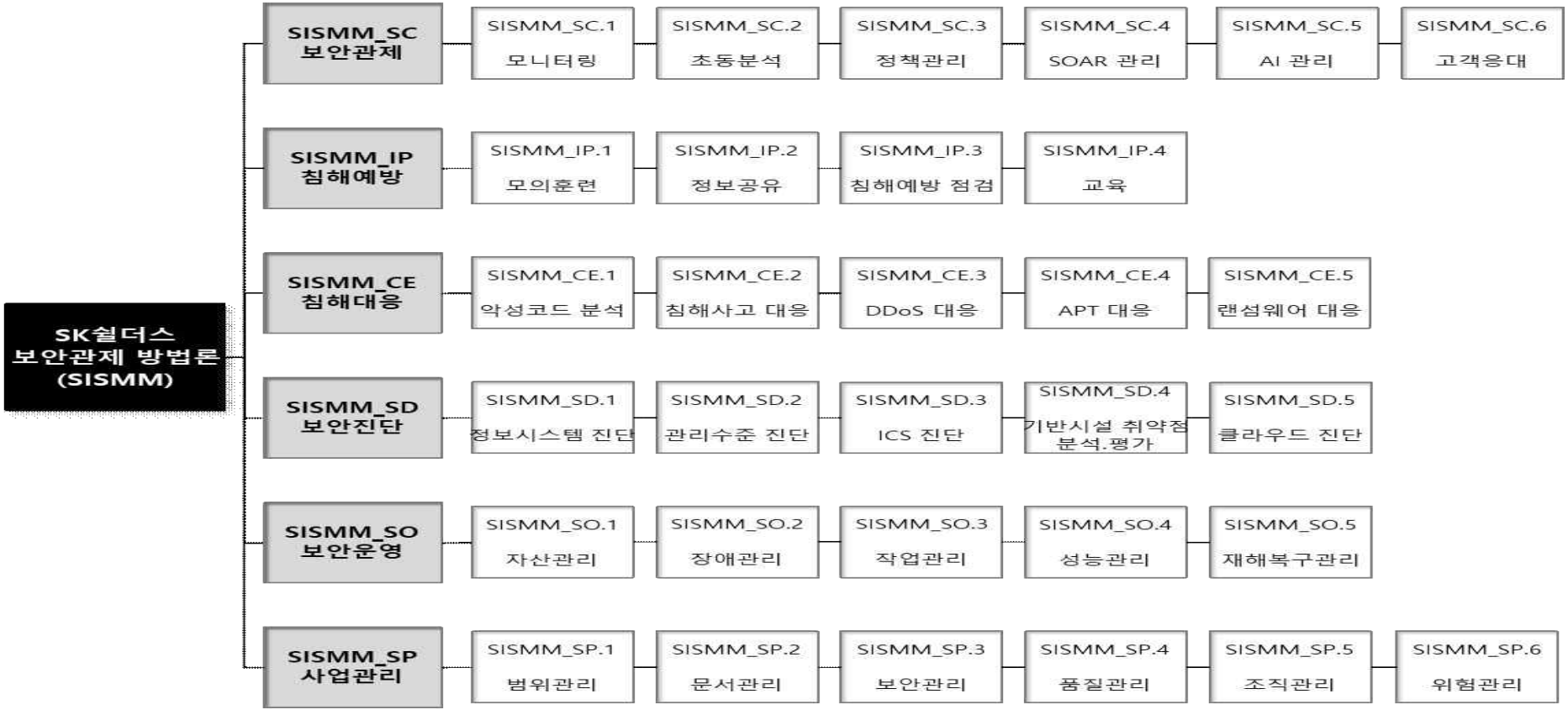
2-2. 보안관제 업무 개요

☞ **보안관제 상세 활동**

구분	활동	내용
예방	보안패치	서버, 네트워크, 응용프로그램 등에 발생된 보안취약점에 패치를 통해 제거하는 활동
	취약점 점검	시스템 및 네트워크에 주기적인 취약점 점검 및 조치 활동
	정책관리	IDS, IPS, F/W, N/W 등 보안정책 적용 활동
	모니터링	침입로그, 싯템 로그 등 각종 이벤트에 대한 확인하는 활동
탐지	NMS, Alert	네트워크 및 시스템에서 제공하는 예·경보 탐지 활동
	시스템 장애 이벤트	각종 시스템 장애에서 발생되는 경보에 대한 탐지 활동
	관리적 이벤트	기타 관리에 필요한 각종 이벤트에 대한 탐지 활동
대응	웜·바이러스	웜, 바이러스, 백도어, 악성 봇 등 악의적인 프로그램 감염에 대한 대응
	스캐닝	악의적인 의도로 시설에 관련된 정보 수집하는 활동
	침해사고	주요 시스템에 불법적인 접근을 시도 권한을 획득하는 활동
	기타 사고대응	정상적인 활동에 대한 대응 활동(사이버 시위 등)

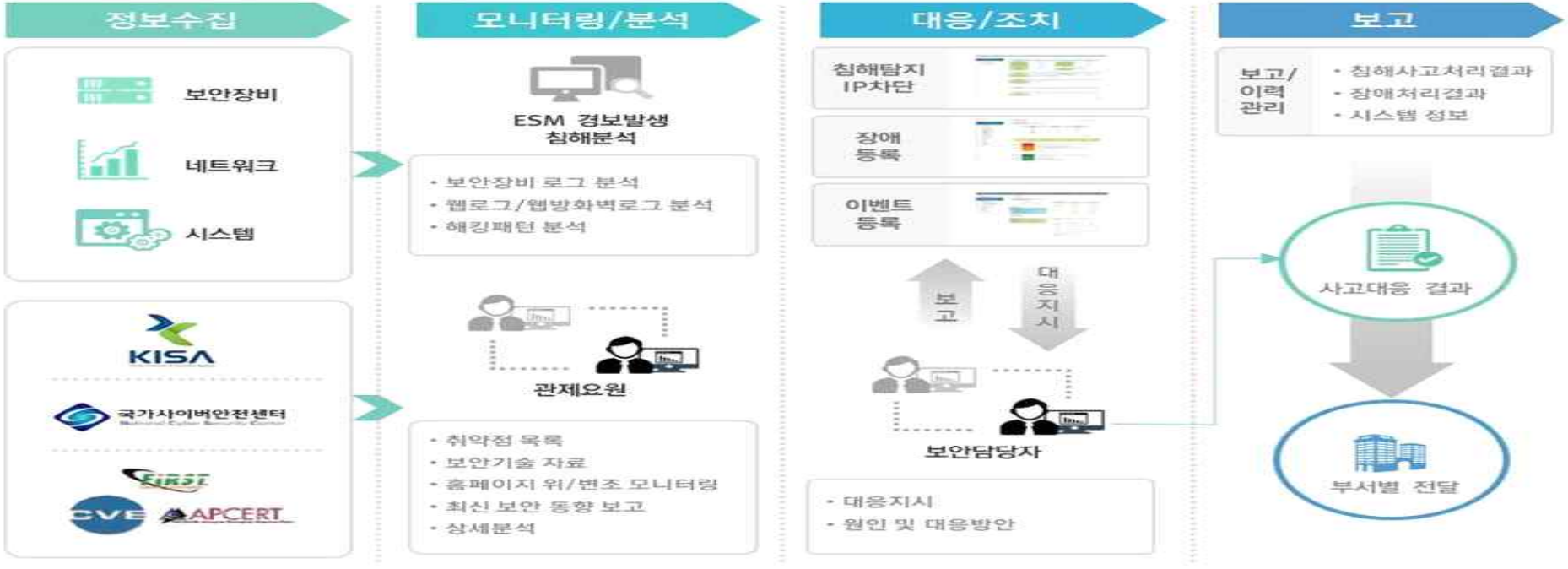
2-2. 보안관제 업무 개요

보안관제 업무는 침해탐지와 직접적인 관련이 있는 침해사고 탐지 및 대응업무를 중심으로 침해위협 정보 수집 및 관제시스템 운영업무와 더불어 프로젝트 또는 사업관리까지를 포함

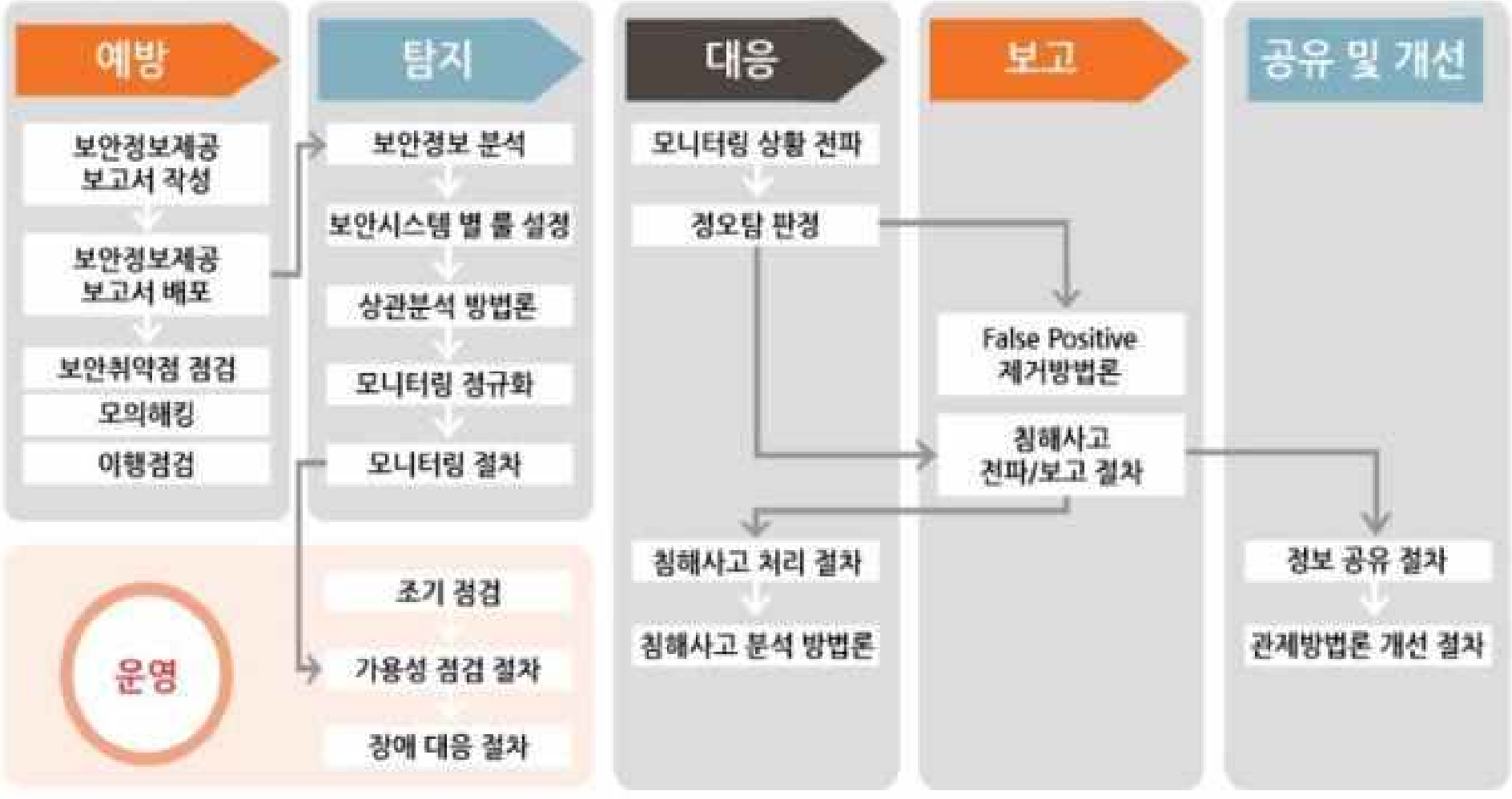


2-2. 보안관제 업무 개요

- ☞ 정보 수집 단계 : 이기종의 보안 장비에서 나오는 다양한 보안 데이터를 수집
- ☞ 모니터링/분석 단계 : 수집된 다양한 로그(경보 발생에 따른 침해사고 및 해킹 패턴)를 기반으로 분석하고, 생성된 보안 로그와 내·외부에서 수집된 최신 보안 위협 정보를 상관 분석함
- ☞ 대응/조치 단계 : 분석된 이벤트에 대한 원인 및 대응책을 마련해 기술적/정책적 대응
- ☞ 보고 단계 : 침해사고 처리 및 장애 처리 결과를 보고 및 공유



2-2. 보안관제 업무 개요


예방
보안정보제공 보고서 작성
보안정보제공 보고서 배포
보안취약점 점검
모의해킹
이행점검
탐지
보안정보 분석
보안시스템 별 룰 설정
상관분석 방법론
모니터링 정규화
모니터링 절차
대응
모니터링 상황 전파
정오탐 판정
보고
False Positive 제거방법론
침해사고 전파/보고 절차
공유 및 개선
정보 공유 절차
관제방법론 개선 절차
침해사고 처리 절차
침해사고 분석 방법론
운영
조기 점검
가용성 점검 절차
장애 대응 절차

2-2. 보안관제 업무 개요

☞ 예방 : 중요 시스템, 네트워크 및 웹 서비스 등 취약점을 사전에 파악하여 침해 사고 예방
- 사이버위협 정보(최신 위협 및 해킹 등 보안동향 정보)를 제공하여 방어토록 함.
- 침입차단시스템, 침입탐지시스템, 웹 방화벽 등 보안 시스템에 대한 보안정책 및 시스템 자원의 최적화를 통해 효율적인 사이버공격 탐지를 지원

☞ 탐지 : 보안 시스템에 대한 24시간×365일 실시간 감시 탐지 및 분석을 의미
- 네트워크 트래픽 정보 및 내부 정보를 절취하기 위한 사이버공격 시도 행위를 사전에 알아내는 행위
- 네트워크 패킷 및 다양한 보안 이벤트(공격자정보/시간/방법 등) 등을 종합적으로 상관분석하여 재발 방지 및 확산을 방지하기 위한 방안을 강구

☞ 대응 : 기관의 시스템 환경을 고려한 보안 정책 설정 및 보안관제 업무 시 발견된 비정상 네트워크 및 시스템에 대한 초기 대응 그리고 사이버 공격 발생 시 신속히 조치 대응
- 해당 기관의 시스템 환경을 고려하여 보안 정책을 설정
- 보안관제 업무 시 발견된 비정상적인 네트워크 및 시스템에 대해 기술적/정책적 대응
- 사이버 공격 발생 시 관련 사실을 해당 기관에 통보하고 피해 시스템 유무 파악 및 정상적으로 운영될 수 있도록 전문 기술 지원과 유사(동일)한 공격을 방지할 수 있도록 업무활용

2-2. 보안관제 업무 개요

☞ 보고 : 관제 일지, 취약점 정보, 침해 사고 대응 분석 보고서 등을 보고 및 관리

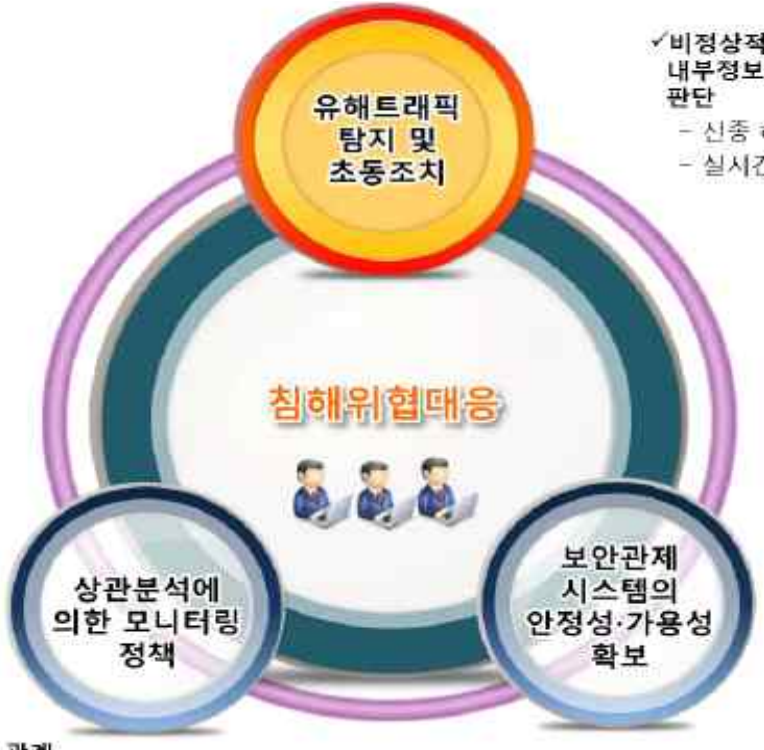
- 보안관제 업무 수행 시, 정기보고서(일간/주간/월간) 및 수시보고서를 통해 현재의 상태를 관리
- 보안사고 사고 및 장애 발생 시, 관련 처리 보고서를 작성 및 보고함으로써 발생한 사고의 원인, 대응, 결과를 통해 향후 대책을 마련

☞ 공유 및 개선 : 보안관제 주요 업무 중 정보 공유의 원칙에 따라 타 기관에게 정보를 제공

- 사이버 공격으로 인한 피해가 타 기관으로 확산되는 것을 방지하기 위하여 관계 법령에 위배되지 않는 범위에서 보안 관제 관련 정보를 공유
- 해당 보안 문제가 발생되지 않도록 기술적이고 정책적으로 개선 조치하여 보안 사고가 발생되지 않도록 예방

2-2. 보안관제 업무 개요

보안관제를 통해 체계화된 대응활동을 수행하여 침해사고에 대한 신속한 대응을 보장하고 피해를 최소화 함

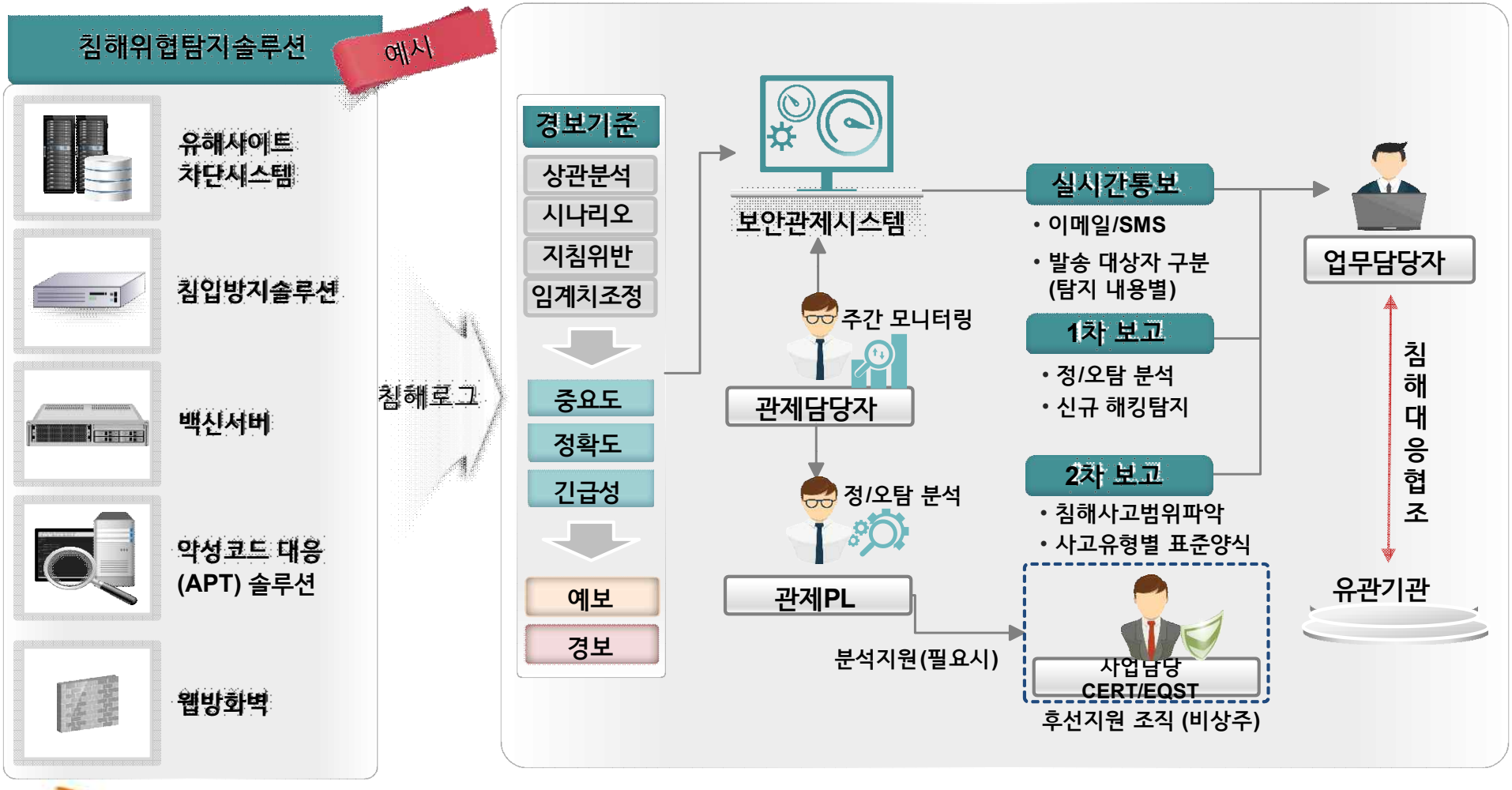


✓비정상적인 트래픽을 탐지 분석하여 내부정보유출 차단 및 침입시도여부 판단
- 신종 해킹 패턴에 대한 분석
- 실시간 대응 활동

✓보안관제 서비스로 시스템 자산에 연속성 확보 및 가용성 점검으로 안정성을 확보함
- 보안관제시스템 성능, 자원, 무결성 등 이상유무 모니터링
- 장애발생 시 원인분석 및 대응
- 주기적 시스템, DB 백업 활동

✓이기종의 다양한 침입탐지 패턴 관계 분석으로 침입 정/오탐을 분석함
- 단위 보안시스템의 탐지 정책 설정
- 상관분석 룰 및 임계값 통제

2-2. 보안관제 업무 개요


침해위협탐지솔루션
예시
유해사이트 차단시스템
침입방지솔루션
백신서버
악성코드 대응 (APT) 솔루션
웹방화벽
침해로그
경보기준
상관분석
시나리오
지침위반
임계치조정
중요도
정확도
긴급성
예보
경보
보안관제시스템
주간 모니터링
관제담당자
정/오탐 분석
관제PL
분석지원(필요시)
실시간통보
• 이메일/SMS
• 발송 대상자 구분 (탐지 내용별)
1차 보고
• 정/오탐 분석
• 신규 해킹탐지
2차 보고
• 침해사고범위파악
• 사고유형별 표준양식
사업담당
CERT/EQST
후선지원 조직 (비상주)
업무담당자
침해대응협조
유관기관

2-2. 보안관제 업무 개요



데이터 수집 및 관리

이기종
보안이벤트 수집

사고 분석

보안이벤트 분석
사고 이관/처리

위험도 분석

연계 기관별
위험도 분석

공격 성향 분석

Top/Trend
분석

정보공유포털

사고접수/통보
침해사고 처리내역 확인
보안정보공유
예경보발령

보안 위반 예·경보

통합보안 관제 모니터링

침해사고 등록/ 처리결과 조회

내부포털

침해사고 전파
Black List 등록
보안권고문 배포
침해사고 전파 현황관리

위협관리시스템

유해트래픽
분석 정보

홈페이지 개인정보

• 홈페이지 개인정보 노출점검 시스템

이기종 보안장비

상관분석 정보

2-3. 보안관제 구성요소

보안관제는 크게 보안관제 정보를 수집하기 위한 보안관제 시스템과 보안관제 조직으로 구성

구분	시스템명
네트워크 영역	▪ 침입탐지시스템(IDS) ▪ 침입차단시스템(방화벽 / IPS) ▪ DDOS 대응 솔루션 ▪ TMS(Threat Management System) ▪ UTM(Unified Threat Management) ▪ NAC(Network Access Control)
서버 영역	▪ 웹방화벽(WAF) ▪ 보안운영체제(SecureOS) ▪ 백신(Anti-Virus)
통합 및 분석	▪ ESM(Enterprise Security Management) ▪ RMS(Risk Management System) ▪ SIEM(Security Information and Event Management)

2-3. 보안관제 구성요소(보안관제시스템 측면)

☞ 전송-에이전트
- 에이전트는 각종 보안 장비 및 서버, 네트워크에 설치되어 해당 시스템에 적합한 설정에 따라 로그 정보를 실시간으로 관제센터에 전송
- 이렇게 전송된 정보를 통해 관제센터에서는 로그를 손쉽게 분석할 수 있음.

☞ 저장 - 정보수집서버
- 정보수집서버는 각각의 에이전트에서 보낸 다량의 정보를 수집/처리하여 DB에 저장하는 역할을 수행
- 이때 에이전트에 대한 확인 작업을 통해 모니터링 과정 및 분석과정에 요구되는 각종 리포팅 소스를 제공

☞ 분석 - 통합관제용 시스템
- 통합관제용 시스템은 각종 이벤트 로그분석 수행과 다양한 정보를 종합적으로 분석하는 것은 물론 상황에 따라 분석하여 관제담당자들을 지원

2-3. 보안관제 구성요소

보안관제는 크게 보안관제 정보를 수집하기 위한 보안관제 시스템과 보안관제 조직으로 구성

구분	업무
관제	▪ 24시간 365일 보안관제시스템에서 발생한 이벤트 모니터링 / 보고 / 대응 조치 수행
침해대응(CERT)	▪ 모니터링으로 확인된 이상 트래픽이나 이벤트에 대해 침해여부에 대한 상세 분석과 대응 조치 수행
정보공유분석센터	▪ 유사업무 분야별 해킹, 바이러스 등 사이버 공격과 침해사고에 대해 효과적으로 공동 대응하기 위한 조직

2-4. 보안관제 업무 절차

☞ 보안관제 수립

- 1단계 : 환경분석

  위험/공격유형별 이벤트 탐지, 정보시스템 현황(네트워크, 서버, 앱, PC), 과거 침해사고 발생 현황 분석

- 2단계 : 체계수립

  침해시도유형(패턴) 정의 및 최적화, 블랙리스트 등록, 경고 메일 발송, 보안관제 및 정보보호 시스템 유지보수, 월간 보안관제 보고에 대한 절차와 조직별 역할 정의

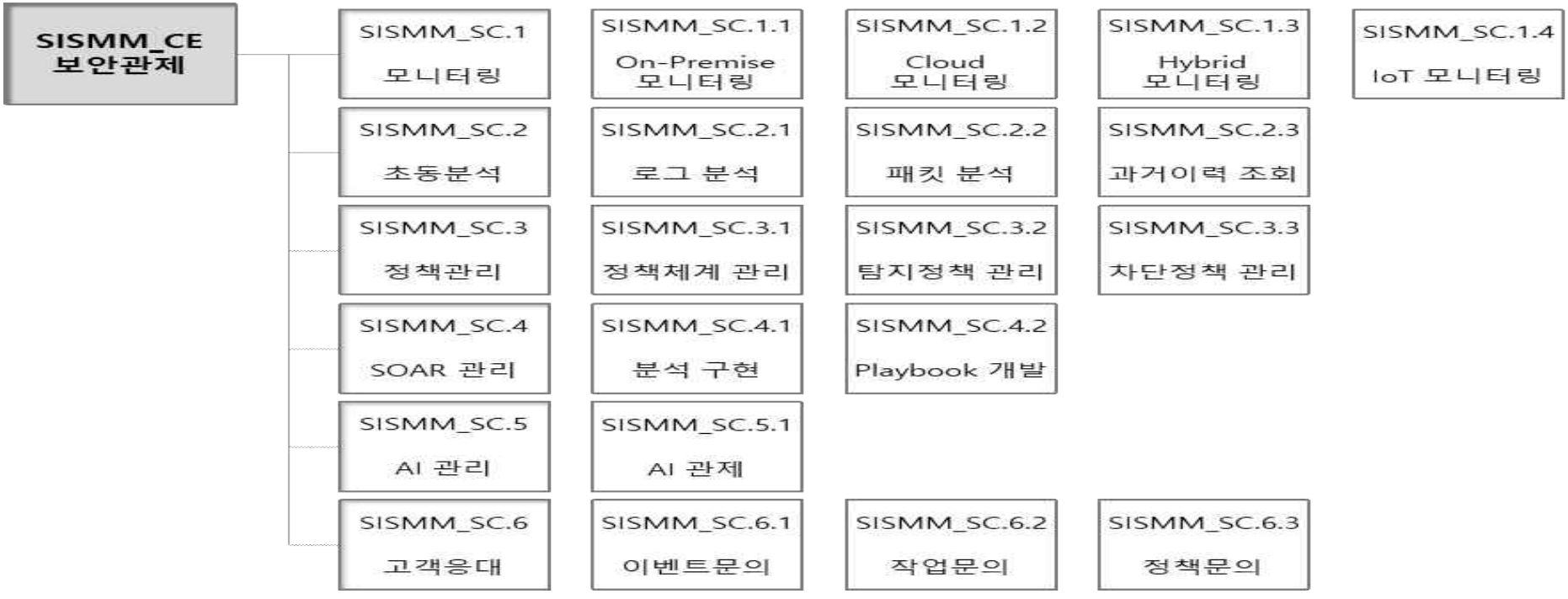
- 3단계 : 보안관제 운영

  보안관제시스템에서 발생되는 이벤트에 대해 모니터링하고 공격을 탐지, 공격이 탐지된 경우 공격자의 IP, 차단 등 긴급 대응조치를 취한 후 미리 수립된 대응 절차에 따라 관련 부서에 통보하고 해당 공격관련 시스템의 영향도와 취약점을 분석

  주간/월간 보안관제 보고 등 정해진 기간의 사이버공격 탐지 및 대응 등 운영결과 보고

2-4. 보안관제 업무 절차

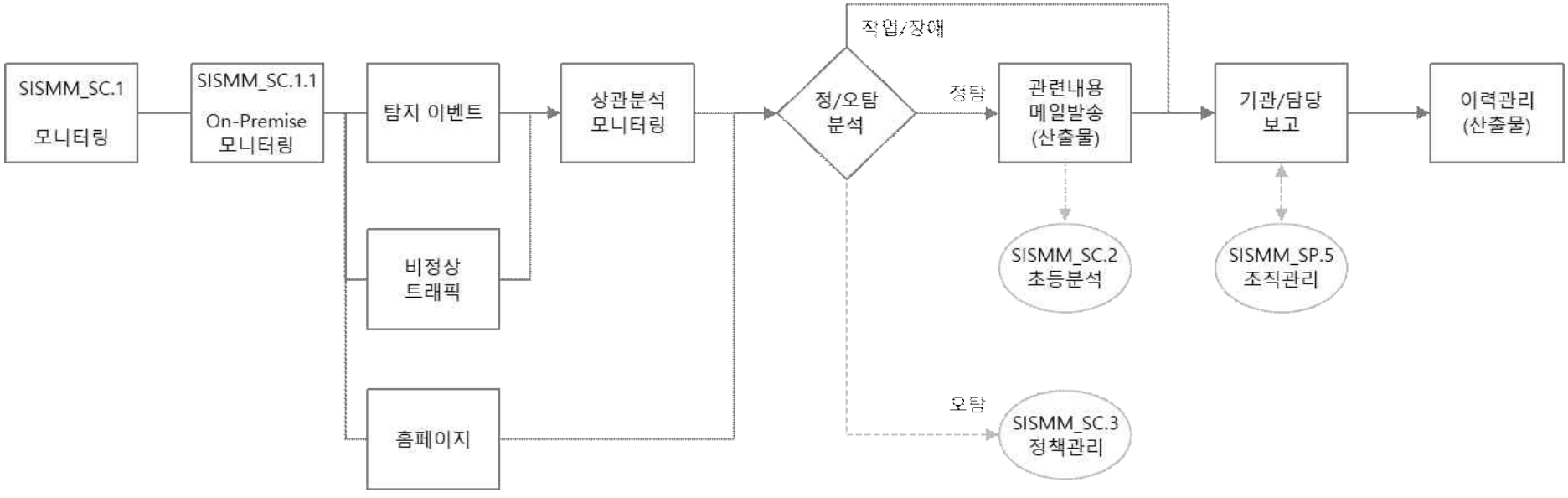
보안관제 업무 프로세스는 비정상 이벤트 및 트래픽, 홈페이지, 시스템 가용성을 모니터링하고 정오탐 판별 후 보고 및 이력관리를 통해 지속적으로 탐지정책을 고도화시켜 효율적인 실시간 대응을 수행함.



2-4. 보안관제 업무 절차(모니터링)

☞ **On-Premise (legacy 환경) 모니터링 (1/2)**

- 단위 보안장비 이벤트, 관제시스템 연동된 이벤트, Alert 등의 발생여부를 실시간 감시하고, 이상 발생 시 전파, 대응하는 업무
- 단위 보안장비, 관제시스템을 통해 모니터링하고 대응함



2-4. 보안관제 업무절차(모니터링)

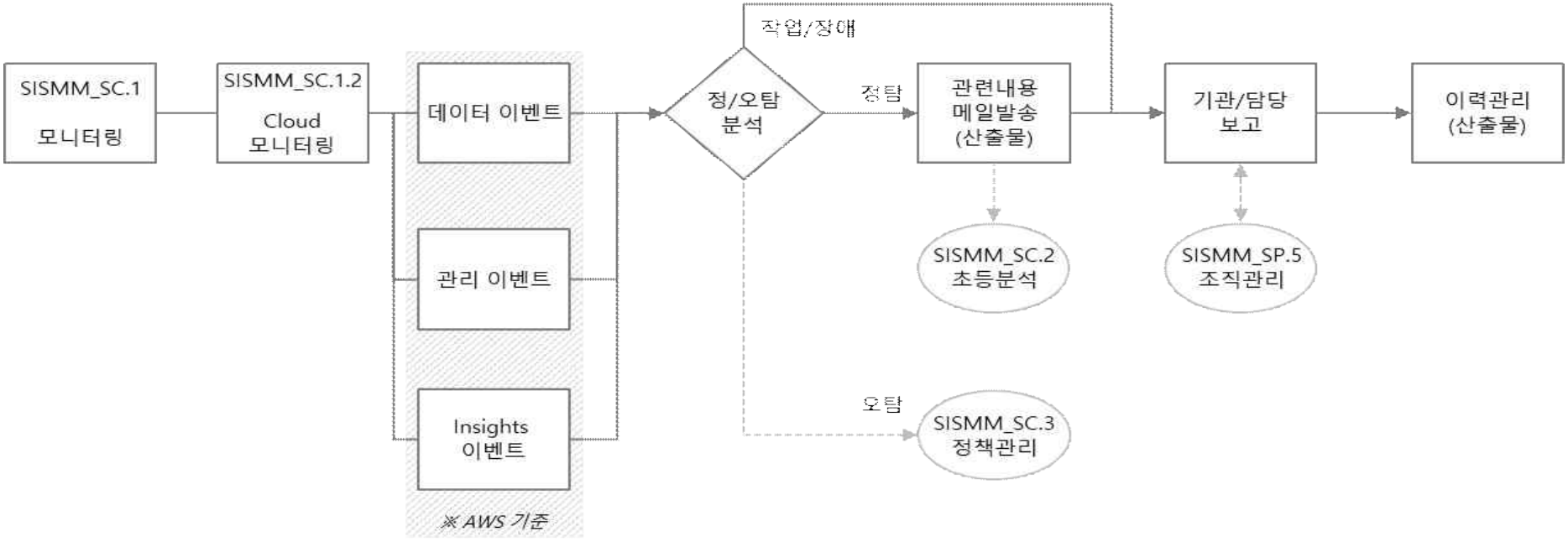
☞ On-Premise (legacy 환경) 모니터링 (2/2)

Task	상세 설명	산출물	대상/주체	비고
탐지 이벤트	보안장비에 탐지된 이벤트를 모니터링한다.		단위 보안장비	
비정상 트래픽	비정상 트래픽의 발생여부를 모니터링한다.		단위 보안장비	
상관분석 모니터링	탐지 이벤트 및 트래픽을 토대로 상관분석 모니터링을 실시한다.		관제시스템	
홈페이지	홈페이지 이상징후 Alert 발생여부를 모니터링한다.		단위 보안장비	
정/오탐 분석	이벤트(비정상 트래픽, Alert 등 포함)가 발생된 경우 초동분석을 실시하여 정/오탐 여부를 판단한다. - 정탐인 경우 next Task 실시 - 오탐(장애, 작업 포함)인 경우 관련 Process 에 따라 후속대응 실시		단위 보안장비 관제시스템 보안관제요원	
관련내용 메일 발송	정탐인 이벤트, Alert 로 확인되는 경우 관련내용 메일 발송한다. ※ 관제대상 기관 내부 프로세스에 의해 내용 전파 방법은 달라질 수 있음	이벤트대응보고서	관제시스템 보안관제요원	
기관/담당 보고	관제대상 기관/담당자에게 보고한다.		보안관제요원	
이력관리	탐지된 이벤트가 조치가 완료될 때까지 고객에게 보고하며 이력을 관리한다. ※ 관제대상 기관 내부 프로세스에 의해 이력관리방법은 달라질 수 있음	이력관리	관제시스템 보안관제요원	

2-4. 보안관제 업무 절차(모니터링)

☞ **Cloud 모니터링 (1/2)**

- Cloud 서비스 중 발생한 데이터, 관리 이벤트 등을 실시간 감시하고, 이상 발생시 전파, 대응하는 업무 (다만, CSP에 따라 이벤트 분류는 달라질 수 있음)
- Cloud 이용 서비스 상 발생한 Alert을 모니터링하고 대응함



2-4. 보안관제 업무 절차(모니터링)

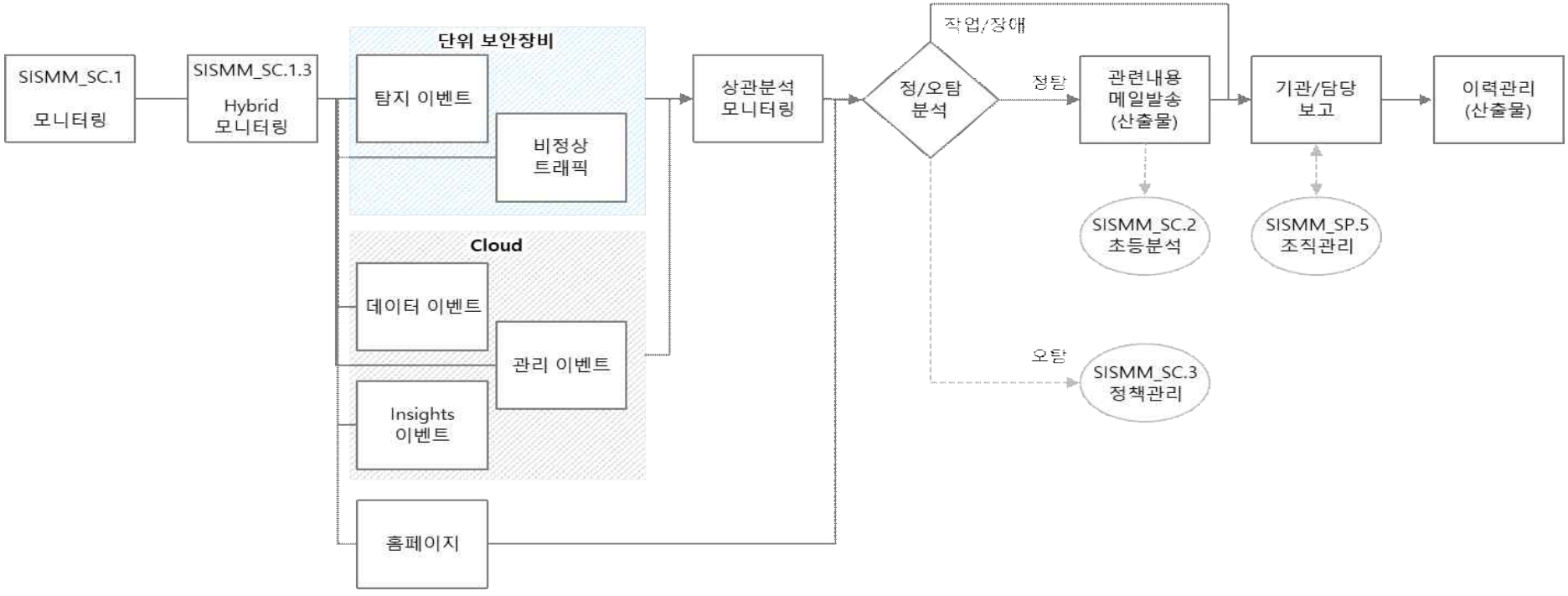
☞ Cloud 모니터링 (2/2)

Task	상세 설명	산출물	대상/주체	비고
데이터 이벤트	Cloud 리소스 작업 관련 이벤트로 AWS 보안 모니터링 탐지 이벤트를 포함한 이벤트 탐지여부를 모니터링한다.		AWS CloudTrail	
관리 이벤트	설정변경 등 Cloud 리소스에 대한 작업 이벤트를 모니터링한다.		AWS CloudTrail	
Insights 이벤트	비정상 API 활동 관련 이벤트를 모니터링한다.		AWS CloudTrail	
정/오탐 분석	이벤트가 발생된 경우 초동분석을 실시하여 정/오탐 여부를 판단한다. - 정탐인 경우 next Task 실시 - 오탐(장애, 작업 포함)인 경우 관련 Process 에 따라 후속대응 실시		보안관제요원	
관련내용 메일 발송	정탐인 이벤트, Alert 로 확인되는 경우 관련내용 메일 발송한다. ※ 관제대상 기관 내부 프로세스에 의해 내용 전파 방법은 달라질 수 있음	이벤트대응보고서	Amazon SNS 보안관제요원	
기관/담당 보고	관제대상 기관/담당자에게 보고한다.		보안관제요원	
이력관리	탐지된 이벤트가 조치가 완료될 때까지 고객에게 보고하며 이력을 관리한다. ※ 관제대상 기관 내부 프로세스에 의해 이력관리방법은 달라질 수 있음	이력관리	보안관제요원	

2-4. 보안관제 업무 절차(모니터링)

☞ **Hybrid 모니터링 (1/2)**

- On-premise 및 Cloud로 동시 서비스하는 경우 관제시스템으로 연동된 이벤트 등을 실시간 감시하고, 이상 발생시 전파, 대응하는 업무
- On-premise 및 Cloud 상 발생한 Alert을 모니터링하고 대응함



2-4. 보안관제 업무 절차(모니터링)

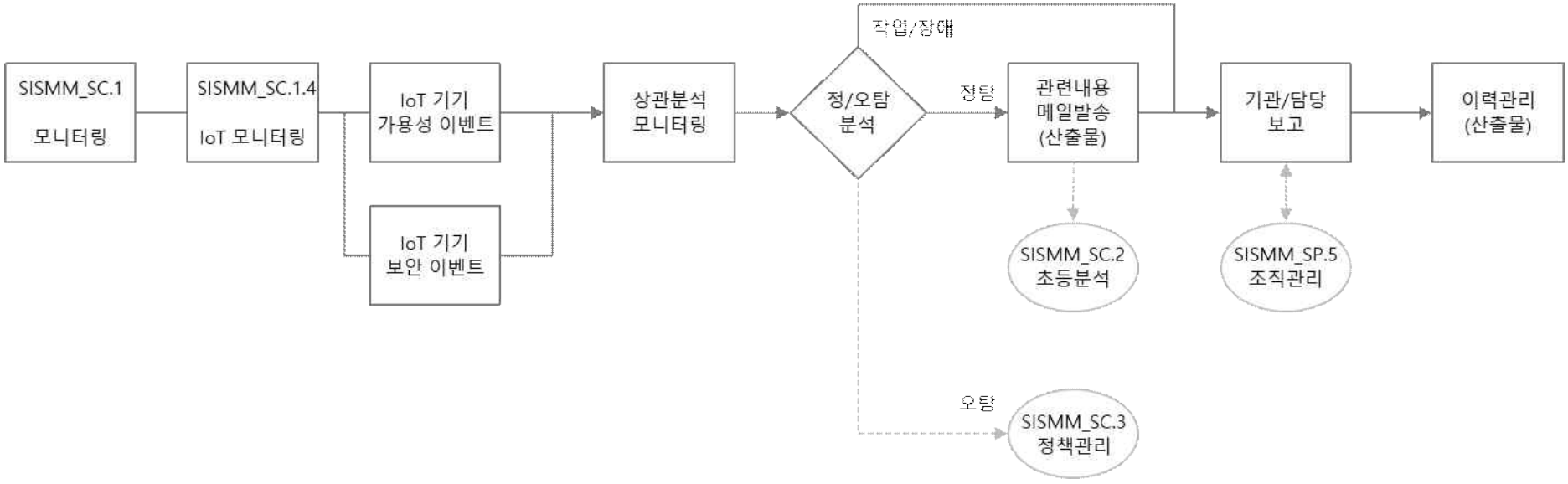
☞ Hybrid 모니터링 (2/2)

Task	상세 설명	산출물	대상/주체	비고
탐지 이벤트	보안장비에 탐지된 이벤트를 모니터링한다.		단위 보안장비	
비정상 트래픽	비정상 트래픽의 발생여부를 모니터링한다.		단위 보안장비	
데이터 이벤트	Cloud 리소스 작업 관련 이벤트로 AWS 보안 모니터링 탐지 이벤트를 포함한 이벤트 탐지여부를 모니터링한다.		AWS CloudTrail	
관리 이벤트	설정변경 등 Cloud 리소스에 대한 작업 이벤트를 모니터링한다.		AWS CloudTrail	
Insights 이벤트	비정상 API 활동 관련 이벤트를 모니터링한다.		AWS CloudTrail	
상관분석 모니터링	탐지 이벤트 및 트래픽을 토대로 상관분석 모니터링을 실시한다.		관제시스템	
홈페이지	홈페이지 이상징후 Alert 발생여부를 모니터링한다.		단위 보안장비	
정/오탐 분석	이벤트가 발생된 경우 초동분석을 실시하여 정/오탐 여부를 판단한다. - 정탐인 경우 next Task 실시 - 오탐(장애, 작업 포함)인 경우 관련 Process 에 따라 후속대응 실시		단위 보안장비 관제시스템 보안관제요원	
관련내용 메일 발송	정탐인 이벤트, Alert 로 확인되는 경우 관련내용 메일 발송한다. ※ 관제대상 기관 내부 프로세스에 의해 내용 전파 방법은 달라질 수 있음	이벤트대응보고서	관제시스템 보안관제요원	
기관/담당 보고	관제대상 기관/담당자에게 보고한다.		보안관제요원	
이력관리	탐지된 이벤트가 조치가 완료될 때까지 고객에게 보고하며 이력을 관리한다. ※ 관제대상 기관 내부 프로세스에 의해 이력관리방법은 달라질 수 있음	이력관리	보안관제요원	

2-4. 보안관제 업무 절차(모니터링)

☞ **IoT 모니터링 (1/2)**

- IoT 관리 시스템에 탐지된 이벤트 등을 실시간 감시하고, 이상 발생시 전파, 대응하는 업무
- IoT 운영 중 발생한 Alert을 모니터링하고 대응함



2-4. 보안관제 업무 절차(모니터링)

☞ IoT 모니터링 (2/2)

Task	상세 설명	산출물	대상/주체	비고
IoT 기기 가용성 이벤트	비정상적인 IoT 리소스 사용 alert, alive 신호 등의 발생여부를 확인한다.		단위 보안장비	
IoT 기기 보안 이벤트	비정상적인 보안 이벤트가 발생하는지 확인한다.		단위 보안장비	
상관분석 모니터링	발생 이벤트 및 IoT Gateway & 관리서버의 로그를 토대로 상관분석 모니터링을 실시한다.		관제시스템	
정/오탐	이벤트를 확인하여 정/오탐 분석을 한다. - 정탐인 경우 next Task 실시 - 오탐인 경우 경보 최적화 및 정책변경 수행		단위 보안장비 관제시스템 보안관제요원	
관련내용 메일 발송	정탐인 이벤트, Alert 로 확인되는 경우 관련내용 메일 발송한다. ※ 관제대상 기관 내부 프로세스에 의해 내용 전파 방법은 달라질 수 있음	이벤트대응보고서	관제시스템 보안관제요원	
기관/담당 보고	관제대상 기관/담당자에게 보고한다.		보안관제요원	
이력관리	탐지된 이벤트가 조치가 완료될 때까지 고객에게 보고하며 이력을 관리한다. ※ 관제대상 기관 내부 프로세스에 의해 이력관리방법은 달라질 수 있음	이력관리	보안관제요원	

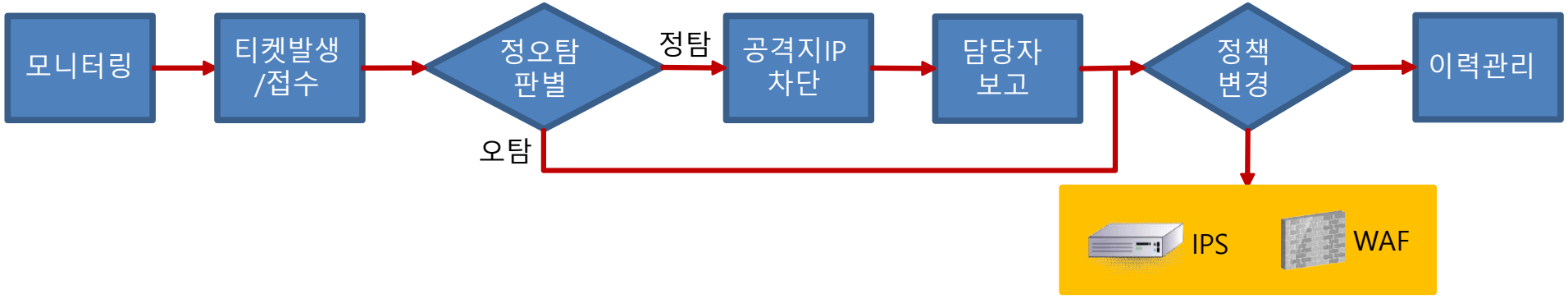
실습

보안관제 업무 절차 도표를 참고하여 상세 이벤트 처리 절차도를 작성

단계	현업 부서	사이버보안센터			고객사
		보안관제	침해대응	보안진단	
탐지					
대응					

2-4. 보안관제 업무절차

비정상적 트래픽을 탐지 분석하여 내부정보유출 차단 및 침입시도 여부를 판단함



보안관제시스템 운영업무

이상징후 탐지고도화	▪ 이상징후에 대한 판단 기준 ▪ 최신 공격기법의 수집 / 분석 ▪ 보안시스템별 특성 이해
관제미처리 오류이벤트	▪ 관제인력 실수에 의한 오탐 및 미대응 ▪ 보안시스템 한계에 의한 미탐

고려 사항

▪ 최신공격기법 자료공유 ▪ 표준 사용자 정의 룰셋 공유	
▪ 교육강화 및 상관분석 고도화 ▪ 관제 PL의 크로스체크 ▪ 자체모의훈련 실시/평가 및 벤더사 협조	
신종 해킹패턴에 대한 분석	**실시간 대응 활동**

2-4. 보안관제 업무절차

☞ 탐지된 이벤트의 정오탐 유무 판정

- 오탐의 가능성? → 탐지되는 이벤트에 대한 이해와 위협행위에 대한 이해

- 확실한 정탐인가? → 이벤트가 탐지되었다면 보안솔루션에서 차단되어 확인 불가

- 정오탐 판단의 근거는 무엇인가?
  → 단순 문자열 일치, IP 대역 일치, 정상 서비스

탐지된 보안 이벤트의 정탐과 오탐을 결정하는 것은 보안 관제 근무자!

2-4. 보안관제 업무절차

보안관제 서비스로 시스템 자산에 가용성 점검으로 연속성 및 안정성 확보함

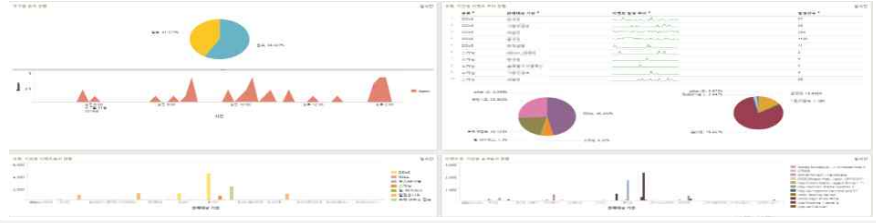
관제 시스템 가용성 모니터링 → 위협 이벤트 누락방지 → 시스템 장애 대응 → 안정적인 운영 모니터링

관제시스템 가용성 모니터링



· 모니터링 대상 선정(관제 시스템)
  - TMS, IPS, ESM,WMS
· 시스템 모니터링 항목
  - CPU, Disk, MEM, Network
· 헬스체크 모니터링 대상(홈페이지)
▶ 실시간 가용성 모니터링 업무 수행

위협 이벤트 누락 방지



· 체크리스트 수행(주기 : 1시간)
· 대시보드 모니터링
  - 대상 : DDoS/IPS/APT/WMS/ESM
▶ 이벤트 누락 방지 실시간· 주기별 확인

시스템 장애 대응



· 시스템 장애 인지
시스템 장애 증상 확인
- 가용성 이슈, 하드웨어/소프트웨어
장애 발생 보고
- 고객사, 유지보수 업체

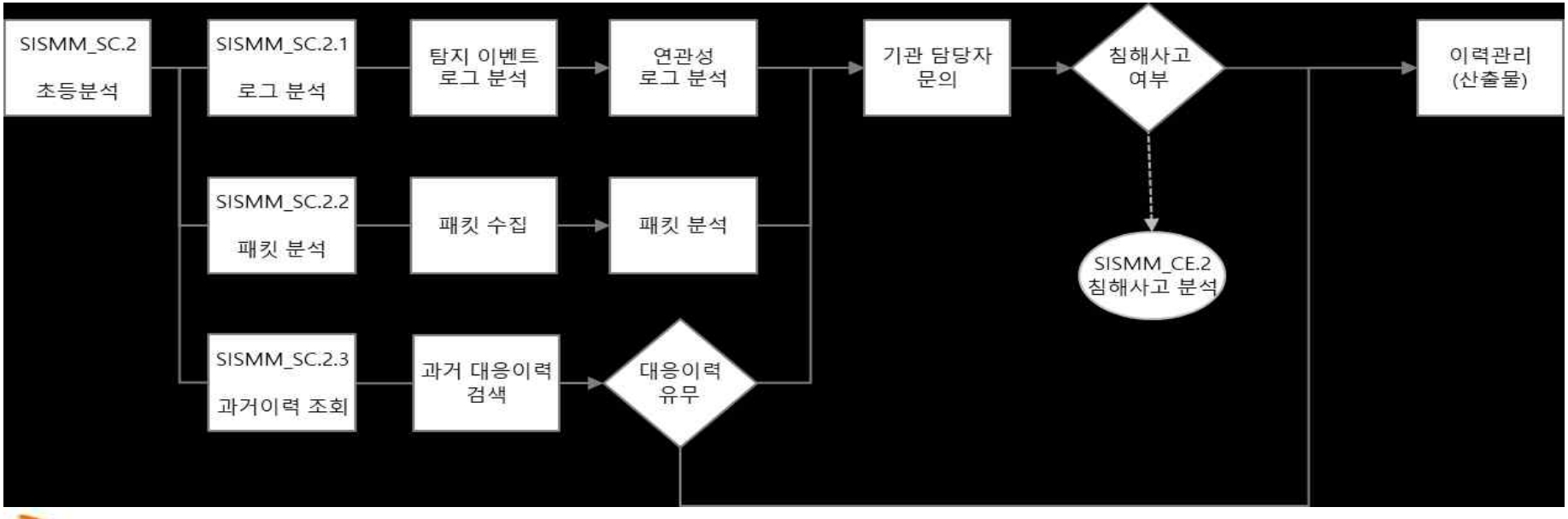
· 장애 처리(주간)
  - 유지보수 업체
· 장애 처리(야간 및 공휴일)
  - 고객사 보고 후, 관제근무자 긴급처리 수행
※ 긴급처리 불가시 유지보수 업체 처리진행

2-4. 보안관제 업무절차

☞ **초동분석**

- 이벤트, 트래픽, 홈페이지 등 모니터링 중 탐지된 비정상 건에 대해 1차 분석을 통해 침해사고 여부를 판별하는 업무

- 1) 로그 분석 – 탐지된 비정상 이벤트 관련 로그를 검색하여 연관성을 분석함
  2) 패킷 분석 – 비정상 이벤트, 트래픽 관련 네트워크 패킷을 수집·분석함
  3) 과거이력 조회 – 비정상으로 탐지된 건 관련 대응 이력을 검색하여 담당자 문의 등 후속 Task의 수행 여부를 결정함



2-4. 보안관제 업무절차

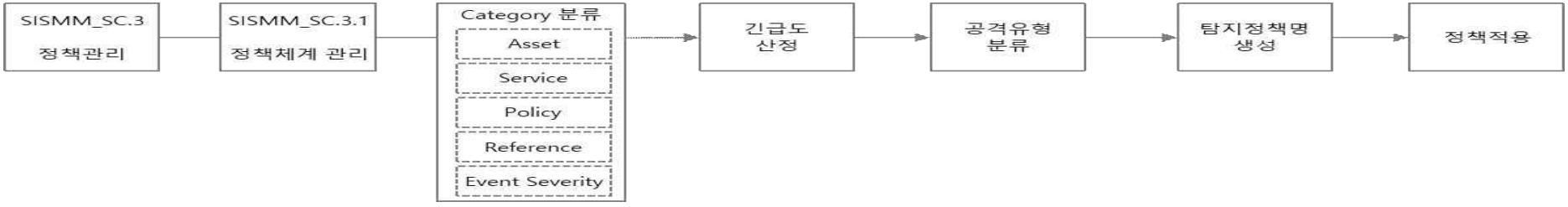
☞ 초동분석

Task	상세 설명	산출물	대상/주체	비고
탐지 이벤트 로그 분석	단위 보안장비 등에 탐지된 이벤트 로그를 분석한다.		단위 보안장비	
연관성 로그 분석	탐지된 이벤트와 연관된 로그들을 분석하여 이상 여부를 확인한다.		단위 보안장비 관제시스템	
패킷 수집	단위 보안장비 등에서 캡쳐된 패킷을 확인하거나, 패킷수집Tool을 활용하여 네트워크 패킷을 수집한다.		단위 보안장비 패킷수집Tool	
패킷 분석	수집된 패킷을 분석하여 이상 여부를 확인한다.		보안관제요원	
과거 대응이력 검색	동일 or 유사 이벤트의 과거 대응이력을 검색한다.		관제시스템	
대응이력 유무	과거 이벤트 대응이력 유무를 확인한다. - 대응이력이 있는 경우 이력관리 실시 - 대응이력이 없는 경우 next Task 실시		관제시스템 보안관제요원	
기관 담당자 문의	로그분석, 패킷분석, 대응이력 유무를 확인하여 기관 담당자에게 문의한다.		보안관제요원	
침해사고 여부	침해사고 여부를 판단한다. - 침해사고인 경우 관련 Process에 따라 후속대응 실시		보안관제요원 관제PL	
이력관리	초동분석한 내용에 대한 이력을 관리한다.	이력관리	보안관제요원	

2-4. 보안관제 업무절차(정책관리)

☞ 정책체계 관리

- 모니터링을 위한 탐지정책을 Category 기준을 고려하여 분류하고, 정의하는 등 정책 전반의 체계를 관리하는 업무
- 정책체계 관리 – 관제 모니터링을 위한 정책체계를 관리함



Task	상세 설명	산출물	대상/주체	비고
Category분류	Category를 분류하기 위한 5개의 기준을 구분하여 분류 - Asset : 공격 대상의 자산 취약점 여부 - Service : 공격 대상의 서비스 외부 오픈 여부 - Policy : 장비에서 발생한 Event의 동작(행위)를 정의 - Reference : 어떤 외부 위협 정보인지 확인 - Event Severity : Event의 위험 수준을 정의	정책분류체계 정의서	단위 보안장비	부록 참조
긴급도산정	긴급도 분류하기 위해 4개의 Level로 구분 - 등급 : Critical(9~10), Major(6~8), Minor(3~5), Info(0~2)		단위 보안장비	
공격유형분류	이벤트를 범주화 할 수 있는 상위 수준의 분류하여 정의(21개 유형) - DDoS, Recon, Scanning, Backdoor, Pattern Matching, Service Attack 등		단위 보안장비	
탐지정책명 생성	유형에 정의된 탐지코드명을 생성	탐지정책 정의서	단위 보안장비	부록 참조
정책적용	보안장비에 탐지정책을 생성하여 적용		단위 보안장비	

2-4. 보안관제 업무절차(정책관리)

☞ 정책체계 관리 – 공격유형 분류(예시)

No.	Attack Type	Description	e.g.
1	D/DoS	DDoS 전용장비에서 발생하는 서비스 거부 유형 이벤트	SniperIPS "서비스 거부" , SniperDDX 이벤트
2	Recon	IP/PORT 등 서비스 사용 유무를 확인하기 위한 정보수집	SniperIPS "정보 수집"
3	Scanning	특정 어플리케이션 대상의 디렉토리 구조, WEB CGI 스캐닝	SniperIPS "Web CGI 공격"
4	Backdoor	백도어 탐지 이벤트	SniperIPS "백도어"
5	Pattern Matching	패킷의 일부 문자열이 매칭되어 탐지되는 이벤트	SniperIPS "패턴 블럭"
6	Service Attack	FTP, DNS 등 특정 서비스 대상 공격 이벤트	SniperIPS "서비스 공격 "
7	Web Attack	웹방화벽에서 탐지되는 이벤트 유형	WAF 이벤트
8	Application Protocol Anomaly	어플리케이션 혹은 프로토콜 기반 이상 행위 탐지	SniperIPS "프로토콜 취약점 "
9	Malware	백신 등 Anti-Virus에서 탐지되는 악성코드	V3 바이러스 로그
10	WebShell	웹쉘 전용 장비 등에서 발생하는 공격 이벤트	W-MDS 이벤트
11	SQL Injection	위험도가 높은 SQL Injection 공격 유형 이벤트	
12	RAT	Remote Access Tool 사용을 탐지	
13	Privacy	개인정보 관련 이벤트	
14	Defacement	홈페이지 위변조 탐지 유형 이벤트	
15	Ransomware	랜섬웨어 탐지 이벤트	
16	Crypto Miner	가상화폐 채굴형 악성코드 이벤트 (크립토재킹)	
17	Mobile Attack	모바일 전용 악성코드	

2-4. 보안관제 업무절차(정책관리)

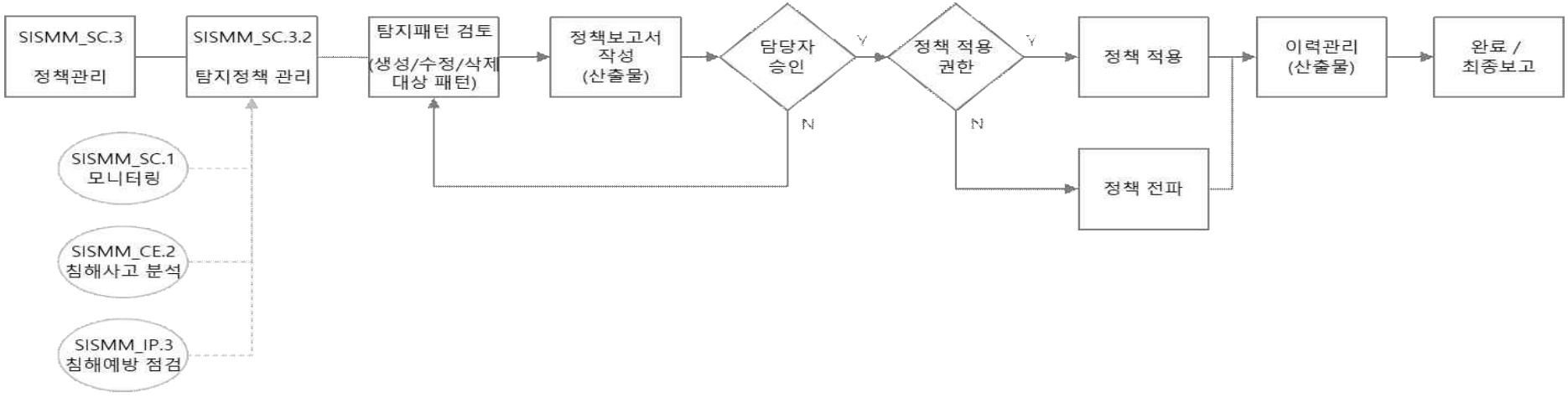
☞ 정책체계 관리 – 공격유형 분류(예시)

No.	Attack Type	Description	e.g.
18	USD (사용자 정의)	사용자 정의 이벤트	
19	Server Log	Application 서버 및 OS에서 생성되는 모든 로그	
20	Network Log	네트워크 시스템에서 생성되는 모든 로그	
21	Others	위 분류에 해당하지 않은 기타 모든 로그	

2-4. 보안관제 업무절차(정책관리)

☞ **탐지정책 관리(1/2)**

- 사고 분석 결과, 신규 취약점 등을 탐지정책으로 개발, 정탐율 향상을 위한 수정, 불필요한 정책 삭제 등 모니터링을 위한 탐지정책을 관리하는 업무
- 탐지정책 관리 – 탐지정책 개발, 수정, 삭제 등 정보보안환경에 최적화하여 적용함



2-4. 보안관제 업무절차(정책관리)

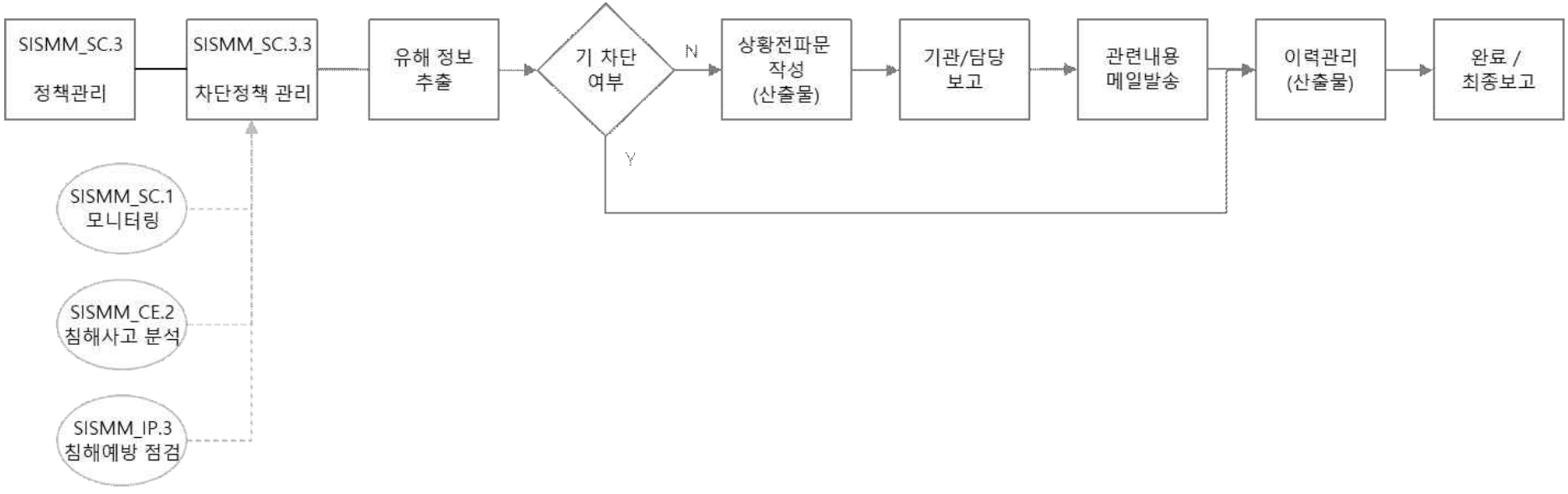
☞ 탐지정책 관리(2/2)

Task	상세 설명	산출물	대상/주체	비고
탐지패턴 검토	생성/수정/삭제할 탐지패턴을 추출하고 검토한다.		보안관제요원	
정책보고서 작성	유형별 정책변경보고서를 작성한다.	정책변경보고서	보안관제요원	
담당자 승인	담당자에게 정책변경보고서를 보고하여 승인을 받는다..		보안관제요원	
정책 적용 권한	승인 결과 및 정책 적용 권한 보유 여부에 따라 Task를 수행한다.		단위 보안장비 관제시스템	
정책 적용	정책 적용 권한 보유 시 정책변경보고서에 따른 정책을 적용한다.		단위 보안장비 관제시스템	
정책 전파	정책 적용 권한 미보유 시 권한보유자에게 정책변경보고서 내용을 전파한다.		보안관제요원	
이력관리	해당 내용을 이력관리한다.	이력관리	보안관제요원	
완료/최종보고	완료/최종 보고한다.		보안관제요원	

2-4. 보안관제 업무절차(정책관리)

☞ **차단정책 관리(1/2)**

- 모니터링, 사고 분석 등을 통해 차단 설정이 필요한 경우 단위 보안장비 등에 차단 정책을 적용하는 업무
- 차단정책 관리 – 보안장비 별 적용할 유해정보(블랙IP/URL/메일주소)를 추출하여 차단 적용함



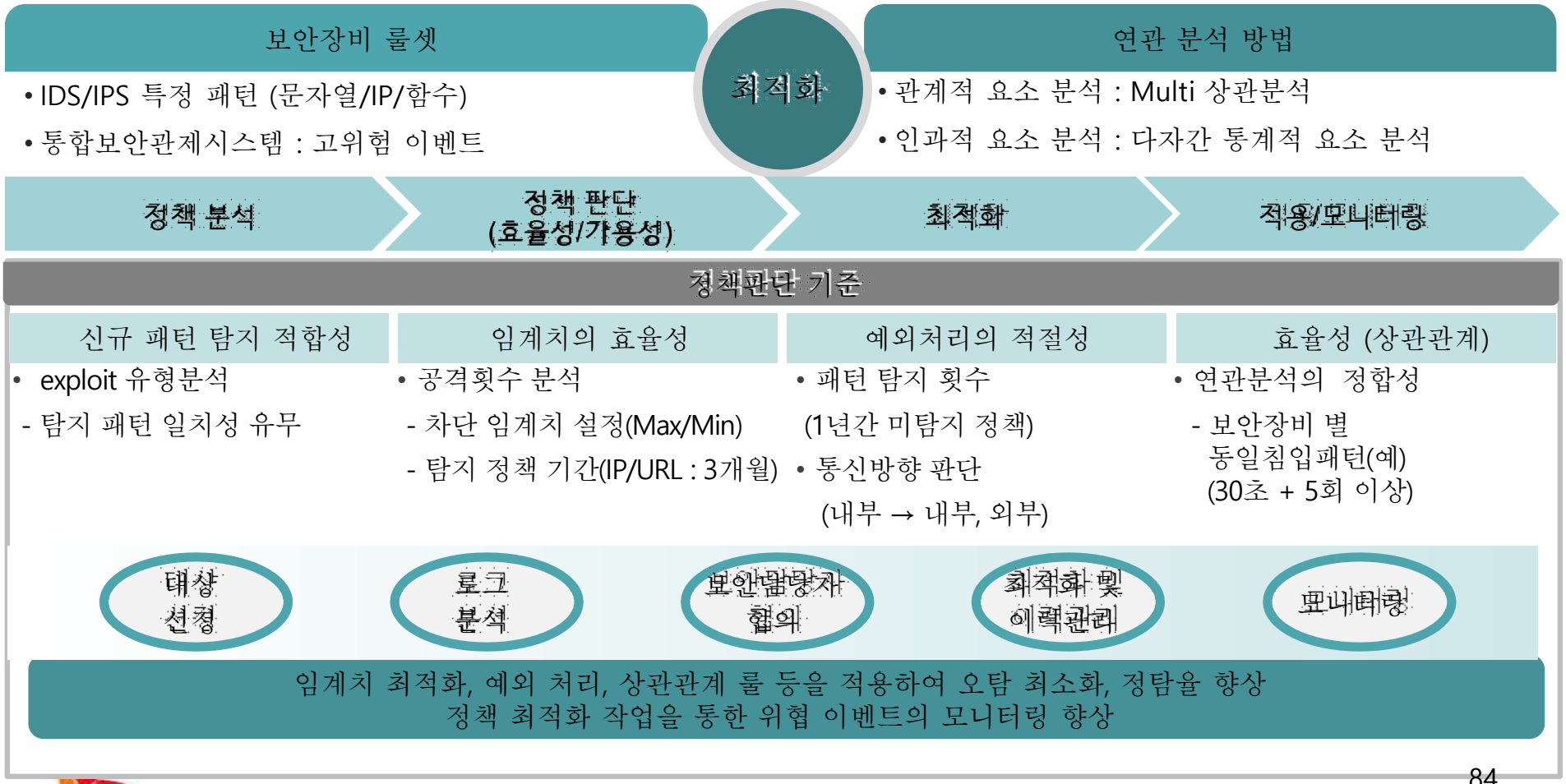
2-4. 보안관제 업무절차(정책관리)

☞ 차단정책 관리(2/2)

Task	상세 설명	산출물	대상/주체	비고
유해 정보 추출	IP/URL/메일주소 등 유해정보를 추출한다.		보안관제요원	
기 차단 여부	기존에 유해 정보에 대한 차단 여부를 확인하다.		단위 보안장비	
상황전파문 작성	침해사고에 대한 상황전파문을 작성한다.	상황전파문	보안관제요원	
담당자 보고	담당자에게 보고하여 승인을 받는다.		보안관제요원	
관련내용 메일발송	관련 내용을 메일로 발송한다.		보안관제요원	
이력관리	해당 내용을 이력관리한다.	이력관리	보안관제요원	
완료/최종보고	담당자에게 최종 대응 내용을 보고한다.		보안관제요원	

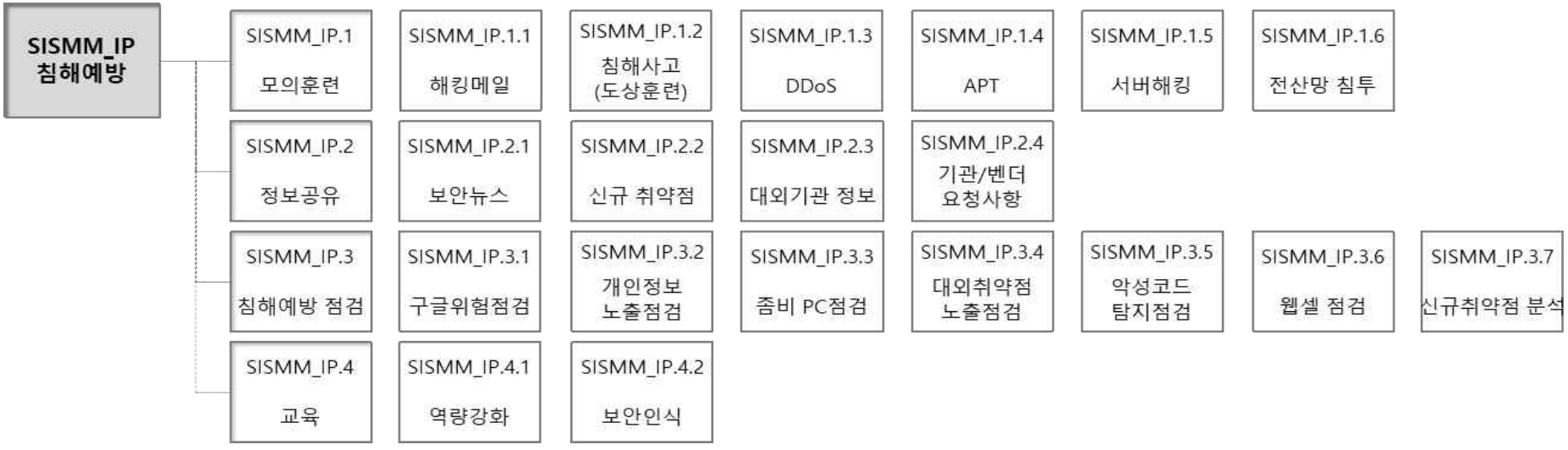
2-4. 보안관제 업무절차(정책관리)

이기종의 다양한 침임탐지 패턴 관계 분석으로 침입 정/오탐을 분석함



2-4. 보안관제 업무절차(침해예방)

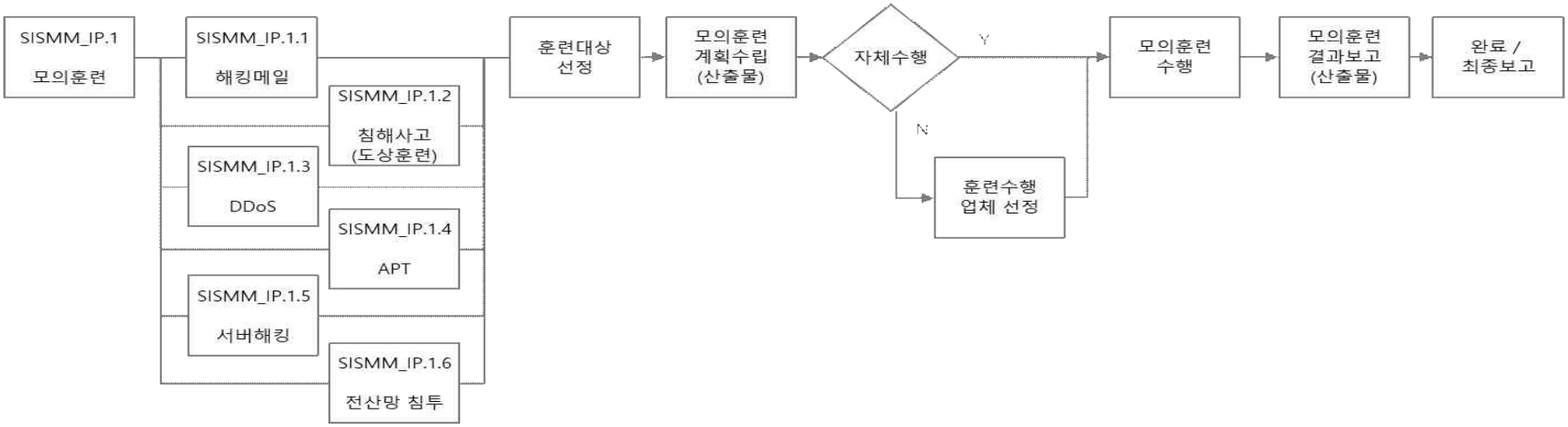
침해예방은 각종 침해사고로부터 사전에 예방하는 것이 목적이며, 세부적으로는 모의훈련, 정보공유, 침해예방점검, 교육 등의 업무를 수행



2-4. 보안관제 업무절차(침해예방)

☞ 모의훈련(1/2)

- 침해사고 발생시 대응력 향상을 위해 사고 상황을 계획하고 발생시켜 상황별 대응하고, 개선점을 도출하여 보완하는 일련의 활동



2-4. 보안관제 업무절차(침해예방)

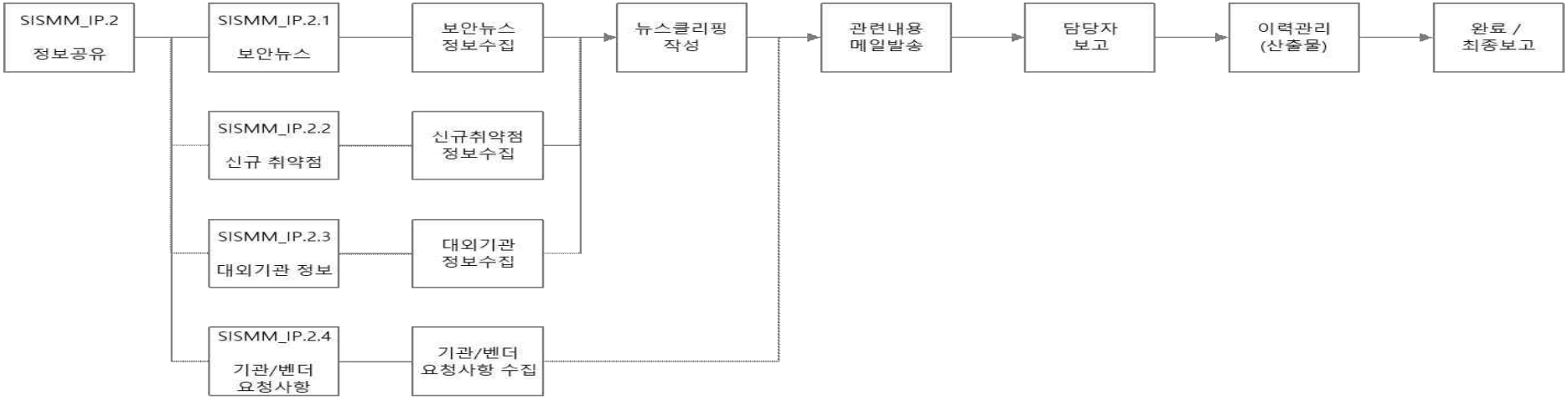
☞ 모의훈련(2/2)

Task	상세 설명	산출물	대상/주체	비고
훈련대상 선정	훈련유형 별 훈련대상을 선정한다. - 1) 해킹메일 : 사용자 중 해킹메일 수신할 훈련대상자를 선정 - 2) 그 외 : 훈련대상 시스템을 선정		침해대응파트	
모의훈련 계획수립	훈련유형 별 일정/대상/방법 등이 포함된 훈련 계획을 수립한다.	모의훈련 계획서	기관 훈련담당자 침해대응파트	
자체수행	센터에서 자체적으로 수행할 수 있는지 검토한다.		침해대응파트	
훈련수행 업체 선정	패킷 제너레이터 등 센터에서 자체적으로 수행할 수 없는 경우 훈련수행 업체를 선정한다.		기관 훈련담당자 침해대응파트	
모의훈련 수행	수립된 계획에 따라 모의훈련을 실시한다.		기관 훈련담당자 침해대응파트	
모의훈련 결과보고	훈련 중 발견된 개선점 및 훈련 결과서를 작성하여 보고한다.	모의훈련 결과서	침해대응파트	
완료/최종보고	훈련을 완료하고, 필요시 최종보고(강평)한다.		침해대응파트	

2-4. 보안관제 업무절차(침해예방)

☞ 정보공유(1/2)

- 국내외 보안동향 등 정보보안 분야 정보를 수집하여 공유하는 업무



2-4. 보안관제 업무절차(침해예방)

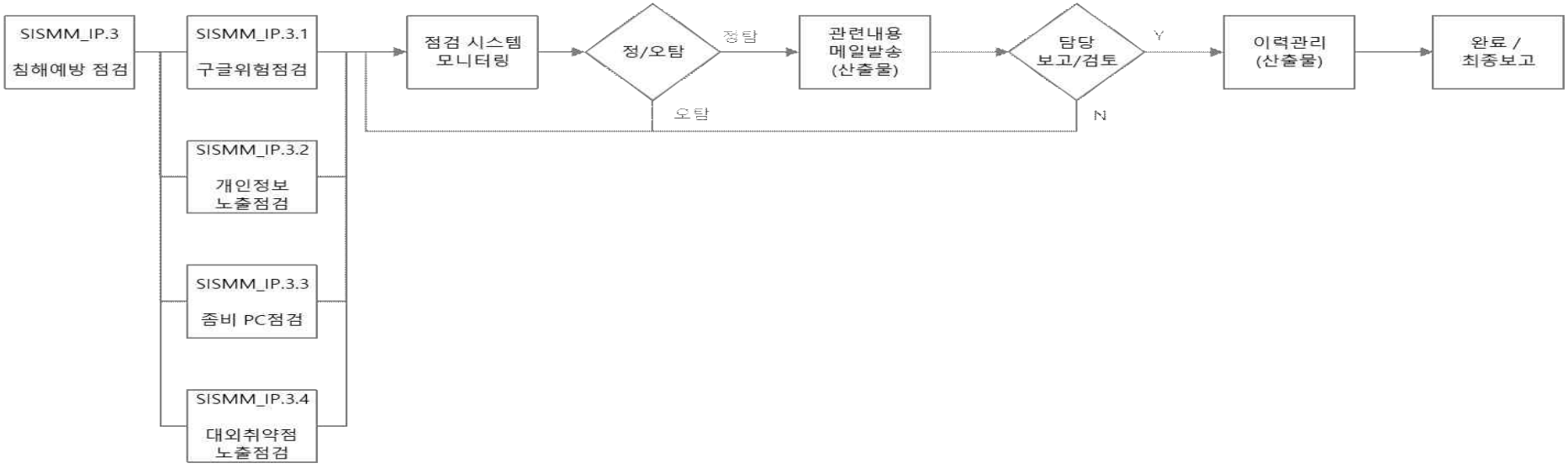
☞ 정보공유(2/2)

Task	상세 설명	산출물	대상/주체	비고
보안뉴스 정보수집	최신 보안뉴스 정보를 수집한다.		보안관제요원 침해대응파트	
신규 취약점 정보수집	신규 취약점 정보를 수집한다.		침해대응파트	
대외기관 전파 정보수집	대외기관으로부터 전파된 정보를 수집한다.		보안관제요원 침해대응파트	
뉴스클리핑 작성	보안뉴스, 신규취약점, 대외기관 정보를 토대로 뉴스클리핑을 작성한다.	뉴스클리핑	침해대응파트	
기관/벤더 요청사항 수집	기관/벤더로부터 요청사항을 수집한다.		침해대응파트	
관련내용 메일 발송	관련 내용을 메일로 발송한다.		침해대응파트	
담당자 보고	기관/담당자에게 보고한다.		침해대응파트	
이력관리	뉴스클리핑 제작/전파 이력을 관리한다.	이력관리	침해대응파트	
완료/최종보고	완료/최종 보고한다.		침해대응파트	

2-4. 보안관제 업무절차(침해예방)

☞ 침해예방 점검 – 정보노출/감염(1/2)

- 고의성 유무와 무관하게 외부에 노출되면 안되는 기관 정보가 노출되어 있는지 점검하여 발견된 정보의 삭제를 목적으로 수행하는 업무



2-4. 보안관제 업무절차(침해예방)

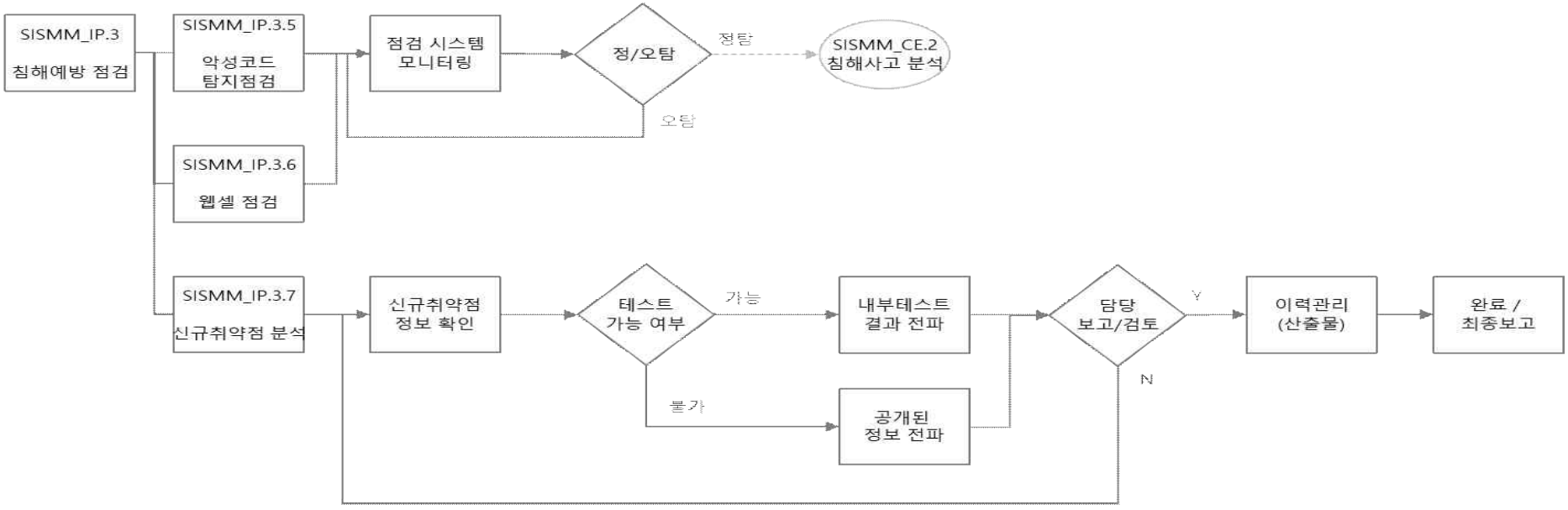
☞ 침해예방 점검 – 정보노출/감염(2/2)

Task	상세 설명	산출물	대상/주체	비고
점검 시스템 모니터링	용도별 점검시스템을 활용하여 정보노출/감염 여부를 모니터링한다 - 1) 구글위험점검 : 주기적인 점검 스케줄/수시 점검 결과 - 2) 개인정보 노출점검 : 주기적인 점검 스케줄/수시 점검 결과 - 3) 좀비 PC 점검 : 주기적인 점검 스케줄/수시 점검 결과 - 4) 대외취약점 노출점검 : 수동/자동 점검 결과		보안관제요원 침해대응파트	
정오탐 분석	각 유형별 점검 결과를 검토하여 정오탐 여부를 분석한다. - 1) 구글위험점검 : 관리자 페이지, 계정정보 노출 등 기관의 정보 노출시 정탐 - 2) 개인정보 노출점검 : 웹페이지, 노출된 파일 내 개인정보 포함되어 노출시 정탐 - 3) 좀비 PC 점검 : C2서버 연결, 이상 프로세스 실행 등 악성코드 감염시 정탐 - 4) 대외취약점 노출점검 : 불필요한 port, 정보 노출시 정탐		침해대응파트	
관련내용 메일발송	정탐으로 확인된 내용을 정리하여 보고서 작성 후 메일로 발송한다.	점검결과 보고서	침해대응파트	
담당자 보고/검토	담당자에게 보고하고, 담당자는 검토한다.		침해대응파트	
이력관리	검출된 결과를 이력관리한다.	이력관리	침해대응파트	
완료/최종보고	완료/최종 보고한다.		침해대응파트	

2-4. 보안관제 업무절차(침해예방)

☞ 침해예방 점검 – 웹 서버(1/2)

- 고의성 유무와 무관하게 기관 내부시스템에 비인가된 파일이나 신규 취약점 존재 여부를 점검하여 제거 조치하는 것을 목적으로 수행하는 업무



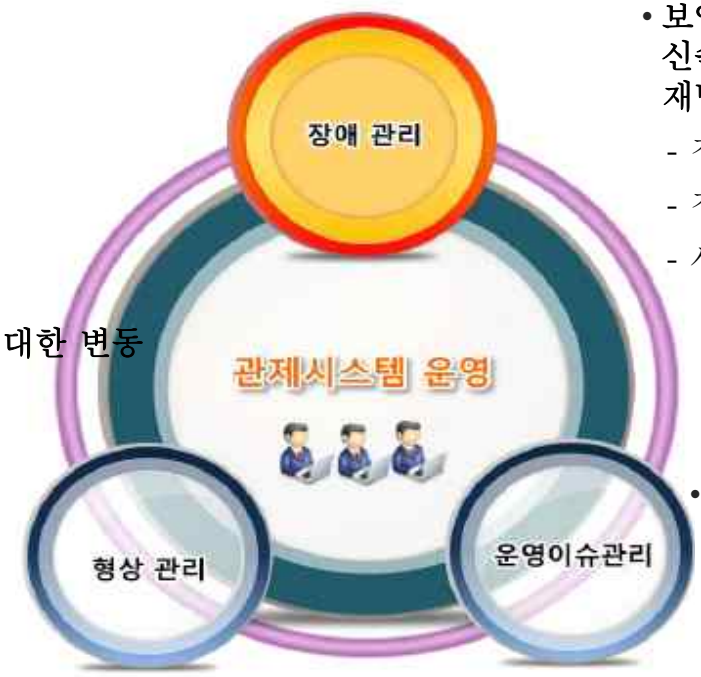
2-4. 보안관제 업무절차(침해예방)

☞ 침해예방 점검 – 웹 서버(2/2)

Task	상세 설명	산출물	대상/주체	비고
점검시스템 모니터링	용도별 점검시스템을 활용하여 비인가 파일 존재 여부를 모니터링한다. - 1) 악성코드 탐지점검 : 탐지시스템을 활용하여 악성코드 존재 여부 - 2) 웹쉘 점검 : 주기적인 점검 스케줄/수시 점검 결과		침해대응파트	
정오탐 분석	탐지 점검 결과를 분석하여 정탐 건을 확인하다. - 1) 악성코드 탐지점검 : 비인가 파일, 비정상 프로세스·세션 활성 등 - 2) 웹쉘 점검 : 쉘 실행 시 서버 OS 명령어 실행 가능 등			
신규취약점 정보 확인	신규취약점 정보를 확인하고 기관 연관성을 분석하여 점검 필요여부를 검토한다.			
테스트 가능여부 분석	신규취약점 관련 테스트환경에서 재현하여 테스트할 수 있는지 분석한다.			
내부 테스트 결과 전파	테스트 가능시 내부 테스트환경에서 테스트 결과를 포함한 정보를 전파한다.			
공개된 정보 전파	테스트 불가능한 경우 이미 공개된 정보를 전파한다.			
담당 보고/검토	담당자에게 보고하고, 담당자는 검토한다.			
이력관리	검출된 결과를 이력관리한다.	이력관리		
완료/최종보고	완료/최종 보고한다.			

2-4. 보안관제 업무 절차 (보안 운영)

보안시스템 의 효율적인 장애 관리 및 ESM 연동대상 장비에 대한 형상 관리로 시스템의 안정성을 도모하고 정규화된 운영 프로세스 및 Issue Lists를 통해 보안운영 최적화



- **보안시스템의 장애 대응 프로세스에 따라 신속한 초동조치와 장애 관련 사후처리 방법 및 재발 방지 대책 체공**
  - 장애처리 프로세스 수립
  - 장애 대응 매뉴얼 제공
  - 사후 처리 방법

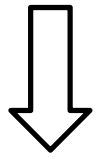
- **시스템 유지보수 및 연동대상 장비에 대한 변동 관리**
  - 보안시스템 운영 매뉴얼 제공
  - 관계사 현황(IP, 자산정보) 관리
  - 연동대상 장비의 변동관리

- **보안관제시스템의 버그 개선 및 벤더사에 커스터마이징 요청관리**
  - 보안관제 Needs 파악
  - 벤더사에 커스터마이징 요청 및 확인
  - 보안시스템 버그 확인 및 개선

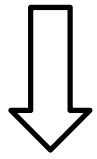
SK 쉴더스

2-4. 보안관제 업무 절차 (보안 운영)

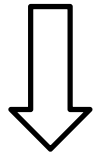
☞ 방화벽등 네트워크 기반 보안장비단위 별 보안관제



☞ 방화벽, IDS, IPS 등 다양한 장비의 종합 관제(ESM)



☞ 고도화되는 보안위협(APT), 다량의 로그, 빅데이터기반 관제(SIEM)



☞ AI와 머신러닝을 통한 대규모 공격의 방어, 업무절차 자동화(SOAR)

2-4. 보안관제 업무절차(보안운영)

☞ 보안운영은 운영대상 정보시스템(주로 정보보호시스템)의 가용성 유지를 위해 자산을 관리하고 운영하는 업무

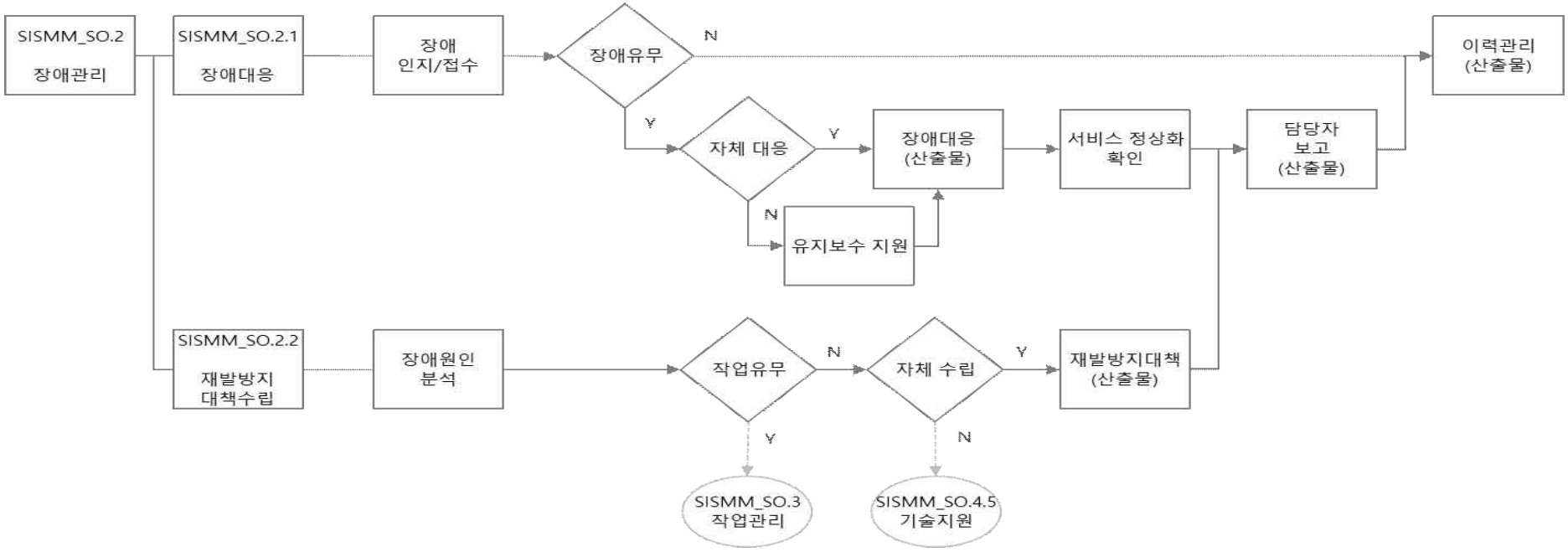
☞ 세부적으로 자산관리, 장애관리, 작업관리, 설정관리, 예방점검, 백업관리, 기술지원 등을 수행



2-4. 보안관제 업무절차(보안운영)

☞ 장애관리 – 장애대응/재발방지 (1/2)

- 운영대상 정보시스템의 장애 발생시 대응 및 재발방지대책을 수립하여 가용성을 유지하는 업무



2-4. 보안관제 업무절차(보안운영)

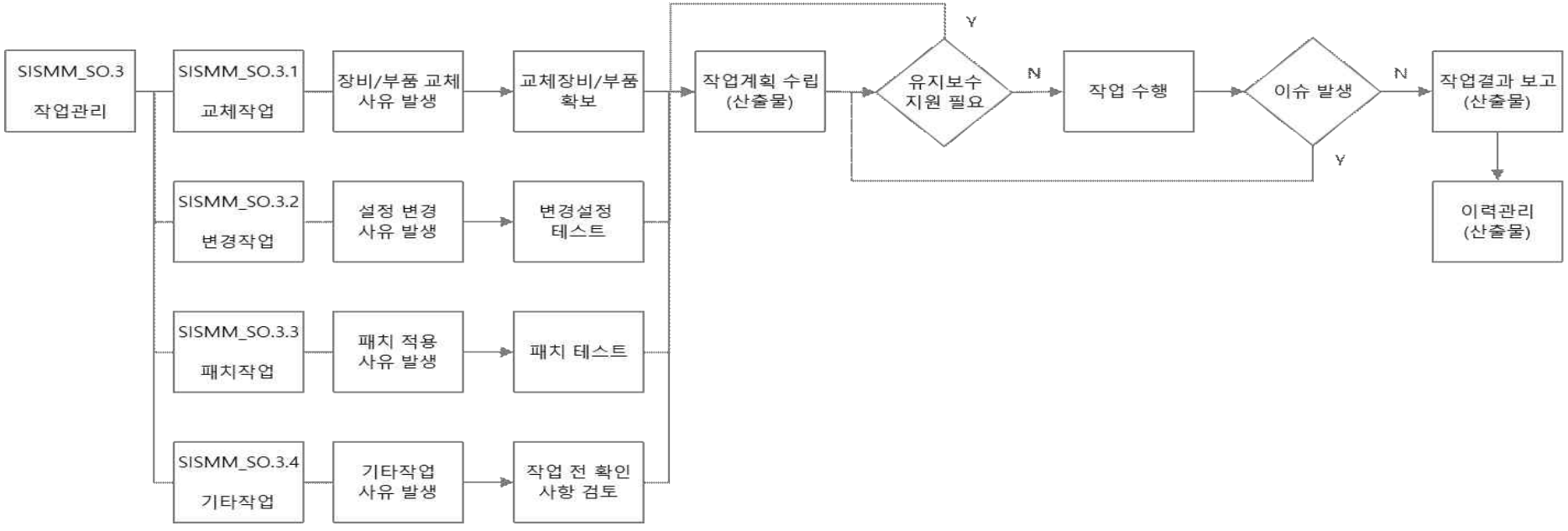
☞ 장애관리 – 장애대응/재발방지 (2/2)

구분	Task	상세 설명	산출물	대상/주체	비고
장애대응	장애 인지/접수	장애 모니터링을 통해 장애 발생을 인지하고 영향도와 긴급도에서 따라 장애를 접수한다.		보안운영 파트 (유지보수 지원)	
	장애 유무	장애 및 작업 여부를 확인한다.			
	자체 대응	자체 대응 가능 여부를 판단한다..			
	유지보수 지원	자체 대응 불가시 유지보수 지원을 요청한다.			
	장애대응	자체 또는 유지보수 지원에 의해 대응 조치한다. 자체 대응하는 경우 장애대응매뉴얼에 의해 정확한 방법으로 대응한다.	장애대응매뉴얼		
	서비스 정상화 확인	장애대응 후 서비스 정상화 여부를 확인하여 장애 종료 여부를 결정한다.			
재발방지	장애원인 분석	장애 발생의 원인 및 위협요소 분석을 통해 장애분석보고서를 생성한다. - 내용: 장애발생원인, 진행경과, 피해수준, 조치방안 등			
	작업유무	계획된 작업에 의해 한시적 장애인 경우 별도의 이력관리하고, 별도 재발방지대책은 수립하지 않는다.			
	자체수립	재발방지대책 수립방법을 결정한다.(자체수립 또는 유지보수 기술지원)			
	재발방지대책 수립	장애에 대한 근본 원인을 도출하고 해결방안을 모색하여 재발하지 않도록 재발방지 대책을 수립한다	장애대응결과보고서		
공통	담당자 보고	장애발생내용, 조치 결과를 담당자에게 보고한다.	장애대응결과보고서		
	이력관리	이력을 관리한다.	이력관리		

2-4. 보안관제 업무절차(보안운영)

☞ **작업**관리 – 교체/변경/패치/기타작업 (1/2)

- 보안운영 중 가용성 및 성능유지를 위해 작업이 필요한 경우 계획을 수립하여 작업을 수행하는 업무



2-4. 보안관제 업무절차(보안운영)

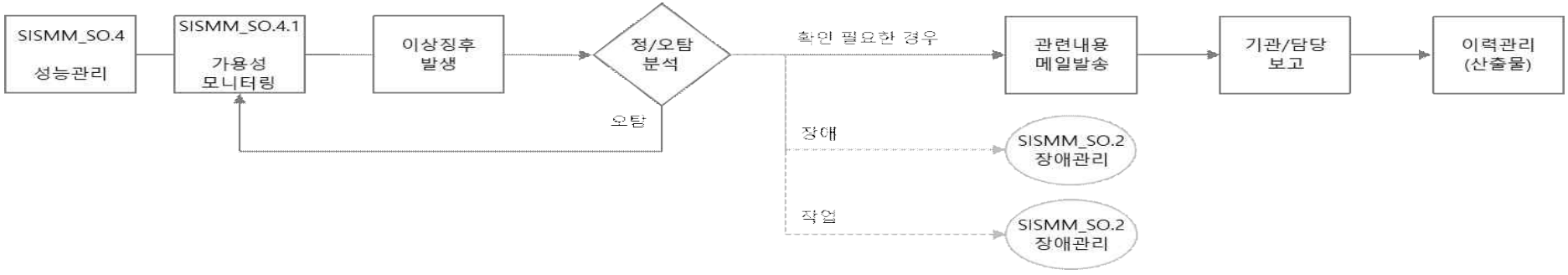
☞ **작업**관리 – 교체/변경/패치/기타작업 (2/2)

구분	Task	상세 설명	산출물	대상/주체	비고
교체	장비/부품 교체사유 발생	Fault, 장애 등으로 장비/부품 교체 사유를 확인한다.		보안운영 파트 (유지보수 지원)	
	교체 장비/부품 확보	교체할 신규 장비/부품 확보 상태를 확인한다.			
변경	설정변경 사유 발생	보안강화 등 설정변경 사유를 확인한다.			
	변경설정 테스트	변경설정시 서비스 영향도 유무 확인 또는 테스트(testbed)를 수행한다.			
패치	패치 적용 사유 발생	업그레이드, 보안강화 등 패치 적용 사유를 검토한다.			
	패치 테스트	패치 적용시 서비스 영향도 유무 테스트(testbed)를 수행하거나 유지보수 측의 테스트 결과를 수신하여 검토한다.			
기타	기타작업 사유 발생	기타 정상적인 운영을 위한 작업 사유를 확인한다.			
	작업 전 확인사항 검토	작업 전 확인사항을 체크하고 검토한다.			
공통	작업계획 수립	작업 유형별 작업계획을 수립한다. - 대상, 일시, 내용, 복구 계획 등 포함	작업계획보고서		
	유지보수 지원 필요	작업을 위한 유지보수 지원 필요여부를 결정한다.			
	작업 수행	계획된 작업을 수행한다. (자체 또는 유지보수 지원)			
	이슈 발생	작업 중 이슈 발생 여부를 확인한다. 이슈 발생시 유지보수 지원하에 이슈를 해결하고, 해결불가시 작업을 중단하고 원복한다. ※ 이슈로 인한 작업 중단 시 이슈사항 해결 후 재작업			
	작업결과 보고	작업수행결과를 보고한다.	작업결과보고서		
	이력관리	이력을 관리한다.	이력관리		

2-4. 보안관제 업무절차(보안운영)

☞ **성능**관리 – 가용성 모니터링

- 운영대상 정보시스템의 가용성 이상유무를 인지하기 위해 모니터링을 실시하고 이상징후 발생시 대응하는 업무

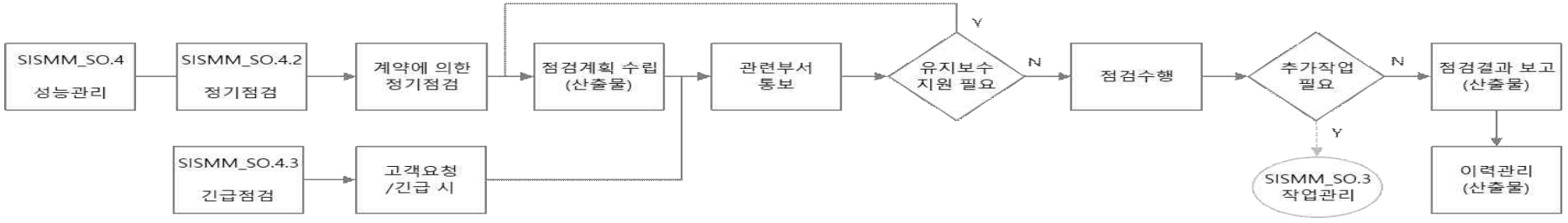


Task	상세 설명	산출물	대상/주체	비고
이상징후 발생	운영대상 정보시스템의 가용성 모니터링 중 이상징후(Alert 등) 발생을 확인하다.		보안운영 파트 보안관제요원	
정/오탐 분석	발생한 징후의 정/오탐 여부를 분석 확인한다. - 확인 필요한 경우 : 징후 발생 원인 파악 불가시 다음 task를 수행한다. - 장애/작업 : 장애발생 또는 작업으로 인한 징후인 경우 각 프로세스로 대응한다.			
관련내용 메일발송	관련내용을 메일로 발송하여 통보한다.			
기관/담당 보고	관련내용을 기관/담당자에게 보고한다.			
이력관리	이력을 관리한다.	이력관리		

2-4. 보안관제 업무절차(보안운영)

☞ **성능**관리 – 정기/긴급점검

- 안정적인 보안운영을 위해 정기점검을 실시하고, 필요시 긴급점검을 수행하고, 이상징후 발견 또는 예방을 위해 추가작업을 수행하는 업무

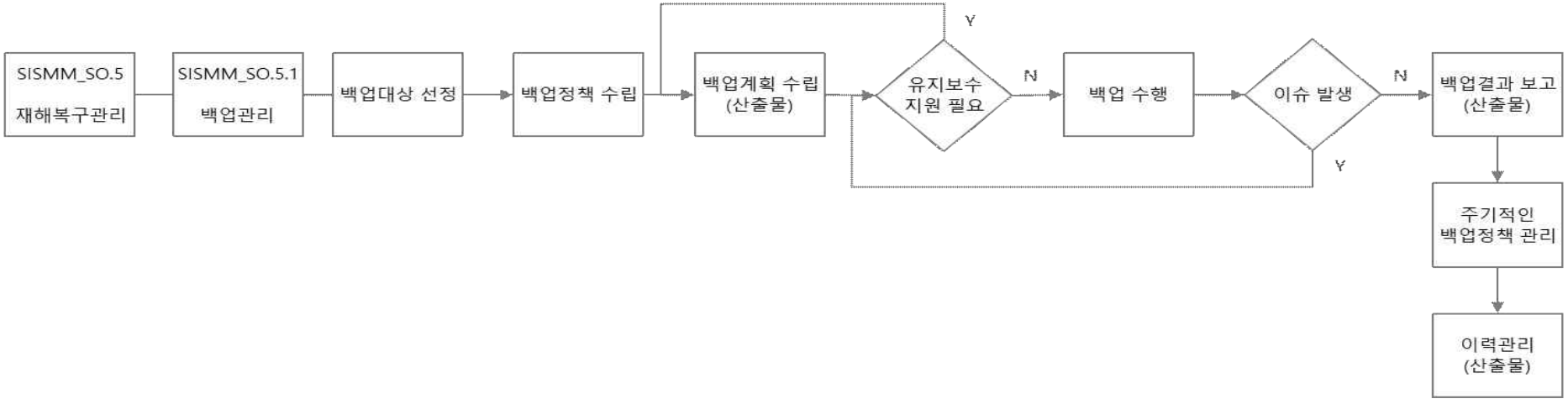


Task	상세 설명	산출물	대상/주체	비고
계약에 의한 정기점검	유지보수 계약에 의해 정기점검 주기별 점검을 실시한다. (정기점검 미포함 계약장비는 자체적으로 점검)		보안운영 파트 (유지보수 지원)	
점검계획 수립	정기점검 계획을 수립한다	점검 계획서		
고객요청/긴급 시	정기점검 이외에 요청 등에 의해 긴급점검을 실시한다.			
관련부서 통보	정기/긴급점검 수행 전 관련부서에 통보한다.			
유지보수 지원 필요	유지보수 지원 필요 여부를 결정하여 지원 필요시 점검계획에 포함하여 계획을 수립한다.			
점검수행	정기/긴급점검을 수행한다.			
추가작업 필요	점검 중 추가작업의 필요 여부를 판단하여 작업 필요시 작업관리 프로세스에 의한다			
점검결과 보고	점검결과를 보고서로 작성하여 보고한다.	점검 결과서		
이력관리	이력을 관리한다.	이력관리		

2-4. 보안관제 업무절차(보안운영)

☞ 재해복구관리 – 백업관리 (1/2)

- 재해, 장애 등의 사유로 운영대상 정보시스템 중단발생시 신속한 정상화를 위한 시스템/데이터 백업을 수행하고, 주기적으로 관리하는 업무



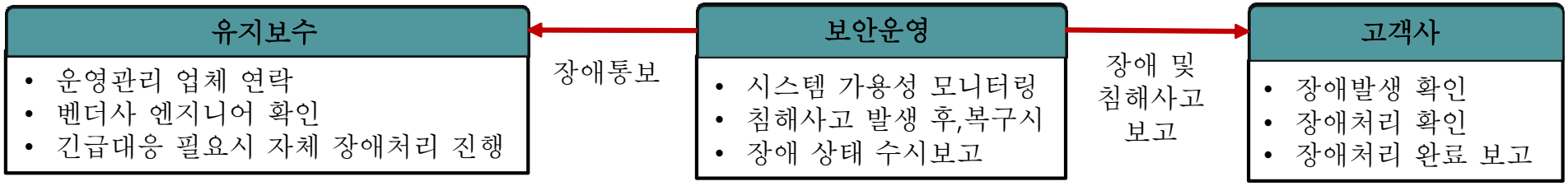
2-4. 보안관제 업무절차(보안운영)

☞ 재해복구관리 – 백업관리 (2/2)

Task	상세 설명	산출물	대상/주체	비고
백업대상 선정	운영대상 시스템 중 백업할 시스템을 선정하고, 해당 시스템의 백업대상을 선정한다.		보안운영 파트 (유지보수 지원)	
백업정책 수립	백업방법, 종류, 주기 등 백업정책을 수립한다.	백업정책 정의서		
백업계획 수립	수립된 백업정책에 의해 시스템에 적용할 백업 작업 계획을 수립한다.	백업 작업계획서		
유지보수 지원 필요	백업정책 적용을 위한 유지보수 지원 여부를 판단하고, 지원 필요시 작업계획에 지원 내역을 포함하여 수립한다.			
백업 수행	백업계획에 의한 백업 작업을 수행한다.			
이슈 발생	백업정책 적용 및 백업실행 시 이슈 발생 여부를 확인하고, 이슈 발생시 유지보수 지원 하에 이슈를 해결하거나, 해결 불가시 원복한다. ※ 이슈로 인한 백업작업 중단 시 이슈사항 해결 후 재작업			
백업결과 보고	백업작업 결과를 보고한다.	백업 결과보고서		
주기적인 백업정책 관리	주기적으로 백업정책의 적정성을 검토하고, 자산 변경 등 정책검토 사유 발생시 백업정책을 검토하여 관리한다.			
이력관리	이력을 관리한다.	이력관리		

2-4. 보안관제 업무절차(보안운영 - 장애관리)

보안시스템 의 효율적인 장애 관리 및 ESM 연동대상 장비에 대한 형상 관리로 시스템의 안정성을 도모하고 정규화된 운영 프로세스 및 Issue Lists를 통해 보안운영 최적화



야간 · 공휴일 장애 발생	장애처리 프로세스 가동	비상연락망 가동	장애 처리 완료
• 야간/주말/공휴일 SMS, 유선을 활용한 장애 정보 전송 • 1차 보고(PM) • 2차 보고 (PM → 고객사) • 장애 내용 및 영향도 확인	• 장애 분석을 통한 장애 등급 지정 • 장애 등급 및 장애 분야에 따른 해당 담당자 확인	• 비상연락망 목록 확인 • 유지보수 업체 연락 • 고객사 담당자 연락 (홈페이지 가용성 이슈)	• (긴급장애) • 처리 필요 시 고객사 담당자와 협의를 통한 장애처리 및 벤더사 방문요청 (유지보수 업체) • 장애 요청자와 장애 처리 완료에 상호 합의 • 장애 완료 보고

3-1. 보안관제 탐지 / 방어기술

사이버 공격의 탐지기술은 패턴기반 탐지기술, 행위기반 탐지기술 및 상관분석 기술로 분류하며, 세가지 탐지기술을 유기적으로 결합시키는 것이 중요

구분	패턴기반탐지	행위기반탐지	상관분석
내용	공격방법과 공격도구에 대한 분석을 통해 특정 패턴을 파악	▪ 일반적인 사용자와 구별되는 인터넷 사용패턴에 기반을 둔 탐지기법 ▪ 공격유형과 사용자 행동을 기계적 학습으로 모델링	▪ 둘 이상 이벤트가 서로 의미를 부여하여 하나의 결과물을 생성하는 것 ▪ 데이터마이닝 알고리즘 사용 (순서패턴, 분류규칙) ▪ 조건 : 정규화와 축약
장단점	▪ 탐지속도가 빠르고 정확성 높음 ▪ 사전에 분석된 공격형태만 탐지 가능	▪ 통계기반의 비정상 행위 탐지에 효과적 ▪ 통계적 특징이 불명확한 공격 탐지 불가능	▪ 공격 시나리오 기반 탐지가 가능하고 탐지의 정확성 향상 ▪ 상관분석 역량 및 시스템 성능 부족
관련 보안시스템	▪ IDS/IPS ▪ WAF ▪ DDoS ▪ Anti-Virus	▪ IDS/IPS ▪ WAF	▪ ESM ▪ SIEM ▪ TMS

3. 보안관제 기술

3-1. 보안관제 탐지 / 방어기술

공격자들의 침해행위에 대한 방어기술은 사전에 정의된 패턴을 통해 차단하는 패턴 기반 방어기술과 보안정책을 위반하는 행위를 차단하는 규칙(rule) 기반 방어기술로 구성

구분	패턴기반방어	규칙기반방어
내용	▪ 패턴 기반 탐지기술에 기초하여 사전에 정의한 패턴과 동일한 태래픽을 차단하는 기술 ▪ 전통적인 보안시스템에서 사용되는 방법	▪ 일련의 기술 즉, 취해야 할 특정 행위를 기준으로 차단하는 기술 ▪ 방화벽에서 보편적으로 사용되는 개념 ▪ 디폴트 규칙이 존재(디폴트거부, 디폴트 허용)
장단점	▪ 이미 알려져 있고 자주 변하지 않는 공격에 대해서는 매우 효과적 ▪ APT 공격처럼 끊임없이 변하고 은밀한 공격에는 비효율적	▪ 방어행위가 명확하고 대상 환경에 대한 이해가 용이 ▪ 모든 규칙을 상세화 하는 것이 어렵고 성능적 한계 존재
관련 보안시스템	▪ IDS/IPS ▪ WAF ▪ DDoS ▪ Anti-Virus	▪ 방화벽, DRM, DLP ▪ 출입통제시스템, DB보안시스템

3-2. 탐지패턴 활용

특정 바이러스나 악성코드 등 특정 패킷이 네트워크를 통과 할 때 탐지하기 위해 제작한 일종의 문구(시그니처)이며, Rule 이라고 부름

스노트(Snort)

Snort는 “Sniffer and more” 에서 유래 초기는 단순한 Packet Sniffer 프로그램 이였으나 현재는 분석 기능이 추가되고, 보완과 향상을 통해 지금과 같은 다양한 기능과 탁월한 성능을 갖춘 프로그램

1988년 Sourefire 프로토콜 분석, 데이터를 검색 및 매칭 및 다양한 옵션으로 사용자의 Rule 작성이 가능하게 함

3-2. 탐지패턴 활용

Snort Rule 구조

룰헤더							옵션
Action	Protocol	SrcIP	SrcPort	->	DstIP	DstPort	Option

Action 유형

명령어	내용
alert	경보발생 및 로그기록
log	Log 기록
pass	패킷무시
drop	패킷차단 및 로그기록(IPS 사용, 단 In-Line 구조로 되어야 함.)
reject	패킷차단 및 로그기록(TCP-TCP RST 응답, UDP-ICMP Unreachable 응답)
sdrop	패킷차단 및 로그기록 없음

3-2. 탐지패턴 활용

Protocol 유형

명령어	내용	명령어	내용
TCP	TCP 탐지	ICMP	ICMP 메시지 탐지
UDP	UDP 탐지	Any	전체
IP	IP 전체 탐지		

SrcIP / DstIP 유형

명령어	내용
192.168.20.50/32	192.168.20.50 Host
192.168.20.0/24	192.168.20.50/24 Subnet
192.168.20.0/24, 172.20.0.0/16	192.168.20.50/24, 172.20.0.0/16 Subnet
$HOME_NET	내부 IP 주소변수
$EXTERNAL_NET	외부 IP 주소변수
$XXX_SERVERS	특정 서버 IP 주소변수

3-2. 탐지패턴 활용

SrcPort / DstPort 유형

명령어	내용
80	80 Port
1:500	1 ~ 500 Port
!80	80Port를 제외한 나머지 Port
!1:500	1 ~ 500 Port를 제외한 나머지 Port
any	외부 IP 주소변수

방향지정

명령어	내용
->	요청 패킷 탐지(응답 패킷 탐지는 SrcIP / DstIP 반대로 설정)
<>	요청 / 응답 패킷 모두 탐지

3-2. 탐지패턴 활용

일반옵션

명령어	내용	형식
Msg	경고 이벤트 메시지	msg:"icmp ping test";
sid	룰 식별자(3000000 이상 권장)	Sid:3000001;
rev	룰버전, 수정될 경우 1씩 증가	Rev:1;
priority	우선순위(값이 작을수록 우선 매칭, 범위 1~10)	priority 1;
Classtype	Snort rule 분류	classtype:분류이름;
reference	취약점 참고 배포 URL 정보	reference:이름 http://~;

3-2. 탐지패턴 활용

흐름옵션

명령어	내용
flow	흐름 옵션 명령어
to_server 또는 from_client	client -> server 패킷 룰 매칭
to_client 또는 from_server	server -> client 패킷 룰 매칭
established	session이 연결된 상태의 룰 매칭
statless	session 연결 유무와 상관없이 룰 매칭
flow:to_server, established	client -> server session 연결 패킷 룰 매칭

3-2. 탐지패턴 활용

페이로드 탐색 옵션

명령어	내용	형식
content	문자/숫자 탐지	content:"XXX"; content:"|16진수 16진수|";
nocase	대소문자 구분없이 탐지	content:"XXX";nocase;
offset	지정한 바이트부터 탐지(3번째 부터 시작)	offset:3;
depth	지정한 바이트까지 탐지(10번째까지)	depth:10;
distance	content 매칭 후 지정위치 이후 다른 content 탐색	content:"XXX";content:"yyy";distance:5;
within	content 매칭 후 지정위치 안에 다른 content 탐색	content:"XXX";content:"yyy";within:5;
pcre	정규화표기, '/'는 시작과 끝에 표기, 16진수는 앞에 ₩x	Pcre:"/(http,ftp) Traffic/";

3-2. 탐지패턴 활용

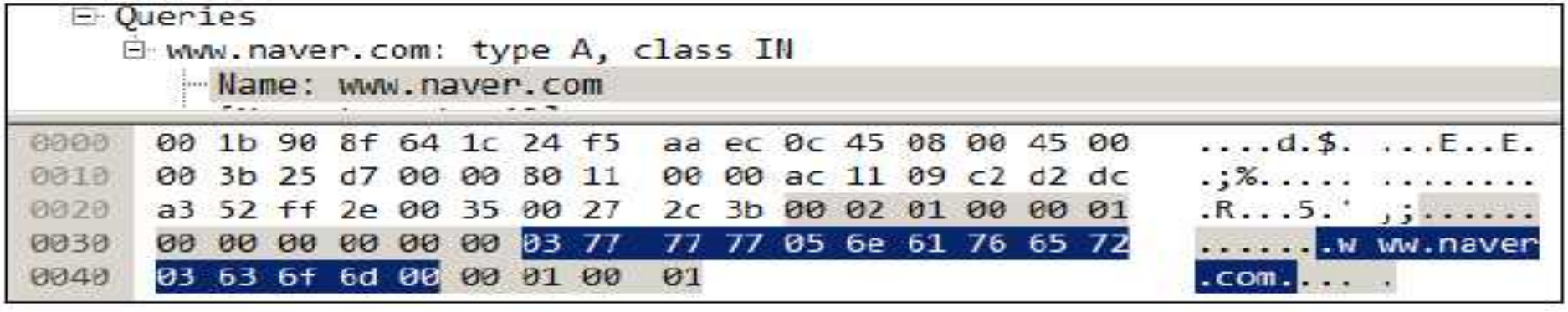
일반적인 탐지패턴

☞ **문자열 탐지패턴**

“naver” 라는 탐지 패턴을 입력하면 해당 문자가 있으면 모두 탐지

☞ **HEXA CODE 방식**

헥사코드 16진수로 나타내는 인코딩 방식 문자열 탐지패턴이란 점은 동일하지만, 패턴으로 작성된 글자가 숫자로 표현



3-2. 탐지패턴 활용

탐지패턴(예시)

- ☞ 프로토콜은 Tcp이고 출발지 IP 및 Port는 Any
- ☞ 목적지 IP 10.10.10.10 으로 Port Any
- ☞ 타입은 Post 방식을 사용하며, .xls Or .xms Or .xlsx의 확장자를 가진 패킷을 탐지

alert tcp any any -> 10.10.10.10 any
룰 헤더 부분

옵션키
Contents
PCRE

옵션값
"POST" "/(₩x2Exls|₩x2xml|₩x2Exlsx)/si

3-2. 탐지패턴 활용

탐지패턴(예시)

- ☞ SQL Injection 탐지하고 경고를 발생 패턴 : 1’and’ 1’=1'
- ☞ SQL Injection 공격 패턴 : 1’and’ 1’=1'
- ☞ 외부에서 내부로 들어오는 tcp 패킷(대소문자 구분없음)

alert tcp $EXTERNAL_NET any -> $HOME_NET any
룰 헤더 부분

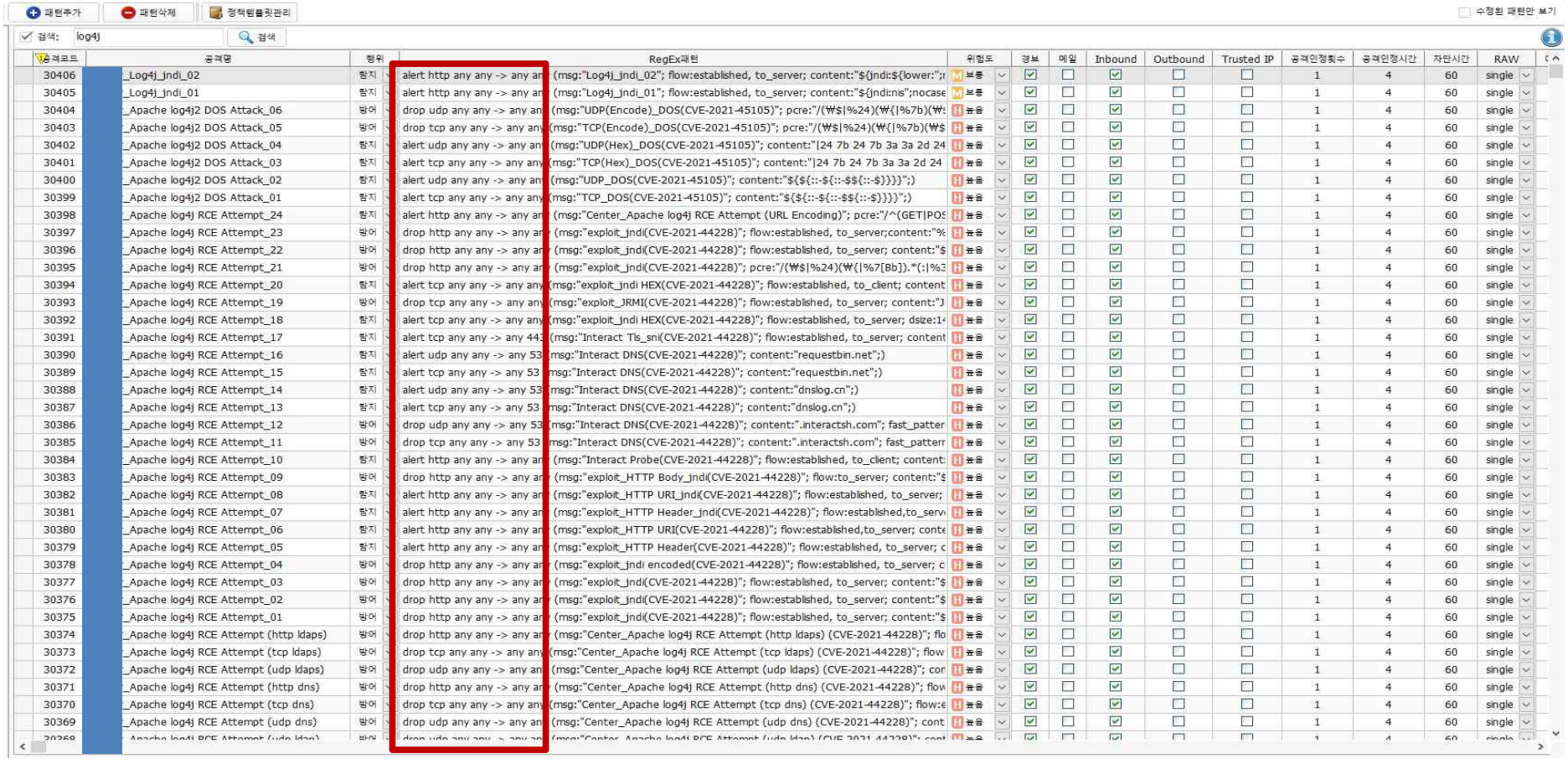
옵션키
Contents
PCRE

옵션값
“msg:”SQL-Injection”; ”content:”1'and’ 1'=1’”;nocase;sid:3000001;rev:1

3. 보안관제 기술

3-2. 탐지패턴 활용

실제 적용된 탐지패턴(예시)



공격코드	공격명	행위	RegEx패턴	위협도	경보	메일	Inbound	Outbound	Trusted IP	공격인정횟수	공격인정시간	차단시간	RAW
30406	_Log4j_jndi_02	탐지	alert http any any -> any any (msg:"Log4j_jndi_02"; flow:established, to_server; content:"${jndi:${lower:";r	보통	☑	☐	☑	☐	☐	1	4	60	single
30405	_Log4j_jndi_01	탐지	alert http any any -> any any (msg:"Log4j_jndi_01"; flow:established, to_server; content:"${jndi:nis";nocase	보통	☑	☐	☑	☐	☐	1	4	60	single
30404	_Apache log4j2 DOS Attack_06	방어	drop udp any any -> any any (msg:"UDP(Encode)_DOS(CVE-2021-45105)"; pcre:"/(₩$\|%24)(₩{\|%7b)(₩$	높음	☑	☐	☑	☐	☐	1	4	60	single
30403	_Apache log4j2 DOS Attack_05	방어	drop tcp any any -> any any (msg:"TCP(Encode)_DOS(CVE-2021-45105)"; pcre:"/(₩$\|%24)(₩{\|%7b)(₩$	높음	☑	☐	☑	☐	☐	1	4	60	single
30402	_Apache log4j2 DOS Attack_04	탐지	alert udp any any -> any any (msg:"UDP(Hex)_DOS(CVE-2021-45105)"; content:"|24 7b 24 7b 3a 3a 2d 24	높음	☑	☐	☑	☐	☐	1	4	60	single
30401	_Apache log4j2 DOS Attack_03	탐지	alert tcp any any -> any any (msg:"TCP(Hex)_DOS(CVE-2021-45105)"; content:"|24 7b 24 7b 3a 3a 2d 24	높음	☑	☐	☑	☐	☐	1	4	60	single
30400	_Apache log4j2 DOS Attack_02	탐지	alert udp any any -> any any (msg:"UDP_DOS(CVE-2021-45105)"; content:"${${::-${::-$${::-$}}}}";)	높음	☑	☐	☑	☐	☐	1	4	60	single
30399	_Apache log4j2 DOS Attack_01	탐지	alert tcp any any -> any any (msg:"TCP_DOS(CVE-2021-45105)"; content:"${${::-${::-$${::-$}}}}";)	높음	☑	☐	☑	☐	☐	1	4	60	single
30398	_Apache log4j RCE Attempt_24	탐지	alert http any any -> any any (msg:"Center_Apache log4j RCE Attempt (URL Encoding)"; pcre:"/^(GET|POS	높음	☑	☐	☑	☐	☐	1	4	60	single
30397	_Apache log4j RCE Attempt_23	방어	drop http any any -> any any (msg:"exploit_jndi(CVE-2021-44228)"; flow:established, to_server;content:"%	높음	☑	☐	☑	☐	☐	1	4	60	single
30396	_Apache log4j RCE Attempt_22	방어	drop http any any -> any any (msg:"exploit_jndi(CVE-2021-44228)"; flow:established, to_server; content:"$	높음	☑	☐	☑	☐	☐	1	4	60	single
30395	_Apache log4j RCE Attempt_21	방어	drop http any any -> any any (msg:"exploit_jndi(CVE-2021-44228)"; pcre:"/(₩$|%24)(₩{|%7[Bb]).*(:|%3	높음	☑	☐	☑	☐	☐	1	4	60	single
30394	_Apache log4j RCE Attempt_20	탐지	alert tcp any any -> any any (msg:"exploit_jndi HEX(CVE-2021-44228)"; flow:established, to_client; content	높음	☑	☐	☑	☐	☐	1	4	60	single
30393	_Apache log4j RCE Attempt_19	방어	drop tcp any any -> any any (msg:"exploit_JRMI(CVE-2021-44228)"; flow:established, to_server; content:"J	높음	☑	☐	☑	☐	☐	1	4	60	single
30392	_Apache log4j RCE Attempt_18	탐지	alert tcp any any -> any any (msg:"exploit_jndi HEX(CVE-2021-44228)"; flow:established, to_server; dsize:1	높음	☑	☐	☑	☐	☐	1	4	60	single
30391	_Apache log4j RCE Attempt_17	탐지	alert tcp any any -> any 443 (msg:"Interact Tls_sni(CVE-2021-44228)"; flow:established, to_server; content	높음	☑	☐	☑	☐	☐	1	4	60	single
30390	_Apache log4j RCE Attempt_16	탐지	alert udp any any -> any 53 (msg:"Interact DNS(CVE-2021-44228)"; content:"requestbin.net";)	높음	☑	☐	☑	☐	☐	1	4	60	single
30389	_Apache log4j RCE Attempt_15	탐지	alert tcp any any -> any 53 (msg:"Interact DNS(CVE-2021-44228)"; content:"requestbin.net";)	높음	☑	☐	☑	☐	☐	1	4	60	single
30388	_Apache log4j RCE Attempt_14	탐지	alert udp any any -> any 53 (msg:"Interact DNS(CVE-2021-44228)"; content:"dnslog.cn";)	높음	☑	☐	☑	☐	☐	1	4	60	single
30387	_Apache log4j RCE Attempt_13	탐지	alert tcp any any -> any 53 (msg:"Interact DNS(CVE-2021-44228)"; content:"dnslog.cn";)	높음	☑	☐	☑	☐	☐	1	4	60	single
30386	_Apache log4j RCE Attempt_12	방어	drop udp any any -> any 53 (msg:"Interact DNS(CVE-2021-44228)"; content:".interactsh.com"; fast_patter	높음	☑	☐	☑	☐	☐	1	4	60	single
30385	_Apache log4j RCE Attempt_11	방어	drop tcp any any -> any 53 (msg:"Interact DNS(CVE-2021-44228)"; content:".interactsh.com"; fast_patterr	높음	☑	☐	☑	☐	☐	1	4	60	single
30384	_Apache log4j RCE Attempt_10	탐지	alert http any any -> any any (msg:"Interact Probe(CVE-2021-44228)"; flow:established, to_client; content:	높음	☑	☐	☑	☐	☐	1	4	60	single
30383	_Apache log4j RCE Attempt_09	방어	drop http any any -> any any (msg:"exploit_HTTP Body_jndi(CVE-2021-44228)"; flow:to_server; content:"$	높음	☑	☐	☑	☐	☐	1	4	60	single
30382	_Apache log4j RCE Attempt_08	탐지	alert http any any -> any any (msg:"exploit_HTTP URI_jndi(CVE-2021-44228)"; flow:established, to_server;	높음	☑	☐	☑	☐	☐	1	4	60	single
30381	_Apache log4j RCE Attempt_07	탐지	alert http any any -> any any (msg:"exploit_HTTP Header_jndi(CVE-2021-44228)"; flow:established,to_serv	높음	☑	☐	☑	☐	☐	1	4	60	single
30380	_Apache log4j RCE Attempt_06	탐지	alert http any any -> any any (msg:"exploit_HTTP URI(CVE-2021-44228)"; flow:established,to_server; conte	높음	☑	☐	☑	☐	☐	1	4	60	single
30379	_Apache log4j RCE Attempt_05	탐지	alert http any any -> any any (msg:"exploit_HTTP Header(CVE-2021-44228)"; flow:established, to_server; c	높음	☑	☐	☑	☐	☐	1	4	60	single
30378	_Apache log4j RCE Attempt_04	방어	drop http any any -> any any (msg:"exploit_jndi encoded(CVE-2021-44228)"; flow:established, to_server; c	높음	☑	☐	☑	☐	☐	1	4	60	single
30377	_Apache log4j RCE Attempt_03	방어	drop http any any -> any any (msg:"exploit_jndi(CVE-2021-44228)"; flow:established, to_server; content:"$	높음	☑	☐	☑	☐	☐	1	4	60	single
30376	_Apache log4j RCE Attempt_02	방어	drop http any any -> any any (msg:"exploit_jndi(CVE-2021-44228)"; flow:established, to_server; content:"$	높음	☑	☐	☑	☐	☐	1	4	60	single
30375	_Apache log4j RCE Attempt_01	방어	drop http any any -> any any (msg:"exploit_jndi(CVE-2021-44228)"; flow:established, to_server; content:"$	높음	☑	☐	☑	☐	☐	1	4	60	single
30374	_Apache log4j RCE Attempt (http ldaps)	방어	drop http any any -> any any (msg:"Center_Apache log4j RCE Attempt (http ldaps) (CVE-2021-44228)"; flo	높음	☑	☐	☑	☐	☐	1	4	60	single
30373	_Apache log4j RCE Attempt (tcp ldaps)	방어	drop tcp any any -> any any (msg:"Center_Apache log4j RCE Attempt (tcp ldaps) (CVE-2021-44228)"; flow	높음	☑	☐	☑	☐	☐	1	4	60	single
30372	_Apache log4j RCE Attempt (udp ldaps)	방어	drop udp any any -> any any (msg:"Center_Apache log4j RCE Attempt (udp ldaps) (CVE-2021-44228)"; cor	높음	☑	☐	☑	☐	☐	1	4	60	single
30371	_Apache log4j RCE Attempt (http dns)	방어	drop http any any -> any any (msg:"Center_Apache log4j RCE Attempt (http dns) (CVE-2021-44228)"; flow	높음	☑	☐	☑	☐	☐	1	4	60	single
30370	_Apache log4j RCE Attempt (tcp dns)	방어	drop tcp any any -> any any (msg:"Center_Apache log4j RCE Attempt (tcp dns) (CVE-2021-44228)"; flow:e	높음	☑	☐	☑	☐	☐	1	4	60	single
30369	_Apache log4j RCE Attempt (udp dns)	방어	drop udp any any -> any any (msg:"Center_Apache log4j RCE Attempt (udp dns) (CVE-2021-44228)"; cont	높음	☑	☐	☑	☐	☐	1	4	60	single

4. 보안관제 시스템

4-1. 보안솔루션 분류

분 류	Step 1	Step 2	Step 3	Step 4
네트워크 보안	방화벽(Firewall)	침입탐지시스템(IDS) 프로토콜 분석도구	침입방지시스템(IPS)	네트워크 접근통제 (NAC)
시스템 보안	바이러스 백신 시스템 방화벽	스팸차단 소프트웨어 패치관리시스템(PMS)	보안운영체제 시스템취약점 분석툴	
애플리케이션 보안		웹방화벽(WAF) 스팸메일차단솔루션	문서저작권관리(DRM) DB 보안 솔루션 웹스캐너(취약점분석)	소스코드 분석도구 취약점스캔 Appliance
통합 보안관리	로그관리 및 분석도구	보안구성관리(SCM)	통합보안시스템(UTM) 전사적보안관리(ESM)	위협관리시스템(TMS) 위험관리시스템(RMS) 포괄적위협관리(CTM)
인증 및 접근통제	싱글사인온(SSO)	스마트 카드 통합접근관리(EAM)	하드웨어 토큰 일회용 비밀번호(OTP) 통합계정관리(EIM)	바이오인식시스템 (지문, 정맥, 얼굴, 홍채, 다중인식 등)
PC 보안	바이러스 백신 안티 스파이웨어	개인용 PC 방화벽	개인용 안티스팸	통합 PC 보안
기타보안	가상사설망(VPN)	공개키기반구조(PKI) 무선랜 보안(Wireless)	모바일 보안(Mobile) RFID 보안	기업정보 유출방지
보안 서비스	인증(공인/사설)	솔루션 유지보수	보안관제 보안교육훈련	보안 컨설팅

4. 보안관제 시스템

4-1. 보안솔루션 분류

단계별 정보보호시스템 구성

단계	적용범위	설명
Step1	소규모 조직(15명 이하), 비영리 기관	조직을 안전하게 운영하기 위한 최소한의 보안솔루션
Step2	중소기업	중소 규모의 조직에서 효과적인 보안 체계를 갖추기 위한 보안 솔루션
Step3	대기업	대규모 조직에서 효율적으로 관리 및 통제하기 위한 보안 솔루션
Step4	기밀정보를 다루는 주요 조직	군사, 주요 정부기관, 핵심 사업부 등 고도의 보안 수준을 요구하는 조직을 위한 보안 솔루션

4. 보안관제 시스템

4-1. 보안솔루션 분류

정보보호 시스템 종류 및 기능

구분	기능
홈페이지 APT 웹쉘공격 탐지 및 차단 시스템	· 웹쉘 및 홈 디렉터리 설정변경 탐지 · 악성코드유포지 URL 탐지 · 웹쉘 탐지 정보 및 이력 저장
정보시스템 서버 접근통제 및 보안감사 시스템	· 접근통제에 의한 모든 작업 이력 저장 · 장애 및 보안사고 발생 시 사후 추적 가능
지능형 네트워크 접근통제 시스템(NAC)	· 네트워크 접속 단말인증 및 무결성 검증 · 필수 S/W 설치 및 불법 소프트웨어 삭제 유도
위협관리시스템(TMS)	· 유해 트래픽 및 악성코드를 실시간 탐지
방화벽(FW)	· 침입차단시스템으로 내부 시스템을 보호하기 위해 IP 및 프로토콜 기반으로 내·외부를 접속 차단하는 시스템
침입방지시스템(IPS)	· 실시간 사이버 공격을 탐지 및 차단하는 시스템으로 악성코드 및 악의적인 바이러스에 대해 문자열 방식으로 탐지하여 차단하는 시스템
내부정보유출 방지시스템	· 사용자 컴퓨터에서 사용하는 메신저(MSN, 네이트온 등) 프로그램 사용 차단 및 이메일 송신 시 붙임 파일 용량 통제 등 내부정보의 유출을 방지하기 위한 시스템

4. 보안관제 시스템

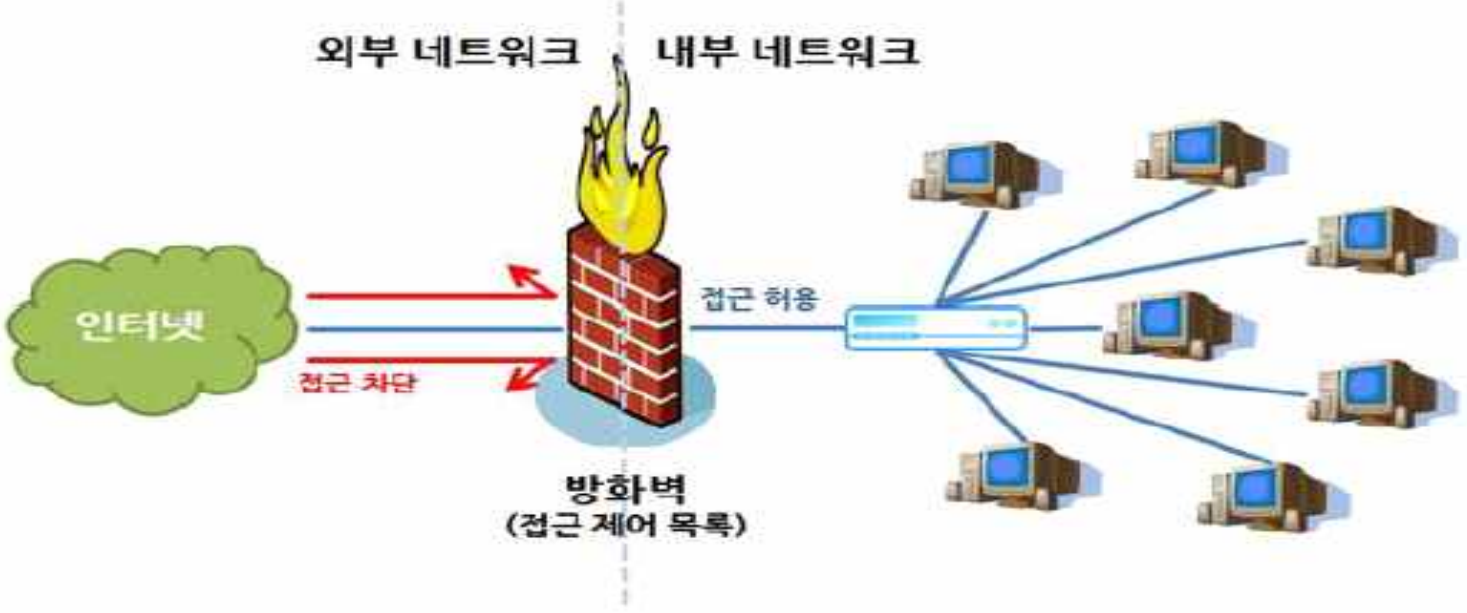
4-1. 보안솔루션 분류

정보보호 시스템 종류 및 기능

구분	기능
홈페이지 위·변조 감시 시스템	· 악의적인 사이버 공격에 의한 홈페이지 화면 위·변조 사항을 실시간 탐지 및 웹 접속 정상 상태를 모니터링하는 시스템
무선랜 침입 차단 시스템 (WIPS)	· 기관 내 비인가 무선 AP 탐지 및 무선랜에 대한 위협을 탐지·차단하는 시스템
DDoS 공격대응 장비	· DDoS 공격에 대한 차단에 특화된 시스템
개인정보 유출방지 시스템	· 컴퓨터에서 주민번호, 여권번호 등 고유식별정보 및 중요 정보가 포함된 문서를 식별하거나 외부유출 시 차단하는 시스템
웹방화벽(WAF)	· 웹 서비스에 대한 사이버 공격 차단에 특화된 시스템
해킹메일 차단 시스템 스팸메일 차단 시스템	· 악의적인 바이러스 및 악성코드 포함된 메일을 수신시에 탐지 및 차단 · 일반적인 다량의 메일 수신 및 비정상적인 메일을 수신 시 차단
지능형지속위협(APT) 공격 대응 시스템	· 시그니처(문자) 기반의 정보보호시스템과는 달리 비정상적인 행위를 판별하여 이상징후를 탐지 및 차단
매체제어시스템	· 인가된 USB 저장장치, 이동형 저장장치의 연결을 허용하고 기타 비인가된 장치에 대해서는 차단 등의 통제 시스템

4-2. 방화벽(Fire Wall)

네트워크에서 방화벽은 보안의 가장 일차적인 것으로, 신뢰하지 않는 외부 네트워크와 신뢰하는 내부 네트워크 사이를 지나는 패킷을 미리 정한 규칙에 따라 차단하거나 보내주는 기능을 하는 하드웨어나 소프트웨어를 말함



4-2. 방화벽(Fire Wall)

방화벽 방어기능

☞ 패킷 필터링

- 소스 및 대상자 IP주소, 포트번호 등 통신 데이터의 통과여부를 판단해 무단 접근을 방지

5	IT기획팀	Any	ANY	✓
0	Any	Any	ANY	✗



- 모든 방화벽 정책은 위에서 아래 순으로 적용 / 필요한 정책만 허용하고 나머지 모두 Deny
- 방화벽 제조사가 매우 많아 정책을 운영하는 환경은 다양하나 기본적인 운영은 큰 차이 없음

※ 방화벽 정책 설정 시에 최소 3번 이상 확인

4-2. 방화벽(Fire Wall)

방화벽 방어기능

☞ 애플리케이션 게이트웨이

- 통신을 중계하는 프록시 서버를 이용해 사내 네트워크과 인터넷 사이에 직접 통신 차단
- 많은 방화벽은 네트워크 주소변환(NAT) 기능을 가지고 있음
- 내부 네트워크 사용하는 IP 주소와 외부에 드러나는 주소가 다르게 유지할 수 있기 때문에 내부 네트워크에 대한 어느 정도의 보안 기능을 지원





4-2. 방화벽(Fire Wall)

방화벽 방어기능

☞ 방화벽을 이용한 로그 분석 및 관제

- 방화벽은 일반적으로 탐지패턴 적용이 아닌 IP 주소와 포트기반으로 패킷을 통과시키거나 차단하는 시스템 즉, 패턴으로 탐지를 못한다 해도 방화벽에서 어떤 IP에서 어떤 포트로 접속 했는지 세션 정보가 확인됨
- 방화벽의 Accept와 Deny 로그를 이용하면 시그니처 기반으로 탐지 못한 이상행위 발견 가능성
- 최근에는 방화벽을 빅데이터 기반으로 분석하여 유용하게 사용 되기도 함

예) 악성코드 감염에 의해 C&C IP와 TCP 통신을 하는 내역 조회 등

☞ 방화벽의 한계

- 방화벽은 네트워크 트래픽이 흐르는 경로 내부(In-Line)에 위치하기 때문에 방화벽 자체 공격의 대상이 되어서 대용량의 트래픽을 견디지 못하고 다운되는 경우가 많음
- 전체 네트워크 마비(장애)가 발생할 위험이 상당히 높음
- 정상적인 서비스 HTTP, DNS 같은 일반적인 인터넷 프로토콜을 이용한 공격은 방어가 어려움

4-3. IDS / IPS

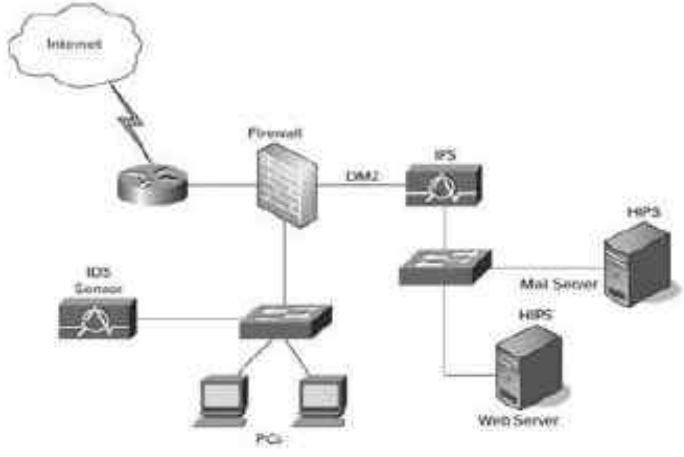
IDS / IPS 주요기능

☞ IPS(Intrusion Prevention System)

- 공격패턴을 기반으로 패턴과 일하는 패킷에 대해서 차단하는 보안 시스템
- 주기적인 패턴 업데이트가 필요하며 정상트래픽도 패턴과 일치 할 경우 차단하므로 오탐 가능성이 존재
- 임계치 기반으로 트래픽을 탐지해 차단 가능 IDS와 다르게 네트워크 상에 In-Line 구조로 설치

☞ IDS(Intrusion Detection System)

- IDS는 침입을 탐지만 하고 IPS는 방어기능까지 수행
- TAP 방식이나 Mirror 방식으로 설치

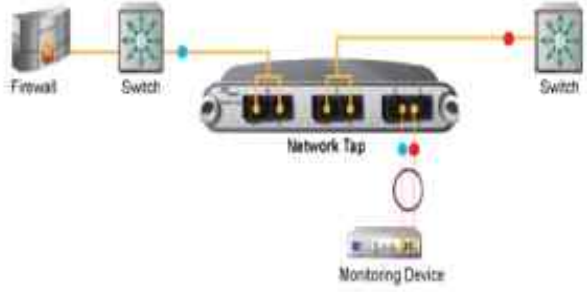


4-3. IDS / IPS

IDS / IPS 트래픽 분석 구성

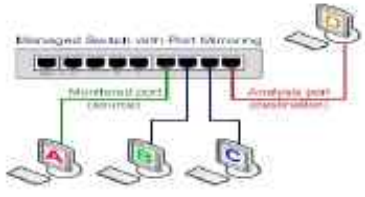
☞ TAP

- 트래픽 손실이나 변조 없이 복사해 주는 장비인 TAP으로 트래픽을 검사하는 구조
- 최초 설치 시 네트워크 단절 필요
- 장비 장애 발생 시 서비스 중단 추가 비용 발생



☞ 스위치 미러링

- 일반적으로 EnterPrise급 Switch에는 Analyzer의 연결을 위한 Mirroring 기능을 지원
- Switch management utility를 통하여 mirror port를 설정



4-3. IDS / IPS

IDS / IPS 트래픽 분석 구성

☞ In-Line

- 트래픽 손실이나 변조 없이 복사해 주는 장비인 TAP으로 트래픽을 검사하는 구조
- 모든 트래픽이 보안시스템을 거쳐서 가기 때문에 하드웨어 장애에 민감

☞ By-Pass

- In-Line 장비에 제공되는 전원에 이상이 있을 경우(정전 등)
- In-Line 장비에 물리적인 문제가 발생할 경우
- In-Line 장비에 에 탑재되어 있는 O.S에 문제가 발생할 경우(O.S Panic 등)
- IPS 엔진에 문제가 발생할 경우 (Dead Lock으로 인한 Hang Up 등)

※ 최근에는 By-Pass 모드 자체의 문제점을 보완하기 위해 By-pass 스위치를 추가로 구성하는 경우가 많음

4-3. IDS / IPS

IDS / IPS 트래픽 분석 구성

☞ Mirror - In-Line – By Pass 스위치

- Aggregation : Network(N)개의 포트를 Tool포트(1) Aggregation 하는 기능



- Replication : Network(1)개의 포트를 Tool포트(N) Replication 하는 기능



- Filtering : Network포트로 들어온 패킷을 Filtering을 통해 특정 트래픽만 Tool port로 보내는 기능

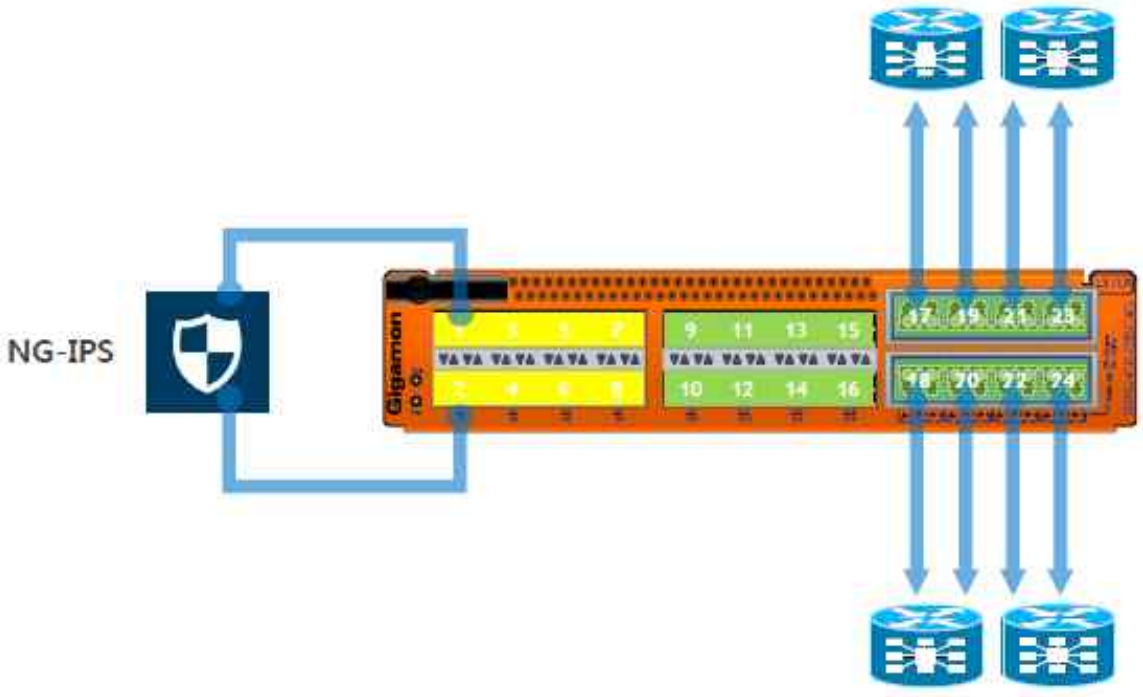


4-3. IDS / IPS

IDS / IPS 트래픽 분석 구성

☞ **Mirror - In-Line – By Pass 스위치**

- 보안시스템이 장애가 발생하더라도 스위치에서 By-Pass 시켜주는 방식



4-4. DDoS 대응 솔루션

DDoS 대응 솔루션의 기능

☞ DDoS대응장비는 기존의 방화벽/IPS 등에 일부 포함된 DDoS방어 기능에서 벗어나 DDoS공격에 효과적으로 방어할 수 있도록 특화된 솔루션

☞ IPS와 같이 자체적으로 내장된 시그니처 기반 위주 탐지 방식으로는 방어가 불가능하므로 DDOS 대응 장비는 트래픽 자체 분석 기능 뿐만 아니라 트래픽을 발송하는 주체 중 좀비 PC를 구별해 낼 수 있는 알고리즘을 제공





4-4. DDoS 대응 솔루션

DDoS 대응 솔루션의 기능

☞ DDoS 대응 솔루션 차단 원리

- 효율적인 차단을 위해서 장비의 성능을 극대화
- 행동기반과 시그니처 기반의 탐지 방어 기법으로 차단
- 네트워크 행동기반 탐지기법을 적용해 DDoS 공격 유형별 방어 자동 학습에 의한 시그니처 생성 자동 패킷 캡처 및 패턴 추출 후 공격을 방어

☞ DDoS 대응 솔루션 한계

- 비정상적인 공격성 패킷과 고객이 발송하는 정상적인 서비스 요청 패킷을 정확히 구분하기 어려움



4-4. DDoS 대응 솔루션

DDoS 대응 솔루션의 기능

☞ 네트워크 차원 – DDoS 대응기법

- 네트워크 차원에서 서비스거부공격에 대한 기존의 방어기술로써 대표적인 것은 ACL, Blackhole Routing (Null0 Routing), Sinkhole Routing등이 있으며, 공격에 대한 추적을 위해서는 트래픽 흐름을 분석할 수 있는 NetFlow 기술이 대표적

- ACL(Access Control List) :
  IP주소, 서비스 포트 그리고 컨텐츠를 기반으로 한 차단 하지만 이 방법은 접근통제를 위한 별도의 ASIC 화된 모듈이 없을 경우 네트워크 장비에 많은 부담을 주어 성능저하의 원인

- Null0 Routing(Blackhole) :
  특정한 목적지로 향하는 패킷들을 Null0라는 가상 인터페이스에 포워딩 함으로써 drop 시킬 수 있는 기술 악성공격 패킷 뿐만 아니라 정상적인 트래픽도 모두 소멸

4-4. DDoS 대응 솔루션

DDoS 대응 솔루션의 기능

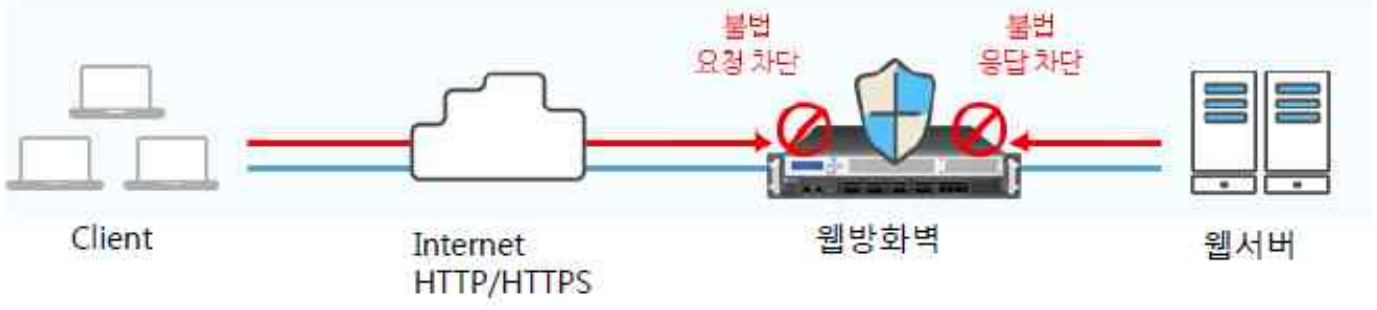
☞ 네트워크 차원 – DDoS 대응기법

- Sinkhole Routing : 특정한 목적지로 향하는 패킷들을 다른 경로로 포워딩
- ISP(SKB, KT, LG U+)

4-5. 웹방화벽(WAF)

웹방화벽 기능

☞ 웹 트래픽에 특화된 보안 솔루션 웹서버 앞에서 사용자의 서비스 요청과 서버의 응답을 검사하여 정상트래픽은 통과 시키고, 인젝션 인증 및 세션관리 취약점, 크로스사이트 스크립팅 등과 같은 악의적인 요청 및 주민번호, 신용카드, 계좌번호 등 민감한 정보 유출에 대한 응답을 차단



4-5. 웹방화벽(WAF)

웹방화벽 기능

☞ 예전 웹방화벽은 OWASP 기준의 웹 유해 트래픽을 차단했다면, 현재는 웹 애플리케이션 취약점에 중점을 두고 패턴 등록 및 차단 진행

- 정보유출방지 : 개인정보가 웹 게시판에 게시되거나 개인 정보가 포함된 파일 등이 웹을 통해 업로드 및 다운로드 되는 경우에 대해서 탐지하고 이에 대응

- 부정 로그인 방지 : 추정 가능한 모든 경우의 수를 대입하여 웹사이트에 로그인을 시도하는 경우와 같은 비정상적인 접근에 대한 접근 제어 기능

- 웹사이트 위변조 방지 : 웹사이트 위변조가 발생 했을 경우 탐지

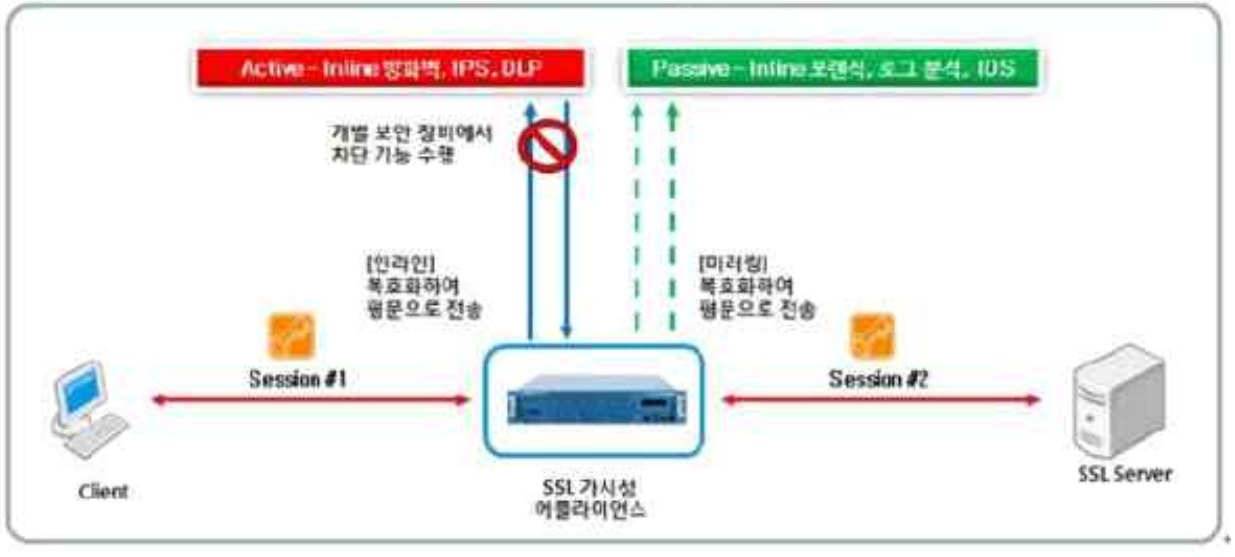
4-5. 웹방화벽(WAF)

웹방화벽 – SSL 복호화 연동

☞ 암호화에 숨은 공격, 인라인 복호화로 투명하게 탐지

☞ 암호화는 데이터를 보호할 수 있는 완벽한 방법이긴 하지만, 공격을 숨기는 최적의 기술이기도 함

<SSL 가시성 장비의 구성방법>



4-5. 웹방화벽(WAF)

웹방화벽 – 웹쉘탐지솔루션

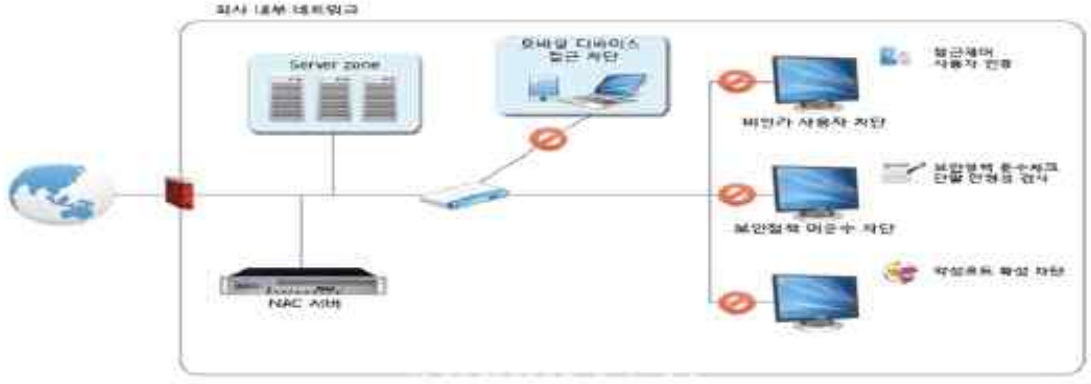
☞ 웹쉘은 웹 공격에 가장 많이 사용되는 기법으로, 웹사이트 취약점을 이용해 게시판 자료실 등에 공격코드를 업로드하고, 원격으로 웹 서버 정보, 관리자 권한을 탈취함



4-5. NAC

NAC 기능

☞ NAC(Network Access Control) 시스템은 네트워크 진입 시 단말과 사용자를 인증하고, 네트워크를 사용 중인 단말에 대한 지속적인 보안 취약점 점검과 통제를 통해 내부 시스템을 보호하는 네트워크 접근제어 솔루션



- 네트워크 접근 요청 : 접속하고자 하는 PC 사용자는 최초 네트워크에 대한 접근을 시도
- 사용자 및 PC 인증 : NAC에 등록되어 있는 MAC 주소를 통해 사용자 PC를 인증하거나 SSO와 연계하여 네트워크에 접근하고자 하는 사용자의 아이디와 패스워드를 추가로 요청하여 인증을 수행 인증 과정에서 백신이나 보안 패치의 적절성 여부를 검토
- 네트워크 접근 허용 : 인증이 완료된 경우 네트워크에 대한 접근을 허용
- 네트워크 접근 거부 : 보안 정책이 제대로 준수되지 않았거나 바이러스에 감염되어 있는 경우 네트워크 접근이 거부되고, 네트워크에서 격리 격리된 PC는 필요한 정책 적용이나 치료 과정을 거쳐 다시 점검

4-6. Anti-Virus

Anti-Virus 기능

☞ 바이러스 백신 소프트웨어는 바이러스, 웜과 같은 악성 소프트웨어 프로그램을 검색, 방지, 해제 또는 제거하는 컴퓨터 프로그램

☞ 최근에는 클라우드 기반, 랜섬웨어 암호화 차단 백신 / IE 취약점, Flash 취약점 등을 차단



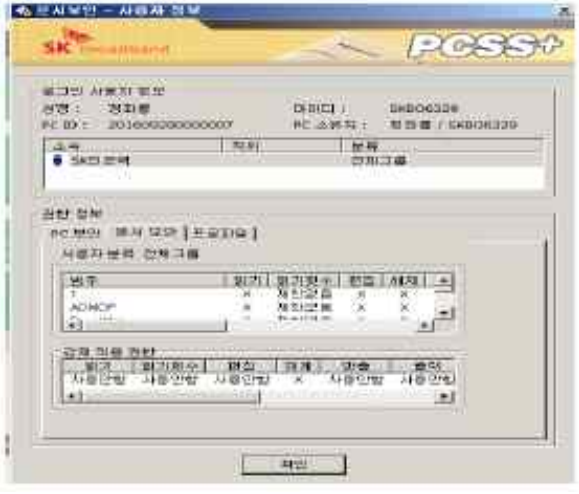
4-7. 기타 보안 솔루션

매체제어시스템

☞ 이동식 저장매체(USB), CD/DVD, FDD, 적외선 장치, 블루투스 장치, 휴대폰 장치, 무선랜 장치 와이브로 장치, 모뎀 장치 등 다양한 매체에 대해서 컴퓨터에 연결을 통제

DRM(Digital Rights Management)

☞ 문서 보안에 초점을 맞춘 기술로 문서 열람/편집/인쇄까지의 접근 권한을 설정하여 통제 특정한 형태의 문서만 통제하는 것이 아니라 MS워드나 HWP, TXT, PDF 파일 등 사무에 사용하는 대부분의 파일을 통제



4-7. 기타 보안 솔루션

DB암호화 솔루션

☞ 데이터 암호화를 통한 정보유출 원천 방지

- 개인정보 필드 암호화
- 개인정보 접근 이력 감사로그
- 개인정보 접근 통제 / 영역 분리

스팸차단 솔루션

☞ 데이터 암호화를 통한 정보유출 원천 방지

- 보낸사람, ID, 제목, 첨부파일, 전송 횟수 등을 탐지하여 차단
- 최근에는 APT 기능을 가지고 있어 스팸 메일 차단 뿐만 아니라, 악성코드 및 각종 공격에 대해서 차단 수행



4. 보안관제 시스템

실습

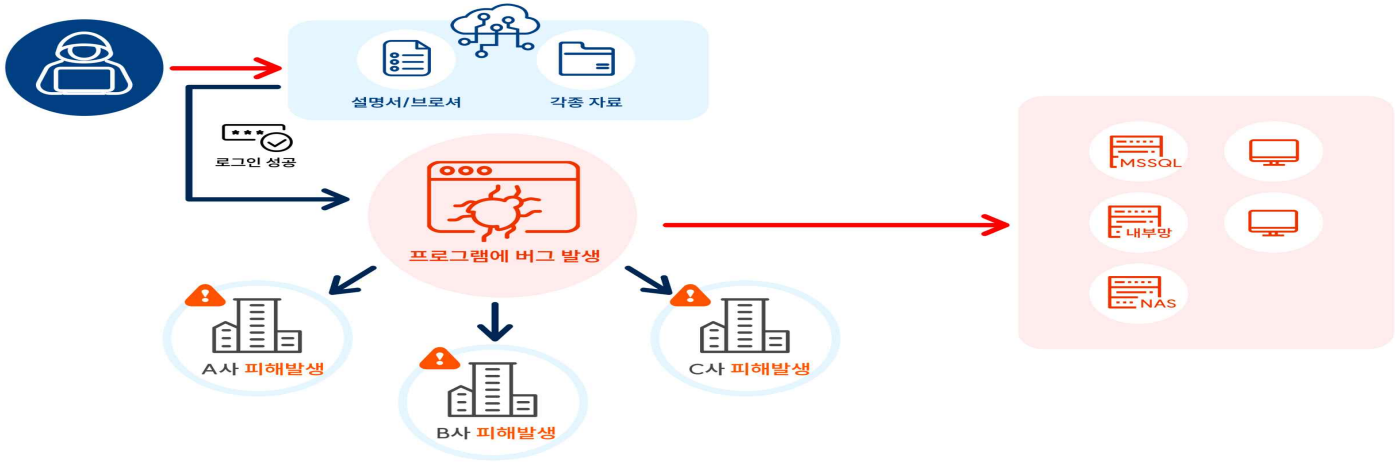
https://www.boannews.com/media/view.asp?idx=114108 로 접속하여 내용 확인 후

보안담당자 입장에서의 대응방안 작성 (4-1 보안솔루션 분류 참고)

4. 보안관제 시스템

과제

취약항목 / 대응방안 작성



<침투 시나리오 설명>

본 침투 시나리오는 상용 제품의 관리적·기술적 보안 공백이 내부망 전반의 위협으로 확산된 사례이다. 침투 초기 단계에서 공격자는 외부에 공개된 매뉴얼 및 브로셔를 통해 제품 구조와 제조사 기본 계정을 식별하였다. 해당 계정이 변경되지 않은 상태로 운영되고 있었으며, 이는 초기 정보수집 단계에서 핵심 단서로 활용되었다. 이후 솔루션의 파일 업로드 기능에서 입력값 검증 로직이 부재한 사실이 확인되었으며, 공격자는 이를 악용하여 웹셸 파일을 업로드·실행함으로써 서버의 제어권을 획득하였다. 침투 성공 후, 공격자는 서버 내 평문으로 저장된 접속 정보와 설정 파일을 수집하여 2차 공격 대상과 내부 자산의 위치를 식별하였다. 특히 내부망 서버 간 접근 통제 정책이 미흡해, 단일 솔루션 서버의 침투가 내부 확산의 게이트웨이로 작용하였다. 결과적으로 MSSQL 데이터베이스, 사내 서버, NAS, 임직원 PC까지 랜섬웨어가 전파되며 피해 범위가 전사적으로 확산되었다.

5. 보안관제 실무

5-1. 보안관제센터





5. 보안관제 실무

5-1. 보안관제센터



5. 보안관제 실무

5-1. 보안관제센터

사이버보안관제센터 상시 출입자명단

2022 . 1 . 1. 기준

관련근거 (지정일자)	소속	사진	직급	성명	출입목적	비고
'22. 1. 1	OOOO		센터장	김으신	정보보안 담당관	
			부장	강감찬	관리자 겸(겸)	
			차장	홍길		
			과		서보안업무	
			국		사이버보안업무	
				최 영	사이버보안업무	
'22. 1. 1	SK쉴더스		수석	이행복	보안관제 PM	
			수석	이경재	침해대응	
			책임	정우성	취약점점검	
			선임	송강호	보안관제	

기관 및 관제사업 투입인력

출 입 자 명 부

년 · 월일	시 간	용 무	출입자		입회자(피면회자)			관 리 책임자 결재란
			주소	성명	직급	성명	인	
	人 出							
	人 出							
	人 出							
	人 出							
	人 出							
	人 出							
	人 出							
	人 出							
	人 出							
	人 出							
	人 出							
	人 出							
	人 出							
	人 出							

관제센터 외부 출입자

5-1. 보안관제센터

사업 투입 및 종료 시 서약서 작성

보 안 각 서

본인은 년 월 일 귀 OO 와 계약 체결한 용역에 참여하는 자로서, 제반 보안규정 및 준수사항을 철저히 준수하겠으며 보안사항을 누설하거나 용역 참여과정에서 본인으로 인한 보안사고가 발생하였을 때에는 관계법규에 따른 어떠한 처벌도 감수할 것을 각서로 제출합니다.

- 준 수 사 항 -

1. 용역과업수행과정에서 지득한 비밀을 누설, 유출하지 않는다.
2. 각종자료(유인물, 간행물, 설계도, 문서포함)의 주요 정보사항을 대외로 유출하지 않는다.
3. 성과물중 전부 또는 일부를 승인된 목적 이외에 사용하기 위하여 복제, 복사하거나 보유하지 않는다.

년 월 일

상 호 :

생 년 월 일 :

성 명 : (서명)

OOOOO장

용역사업 퇴직자 보안서약서

용역 사업명 :
성 명 :
생 년 월 일 :
주 소 :

상기 본인은 OOOOOOO(기관명))에서 퇴직 후기관 의 영업비밀을 제 3자에게 공개하거나 누설하지 아니하며, 제3자를 위하여 절대 사용하지 않을 것이며, 다음 사항을 반드시 준수하겠습니다.

1. 퇴직 시기관 에서 제공 받은 모든기관 소유 비밀 및 정보자산을 즉시기관 에 반납한다.

2. 퇴직 후에도기관 의 비밀 및 정보자산을 개인적으로 보유하거나 저장, 활용하지 않음을 서약한다.

3. 재직기간 중 취득한기관 의 지적 자산 및 비밀에 해당하는 사항을 퇴직 후에도기관 의 업무 인수, 인계와 관련 없는 어떠한 공사 내의 기타 외부 인력에게도 누설하지 아니한다.
   - 사업계획, 연구개발계획에 관한 비밀사항
   - 제품 생산방법 등 기술비밀에 관한 사항
   - 고객명부 등 영업비밀에 관한 사항
   - 타사 제휴 현황에 관한 비밀사항
   - 협력업체 등 관련회사와의 사업정보에 관한 사항
   - 기타 기관 에서 영업비밀로 취급, 관리하는 사항

4.기관 의 비밀 보호를 위한 노력에 적극 협조할 뿐 아니라, 그에 따른 법적, 도덕적 의무를 성실히 이행한다.

본인은 위의 사항을 숙지하여 이를 성실히 준수 할 것이며, 만일 이를 위반하였을 경우 관련 법령 및 규정에 따라 민,형사상의 책임을 지며, 손해액을 지체없이 변상할 것을 서약합니다.

20 년 월 일

서약자 (인)

5-1. 보안관제센터

신원조회(정부부처 및 공공기관)

[별지 제21호서식]

신 원 진 술 서(약식)

(앞쪽)

성 명		한 자		주민등록번호	
등록기준지					【 사 진 】 사진파일 가능 (3cm×4cm)·(3.5cm×4.5cm)
주 소					
실거주지					
직 장	직장명 : 소재지 :			연락처	직장전화 : 휴 대 폰 : E-mail :

	학 교 명	기 간	전 공 학 과	학 위	소 재 지
학력		. . ~ . .			
		. . ~ . .			
		. . ~ . .			

	기관·업체 및 정당·사회단체명	기 간	직 책(직급)	상 벌 관 계(일자)
경력		. . ~ . .		
		. . ~ . .		
		. . ~ . .		

	거주 국가	기 간	거주 목적	동반
해외 거주 사실		. . ~ . .		
		. . ~ . .		

	군 별	기 간	병 과	최종 계급
병역		. . ~ . .		

	관 계	성 명	생년월일	관 계	생년월일
배우자 부모 자녀	배우자			子女	
	父			子女	
	母			子女	

위 내용은 사실과 다름이 없으며, 기재사항을 누락하거나 허위로 기재할 경우 관계 법령에 따라 불이익을 받을 수 있다는 사실을 고지 받았음을 확인합니다.

년 월 일

작 성 자 성명 인(서명 또는 날인)

210mm×297mm [백상지(80/㎡) 또는 중질지(80/㎡)]

(뒤쪽)

개인정보 수집 및 이용 동의서

국가정보원, 국방부 및 경찰청은 「보안업무규정」 제46조(고유식별정보의 처리) 및 「개인정보 보호법」 제15조(개인정보의 수집·이용), 제23조(민감정보의 처리 제한), 제24조(고유식별정보의 처리 제한) 및 제24조의2(주민등록번호 처리의 제한)에 따라 신원조사 업무의 수행에 필요한 개인정보, 민감정보 및 고유식별정보를 수집·이용합니다.

■ 개인정보 수집·이용 내역

항목	성명(한자 포함), 사진, 주민등록번호, 등록기준지, 주소, 실거주지, 직장(직장명, 소재지 포함), 연락처(직장전화, 휴대폰, E-mail 포함), 학력(학교명 등 포함), 경력(기관 또는 업체명 등 포함), 거주국사실(거주목적, 동반가족 등 포함), 병역사항, 가족관계(배우자, 부모, 자녀 포함)
수집·이용 목적	사 및 사실관계의 확인
보유·이용 기간	

※ 을 위해 필요한 최소한의 필수 정보에 해당하며 그 내용에 관하여 **개인정보 수집·** 습니다. 그러나 **동의를 거부하는 경우에는** 「보안업무규정」에 따른 신원조사를 ·비밀취급인가 등에 제한을 받을 수 있음을 알려 드립니다.

소를 수집·이용하는데 동의하십니까? 동의함 [ ] 동의하지 않음 [ ]

내 안내

항목	정당·사회단체 경력
수집·이용 목적	신원조사 및 사실관계의 확인
보유·이용 기간	2년

※ 위 내용은 신원조사 업무 수행을 위해 필요한 최소한의 필수 정보에 해당하며 그 내용에 관하여 **민감정보 처리 동의를 거부할 권리**가 있습니다. 그러나 **동의를 거부하는 경우에는** 「보안업무규정」에 따른 신원조사를 실시할 수 없어 **임용(채용)·비밀취급인가 등에 제한**을 받을 수 있음을 알려 드립니다.

☞ 위와 같이 민감정보를 처리하는데 동의하십니까? 동의함 [ ] 동의하지 않음 [ ]

■ 고유식별정보 처리 안내

항목	주민등록번호
수집·이용 목적	신원조사 및 사실관계의 확인
보유·이용 기간	2년

※ 「개인정보 보호법」 제24조의2제1항제1호 및 「보안업무규정」 제46조에 따라 별도의 동의는 필요하지 않습니다.

☞ 위와 같이 고유식별정보를 처리하는 것을 확인했습니다. [ ]

「개인정보 보호법」에 따라 개인정보처리자가 준수해야 할 개인정보보호 규정을 준수하고 있으며, 관련 법령에 따라 대상자의 권익을 보호하고 허가된 이용 목적 외에는 사용하지 않겠습니다.

20 년 월 일

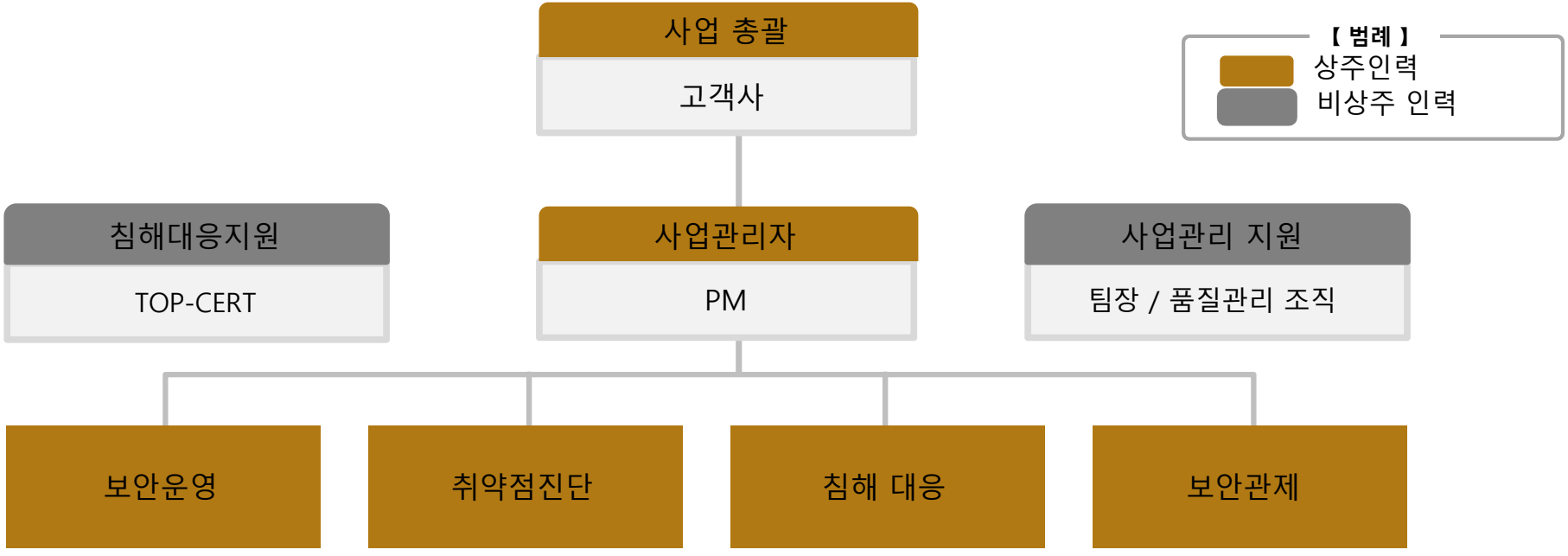
신청인(대리인): (서명 또는 인)

(필요시) 법정대리인: (서명 또는 인) 연락처:

210mm×297mm [백상지(80/㎡) 또는 중질지(80/㎡)]

경찰청 민원서식 다운로드 가능

5-2. 보안관제 사업조직

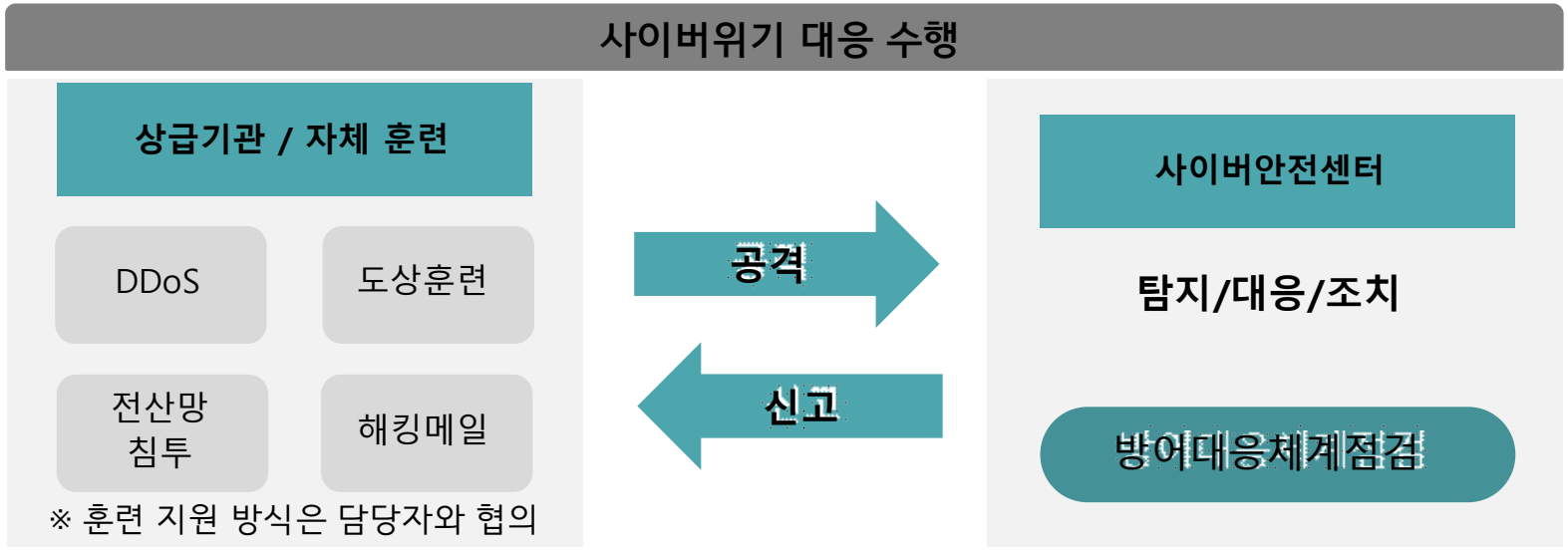


보안관제 : 2인 1조 / 4조 2교대(주야비비)

5-3. 보안관제 사업수행 업무

	수행업무
보안관제	▪ 24시간 365일 실시간 사이버테러 공격 징후 탐지 및 차단 ▪ 보안 이벤트 모니터링 및 분석 ▪ 사이버공격 탐지 룰 개발, 이력관리 및 최적화 ▪ 사이버위기 상황별 예·경보 전파 및 대응·조치 ▪ 유관기관 침해대응 협조 및 공조체계 유지
취약점 점검 및 모의해킹	▪ 주요정보시스템 취약점점검 수행 및 이행점검 ▪ 웹사이트에 대한 주기적 모의해킹 수행 및 조치방안 제시 ▪ 최신 보안이슈사항에 대한 전파 및 취약점 제거방안 제시
정보보호 시스템 운영	▪ 정보보호시스템 장애처리, 정기점검, 패치 등 작업수행 ▪ 기관 보유 정보보호시스템 운영
모의훈련 수행	▪ 자체 모의해킹메일 대응훈련, DDoS 모의훈련 등 지원 ▪ 각 부처, 국정원 등 정부기관 사이버 위기대응 훈련 지원
정보보안 관리	▪ 보유 정보보호시스템 자산 현행화 및 매뉴얼 최신화 ▪ 보안성 검토 및 보안적합성 기술 검토 지원 ▪ 정보보안 전문 교육 및 인식 제고 활동
사업 관리	▪ 보안관리, 서비스수준관리, 위험관리 및 진도관리 ▪ 보고 및 이슈관리, 기타 지원업무

5-4. 훈련지원



사전준비	• 훈련 수행 계획(DDoS, 도상훈련, 전산망침투, 해킹메일) - 훈련 대응 프로세스 작성 및 고객사 제공 • 훈련 일정 및 대상 기관 선정, 훈련 유형별 시나리오 준비 지원
자체 테스트	• 자체 검증 - 훈련 유형별 장애 요소 파악(FW 차단 유무 확인) - 훈련용 시스템의 기능별 테스트 수행
수행결과	• 대응 신속도 : 역할별 대응 프로세스 준수 유무 점검 • 결과 보고서 작성 및 증적자료 제출 • 전년도 훈련결과 분석 후 취약항목 도출 및 차년도 훈련 대비

5-5. 정보공유

정보수집

취약점 권고문

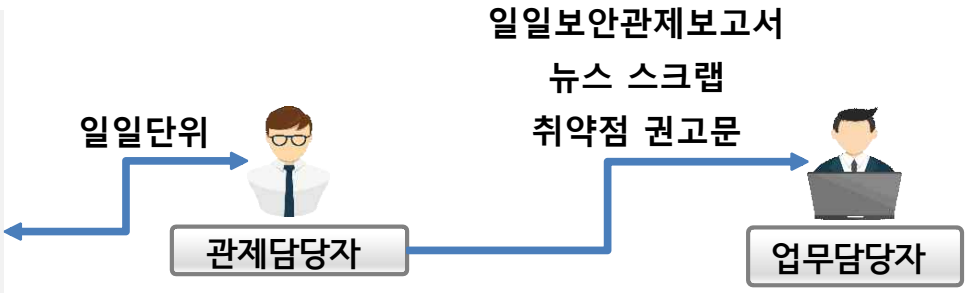


국정원, 금보원
KISA KrCert, 벤더사

보안뉴스



데일리시큐리티,
보안뉴스 등 언론매체



정보배포



국가정보원/
금융정보원

탐지이벤트, 위협정보, 블랙IP/URL



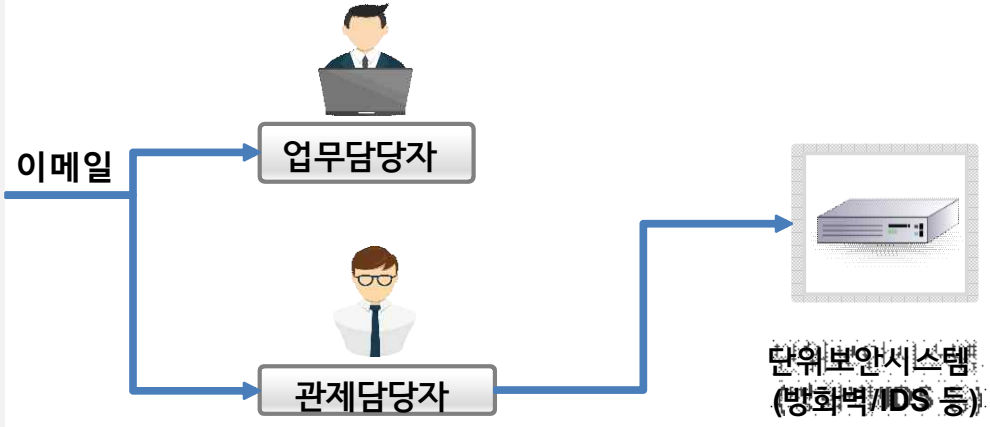
상급기관

탐지이벤트, 위협정보, 블랙IP/URL



관제업체 본사

위협정보, 블랙IP/URL



5-5. 정보공유

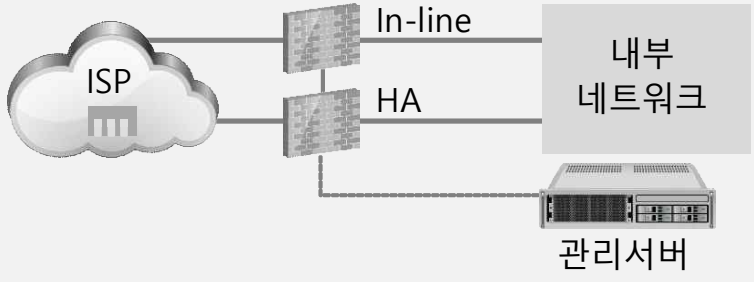
☞ **정보배포(블랙 IP)**

탐지시간	공격유형	심각도	공격종류	공격 P	공격 국가	URL
2022-10-19 00:48:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	3.	US	-
2022-10-19 00:48:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	1	US	-
2022-10-19 00:48:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	34	US	-
2022-10-19 00:48:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	134	US	-
2022-10-19 00:49:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	4	US	-
2022-10-19 00:49:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	18	US	-
2022-10-19 00:49:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	1	US	-
2022-10-19 00:49:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	3	US	-
2022-10-19 00:49:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	18	US	-
2022-10-19 00:50:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	18	US	-
2022-10-19 00:50:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	18	US	-
2022-10-19 00:50:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	3	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	1	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	16	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	18	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	18	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	1	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	16	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	13	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	35	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	3	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	54	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	3.	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	18	US	-
2022-10-19 00:54:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	1	US	-
2022-10-19 00:55:00.0	Hacking	WARNING	Web 취약점 공격시도 탐지	9	PT	-
2022-10-19 00:55:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	3	US	-
2022-10-19 00:56:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	3	US	-
2022-10-19 00:56:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	3	US	-
2022-10-19 00:56:00.0	Hacking	MINOR	HTTP 비허용 URI 확장자 접근 시도 탐지	3	US	-
2022-10-19 00:59:00.0	Hacking	MINOR	Path Traversal 공격시도 탐지	1	CN	-

5-6. 보안관제시스템 성능관리

보안관제시스템 구성 / 특징

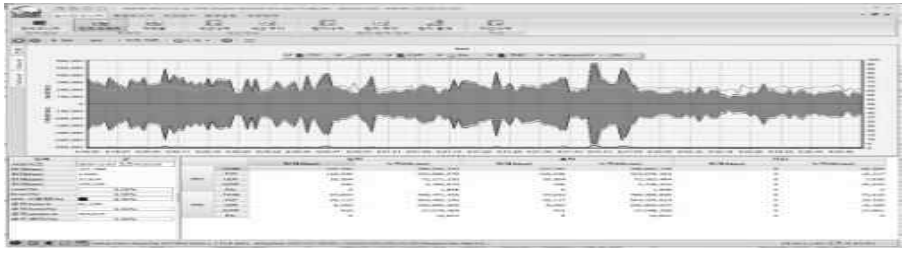
구성



특징

- 주요 네트워크 영역에 인라인으로 이중화 구성
- Active-Active, Active-Standby 방식으로 구성
- 관리 대상이 많은 경우 별도 관리서버 운영

H/W	• CPU, Memory, Disk, HA, NIC, Power
S/W	• 데몬, Bypass, NTP, 파일 무결성, 정책
Network	• In/Out 트래픽, 최대 세션, 프로토콜
기타	• 침입탐지 이벤트량, 변동율, BackUp



주기	내용
실시간/일일	• ESM Agent연동을 통한 시스템 상태 정보 확인 (경보 이벤트, SMS) • 점검내용 : CPU, Memory, Disk, Power, 데몬 • 최대 허용 세션 확인, Disk 가용 상태 확인
월간	• 트래픽 및 이벤트 변동 추이, NTP 동기화, 백업현황 • 정책 점검(기간만료 정책, 미참조 정책)

5-6. 보안관제시스템 성능관리

성능관리 포인트

방화벽

- 최대 허용 세션 임계치 초과 시 장애 발생
- Disk 가용 상태 비확보 시 장애 발생(로그저장기간 미관리)
- 이중화 구성(HA) 장애 발생 시 전체 네트워크 차단
- Active-Standby 구성 시 Master 전환 오류

IDS/IPS

- 다량의 비정상 이벤트 발생 시 데몬 Hang-up 발생
- 정책 분배 적용 시 대상 장비별 적용 여부 확인
- In-line 회선 장애 시 Bypass모드로 전환

WAF

- DB트랜젝션 수치 증가 시 이벤트 유실 및 데몬 장애 발생
- Disk / Power fault 발생 시 Bypass 자동 전환
- 과다로그 유입시 NIC 버퍼 처리 초과로 이벤트 유실 및 데몬 속도 저하
- 다수의 대용량 첨부파일 분석 시 이벤트 유실 및 데몬 속도 저하

5-7. 산출물

구분	보고명	보고 내용	제출 기한
정기 보고	일일 보안 관제보고서	• 일일 사이버위협 모니터링 탐지 및 대응내역 • 정보시스템 운영내역/보안위협정보 제공내역	일 1회
	월간/분기 실적보고서	• 보안관제 및 운영 월간/분기실적 • 월간 사이버위협 동향 및 특이사항	매월, 분기
	연간 보고서	• 연간 보안관제 운영 및 실적, 고도화 방안 제시	년1회
수시 보고	사이버침해 분석・대응 보고서	• 침해사고 분석・대응 보고서 • 정책설정(변경)신청서 • 정책설정(변경)이력관리대장 • 상황전파문	발생 시
	매뉴얼 지침 재・개정	• 보안관제운영매뉴얼/사이버안전센터 운영매뉴얼 • 업무처리 현행화	상시
	기타보고서	• 월별근무편성표 • 자료관리대장, 통계 및 각종 보고서 작성 • 월별휴가계획서,비상대응방안,교육계획서(수행인력) • 매체 및 장비 반출입 대장 • 인원 및 문서 장비 등 보안관리계획서 • 보안교육 계획서 및 결과 보고서(수행인력) • 보안서약서(퇴사자·기타 사유로 인한 인력교체시)	수행시

7-7. 산출물

일일보안관제보고서

☞ 일일보안관제보고서 작성 시간 기준 : 매일 00:00 ~ 23:59 또는 금일 06:00 ~ 명일 05:59

※ 각 기관마다 작성시간 기준은 상이

☞ 일일보안관제보고서 포함내용(각 기관마다 보고서 내용은 상이)

- 각 보안장비에서 발생한 침해위협 발생 현황(정/오탐 모두 포함)
- 침해위협 발생 기반으로 티켓팅 현황

구분	계		웹해킹		비인가접근		악성코드		서비스거부		스캐닝		기타	
	탐지	대응	탐지	대응	탐지	대응	탐지	대응	탐지	대응	탐지	대응	탐지	대응
자체	5,544	5	423	0	1,515	5	0	0	3,525	0	81	0	0	0
OOO	25,407	0	8	0	46	0	7,257	0	1	0	0	0	18,095	0
OOO	0	0	0	0	0	0	0	0	0	0	0	0	0	0
총계	30,951	5	431	0	1,561	5	7,257	0	3,526	0	81	0	18,095	0

- 티켓팅 상세내용 : 티켓팅 순번, 침해위협명, SIP, DIP, 침해위협 분석내용

5-7. 산출물

일일보안관제보고서

☞ 일일보안관제보고서 포함내용(각 기관마다 보고서 내용은 상이)

- 시스템 운영 현황 : ESM 또는 SIEM, 각 보안장비 이상유무 현황
- 스팸 / 피싱 메일 수신 현황
- 각 보안장비 탐지정책 추가 / 변경 현황
- 침해사고 예방활동 : 보안뉴스, 취약점 권고문

보안 뉴스

스크랩 일자	2022-00-00	뉴스 일자	2022-07-26
URL	https://www.hankookilbo.com/News/Read/A2022072615450001882		
제목	[단독] 국내 대형 제약사도 '랜섬웨어' 공격당했다		

내 용



"영업 시원에게 1초가 아까운데, 주요한 진산에 입력할 수 없어 발인 손실이 크고 있습니다."
(국내 제약사 A사 관계자)

18일 해경 공거으로 전국 30여 개 시군 공무서 시스템이 마비된 데 이어, 25일 국내 대형 제약사 중 한 곳이 랜섬웨어 공격을 당한 것으로 확인됐다.

26일 한국일보 취재 결과, 국내 제약사 A사는 하루 전인 25일 오후 랜섬웨어 공격을 받아 전 직원이 업무용 컴퓨터를 사용하지 못하고 있다. 이 회사 전산팀은 업무 컴퓨터가 랜섬웨어 공격을 당한 것으로 파악하고, 더 이상 피해가 번지지 않도록 대응 체을 마련하기 위해 만전을 쓰고 있다. 다만 피해 발생 후 24시간째 해결하지 못하고 있는 실정이다.

A사 관계자는 "회대한 컴퓨터를 켜지 않고 오프라인으로 작업하고 승인이 필요한 업무는 구두

보안 권고문

스크랩 일자	2022-07-25	출처	KISA 보안뉴스
URL	https://www.krcert.or.kr/data/secNoticeView.do?bulletin_writing_sequence=66828		
제목	구글 Chrome 브라우저 보안 업데이트 권고		

□ 개요
○ 구글은는 자사 제품에서 발생하는 취약점을 해결한 보안 업데이트 발표 [1]
○ 공격자는 해당 취약점을 악용하여 피해를 발생시킬 수 있으므로, 해당 제품을 사용하는 이용자들은 최신 버전으로 업데이트 권고

□ 설명
○ 크롬 브라우저의 레스트 부트에서 발생하는 Use-after-free 취약점 (CVE-2022-2477)
○ 크롬 브라우저의 PDF에서 발생하는 Use-after-free 취약점 (CVE-2022-2478)
○ 크롬 브라우저에서 파일에 대한 신뢰할 수 없는 입력이 불충분한 검증으로 발생하는 취약점 (CVE-2022-2479)
○ 크롬 브라우저의 Service Worker API에서 발생하는 Use-after-free 취약점 (CVE-2022-2480)
○ 크롬 브라우저의 Views에서 발생하는 Use-after-free 취약점 (CVE-2022-2481)
○ 크롬 브라우저의 Cast UI와 롬바에서 발생하는 Use-after-free 취약점 (CVE-2022-2163)

□ 영향을 받는 버전 및 해결 버전

제품명	영향받는 버전	해결 버전
Chrome	103.0.5060.134 이전 버전	103.0.5060.134

※ 하단의 참고 사이트를 확인하여 업데이트 확인 및 수행 [2]

□ 기타 문의사항
○ 한국인터넷진흥원 사이버민원센터: 국번없이 118

[참고 사이트]
[1] https://chromereleases.googleblog.com/2022/07/stable-channel-update-for-desktop_19.html
[2] https://support.google.com/chrome/answer/95414?co=GENIE.Platform%3DDesktop&hl=ko

□ 작성 : 침해시고분석단 취약점분석팀

기타사항	-

SK 쉴더스

5-7. 산출물

침해사고 분석 보고서

☞ 침해사고 분석보고서는 각 기관에서 운영하는 서버 및 보안장비 등에서 발생한 보안사고에 대해 침해사고 대응팀이 출동하여 사고 관련 자료를 수집하고 분석하여 작성하는 보고서

- 작성 주기 : 침해사고 발생시 또는 침해사고 분석 요청 시

☞ 침해사고 분석 보고서 포함내용(각 기관마다 보고서 내용은 상이)

- 개요 : 침해사고 및 분석에 대한 간단한 설명
- 피해 서버 또는 장비 정보
- 공격자 정보
- 침해사고 일시 및 경과(Time Table)
- 공격내용
- 피해내용
- 향 후 대응방안

5-8. 비정상 트래픽 티켓팅

티켓팅 : 보안관제시스템에 미리 적용한 정책에 의해 비정상적 트래픽 탐지시 자동으로 경보가 발생하면 관제인원이 시스템을 통해 접수하여 종결 처리하는 일련의 과정

☞ **티켓팅 기준 : 각 사이트마다 상이함.**

절차	DDoS	IPS/WAF	APT(DDI)
1	30분에 1번씩 DDOS 일일 탐지로그 검색	ESM 경보 발생 시 보안장비 직접 RawData 로그 검색	ESM 경보 발생시 보안장비 직접 로그검색 DDI - Detection - All Detections - ESM경보의 IP 조회진행 웹이나 분석 리포트 내용을 토대로 분석
2	공격코드 DNS ETC Type Qurey Flooding(484), UDP Source_IP Flooding(395) 등 대상서버 주DNS([redacted])·보조DNS([redacted])로 향하는 트래픽을 보고 시도횟수 1000건 이상 및 트래픽 800K 이상 탐지시 티켓팅 단, 공격의심IP 검색조건 OR로 양방향 통신인지 확인하여 단방향(인바운드)으로 유입되는 경우에만 티켓팅 참고IP(21년 8월 11일 50.87.227.240), (21년 8월12일 61.68.158.91)	정책에 의해 자동차단 된 경우라도 아래 조건을 모두 충족하면 티켓팅 1) 시도횟수 : 30회 이상 2) 평판분석 사이트 IP조회(VirusTotal/dbIP등) : 유해IP 확인 **단, 30회 미만이라도 서버환경에 영향력 있는 웹해킹 및 기타 공격은 티켓팅** **(취약점 공격에 맞는 서버사용 등/예 : JAVA기반 취약점 공격 - JSP/서블릿환경 서버 매칭시)**	1) 첨부파일 의심시 샘플 다운로드 받아 내부 DDAN 등에서 동적분석 진행 또는 2) 외부 평판분석 사이트(동적분석)에서 SHA-1, MD5 등 파일HASH값으로 유해성 조회 티켓팅 진행 유해성이 확인되면 C&C 서버 차단 또는 외부연결시도 IP 차단 등
3	모니터 - 전체 트래픽'에서도 현재 bps 확인하여 1G를 넘는 트래픽이 지속적으로 들어오거나 그래프 변동폭이 높게 변화하는지 관찰 필요 평상시 평균 bps는 100M ~ 500M 사이 값으로 유지되고 있음	정책에 의해 모두 탐지모드(통과)인 경우, 정탐이면 티켓팅 1) DPI 보안장비 상세로그 조회로 서버 응답결과 분석할 것(티켓팅 접수에 캡쳐 첨부 등)	※ 유의점 외부인터넷 평판분석 사이트(동적분석)에서 첨부파일을 업로드하여 분석하고 싶은 경우 : 내부직원이 작성한 문서로 의심가는 경우는 업로드 분석하지 말것, 개인정보 유출문제 발생할 수도 있음 : SHA-1, MD5 등 해시값을 기반으로 한 검색을 최우선으로 하고, 내부적인 문서가 아닌 경우가 확실하다면 관찰을 : 동적분석사이트 참고(hybrid-analysis.com 또는 any.run)
4	모니터 - cps 트래픽(TCP)'에서도 전체 cps, 객체 트래픽 부분(임계치:30) 모니터링하여 그래프 변동폭이 높게 변화하는지 관찰 필요, 정상적인 통신이라면 초당 하나의 IP에서 세션연결시도 30을 넘는 경우는 없음 객체 트래픽 부분(임계치:30)을 넘는 경우 원인파악 필요, 내부적인 작업 요인인지 외부에서의 접근시도인지 등 파악	**※ 신규 Penta WAF Request Header Filtering 정책 관련의 경우** 1) 평판분석 사이트 IP 조회(VirusTotal/dbIP등) : 2곳 이상에서 유해IP로 확인(예외적으로 1곳인 경우라도 연관정보로 3개월 이내 악성정보가 있다면 유해하다고 판단내릴 것) 2) ESM 경보접수된 RawData 부분의 URI를 보면 단순 / 가 아닌 라우터 취약점(/HNAP/), GPON(/boaform/)도 섞여 있으므로 구별하여 대응 필요	
5		: PHP 기반으로 한 공격(PHP 취약점 페이지 접근시도, PHP 관리자 페이지 접근시도 등) : 공사와 관련없는 장비 취약점 공격(GPON 라우터, NetLink 라우터 등) 예를 들어 목적지가 DMZ대역의 알려진 서버인 경우에는 Cisco 네트워크 장비를 거쳐온다고 생각하시면 되므로 티켓팅 하지 않되, 유해(30회이상 or 탐지통과)할 경우 IP차단만 진행해주시면 됩니다. : 30회 이상 공격 및 평판분석 유해IP로 티켓팅이 필요한 경우, 이제부터 ESM 티켓팅 접수는 하지 않아도 됩니다. 대신에 외부방화벽에 IP차단조치 '20210826 사이버보안상황실 유해IP차단(ETC)' 후 티켓팅리스트.xlsx의 'PHP공격 및 관련무장비'시트에 내용정리해주면 되고, 야간근무자는 일보 '유해IP 차단' 내역으로 기입하면 됩니다. 아침 8시마다 보내는 방화벽차단내역.hwp은 'PHP공격 및 관련무장비'+'차단TTL대장' 2곳 모두 참고해서 작성하며, 차단3개월 기간만료 됐으면 '해제'합니다. : 교대근무시 '방화벽 차단IP 수'와 'ESM 티켓팅 수'도 서로 일치하는지 꼭 크로스체크 바랍니다.	

5-8. 비정상 트래픽 티켓팅

티켓팅 처리과정

☞ 단위보안장비(Anti-DDoS, DDX, IPS, WAF, APT 등)에서 통합보안관제시스템으로 수집되는 로그들에 대해서 공격지 IP, 목적지 IP 경보내용을 확인 후 해당 보안장비에 접속, 정/오탐을 판단하여 실제 공격으로 확인될 경우 외부 방화벽에 유해 IP 차단

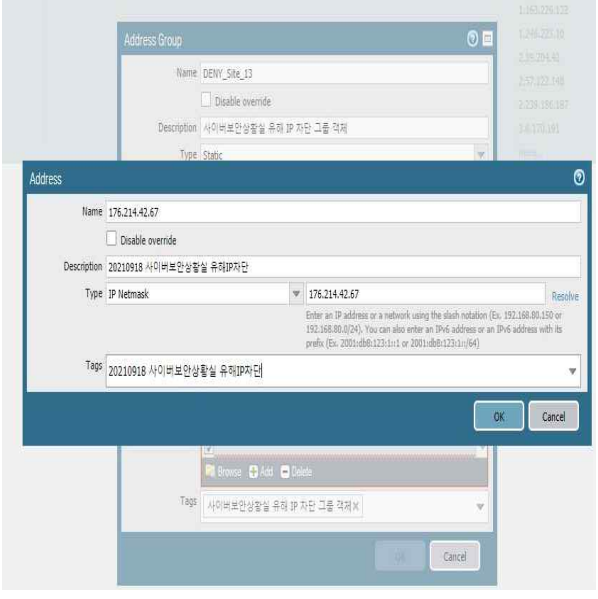
단위보안장비



로그 수집(경보 발생)



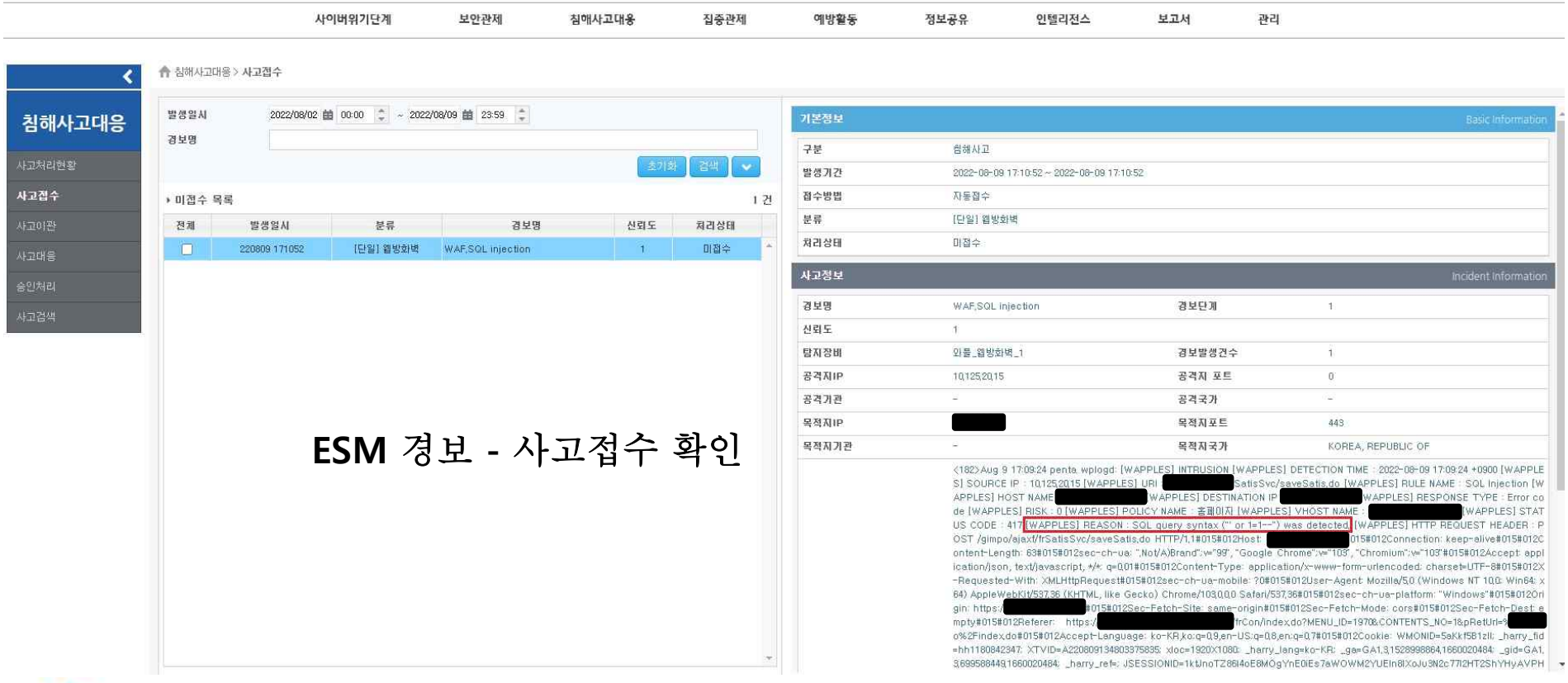
F/W 차단



5-8. 비정상 트래픽 티켓팅

티켓팅 처리상세(경보발생)

☞ ESM으로 수집되는 로그(경보 발생)에 대해서 공격지 IP/목적지 IP 내용을 파악 후, 해당 단위 보안 장비에 접속하여 재확인

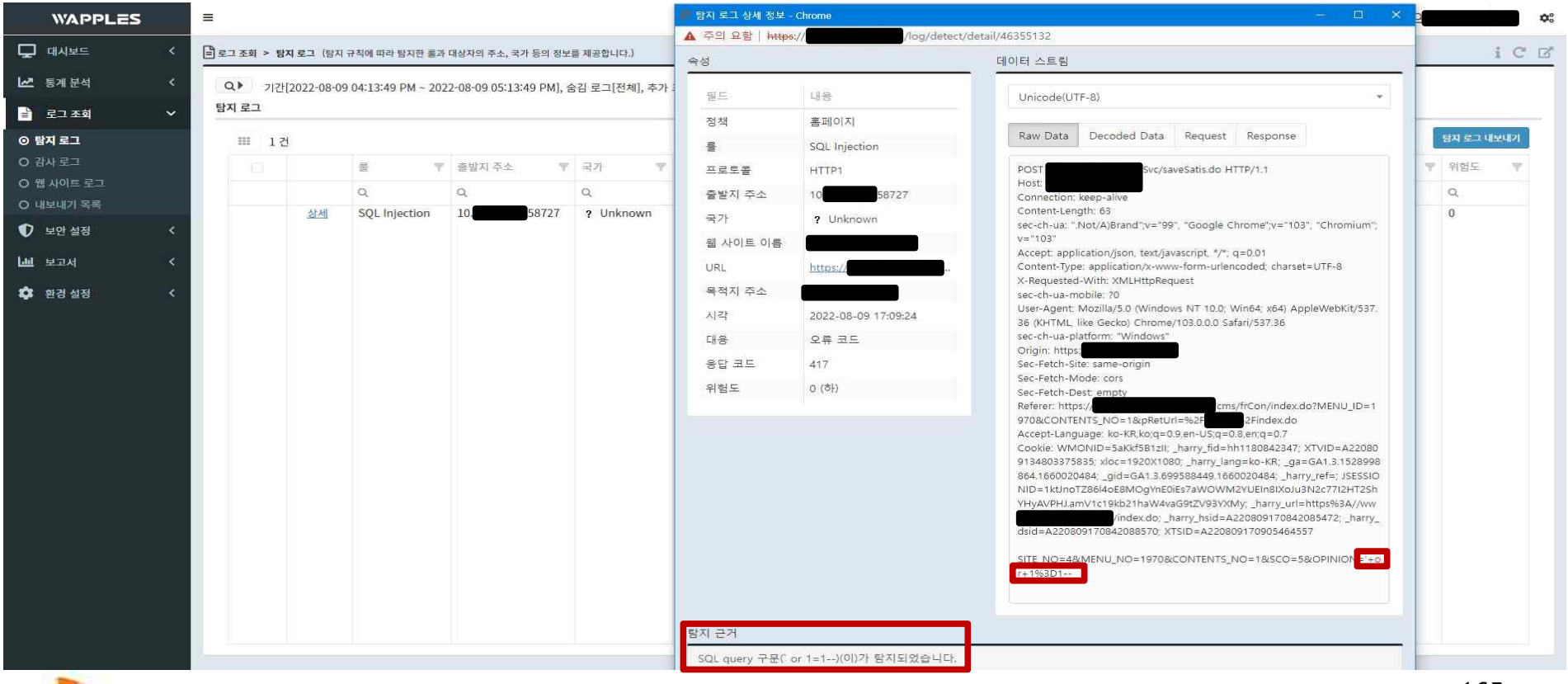


ESM 경보 - 사고접수 확인

5-8. 비정상 트래픽 티켓팅

티켓팅 처리상세(Raw Data 분석)

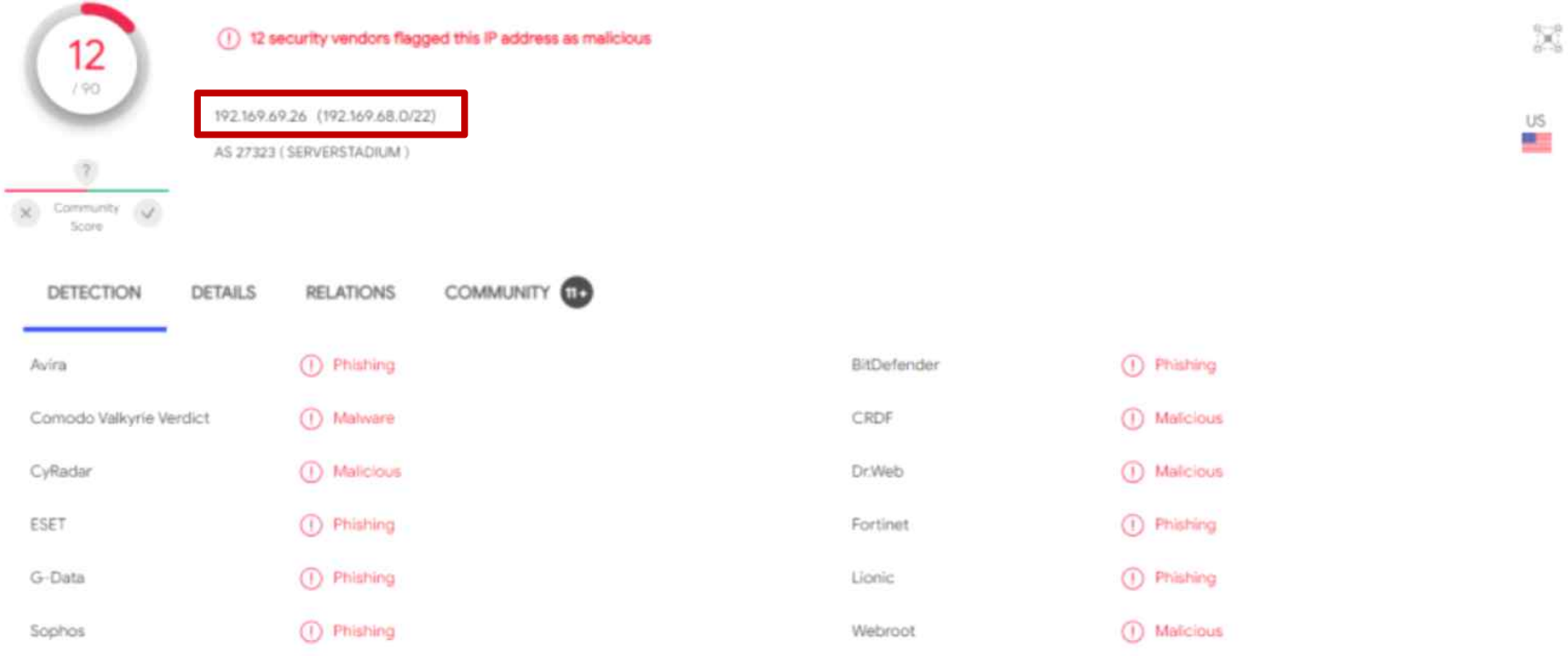
☞ 패킷 내 Rawdata를 기반으로 정/오탐을 판단하여 실제 공격으로 확인될 시 외부 방화벽(FW)에 공격지 IP 차단



5-8. 비정상 트래픽 티켓팅

티켓팅 처리상세(공격자 IP 평판 검색)

☞ **Rawdata 분석 이외에도 외부 평판기반 조회 사이트(VirusTotal, DB-IP 등)를 참고하여 유해 IP 여부를 활용**



5-8. 비정상 트래픽 티켓팅

티켓팅 처리상세(유해 트래픽 분류)

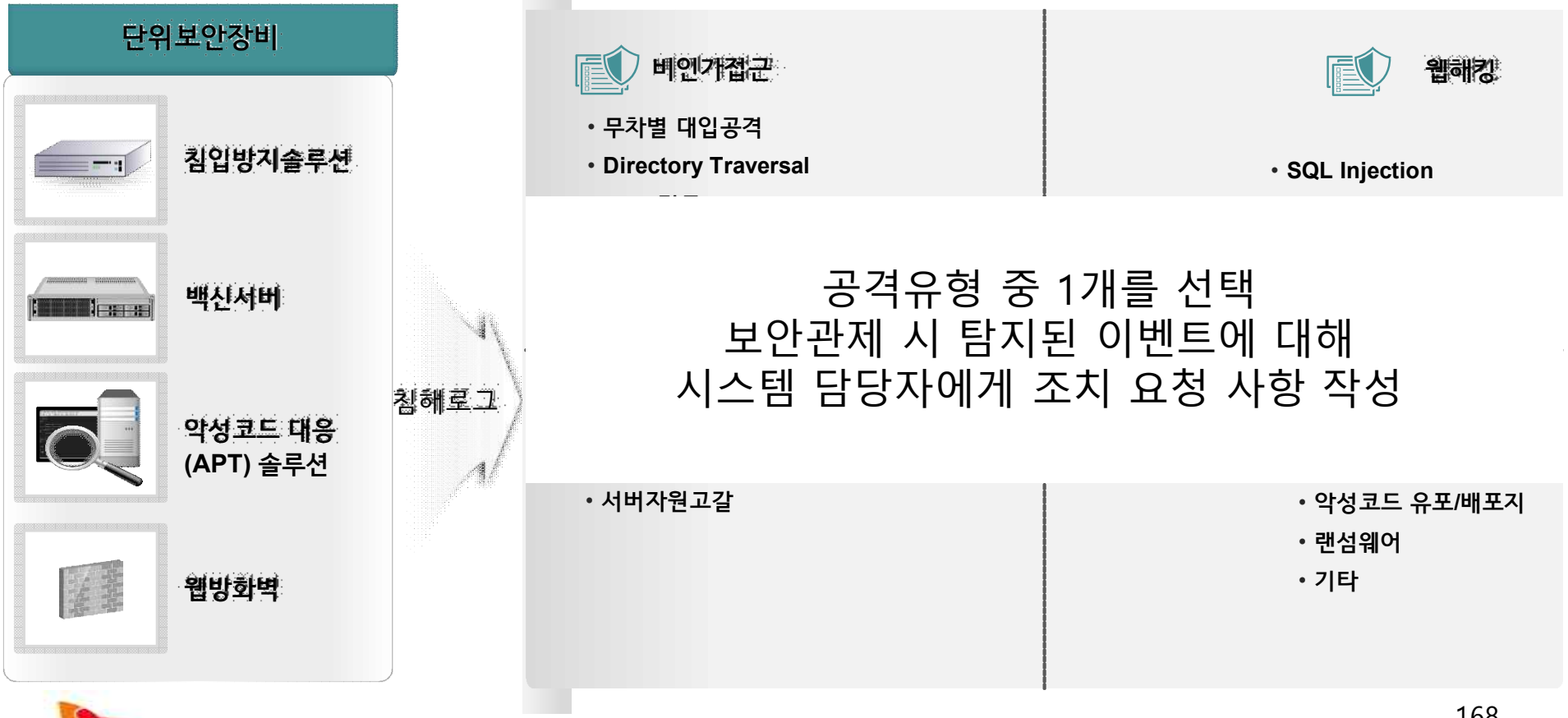
☞ 탐지된 유해 트래픽에 대해 티켓팅 시 공격 유형을 분류하여 이력관리를 함.



5-8. 비정상 트래픽 티켓팅

티켓팅 처리상세(유해 트래픽 분류)

☞ **탐지된 유해 트래픽에 대해 티켓팅 시 공격 유형을 분류하여 이력관리를 함.**



5-8. 비정상 트래픽 티켓팅

PHP 관리자페이지 접근시도

- ☞ **phpMyadmin은 PHP로 개발한 MySQL 관리용 웹 인터페이스 데이터베이스에 대한 테이블, 열, 권한, 쿼리 작성 등에 대한 기능을 제공하는 무료 소프트웨어임.**
- ☞ **해커가 웹 서버 프로세스에 악의적인 php코드를 삽입하거나 관리자 권한을 획득하여 시스템을 손상 시킬 수 있음.**

RAWDATA

```
GET /phpmyadmin/index.php HTTP/1.1
Host: [redacted]
User-Agent: Mozilla/5.0 (Linux; Android 10; LIO-AN00 Build/HUAWEILIO-AN00; wv) AppleWebKit/537.36
(KHTML, like Gecko) Version/4.0 Chrome/78.0.3904.62 XWEB/2692 MMWEBSDK/200901 Mobile Safari/537.36
Accept-Encoding: gzip
Connection: close
```

공격문구

공격대응

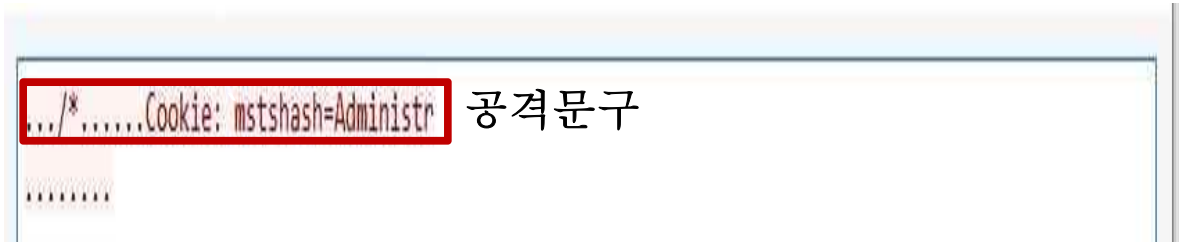
phpMyAdmin 페이지에 허용할 IP 등록
phpMyAdmin의 이름을 유추하기 힘들게 설정
phpMyAdmin 설치 후 불필요한 설정 파일 제거
웹 서버에서 Method(PUT, DELETE, HEAD, TRACE 등) 제한 설정

5-8. 비정상 트래픽 티켓팅

RDP (Remote Desktop Protocol) 접근시도

- ☞ **윈도우 원격접속 프로그램인 RDP서비스를 취약한 패스워드와 기본포트(3389)를 사용할 경우 공격자의 로그인 무차별 대입 공격(Brute Force attack)에 의해 접근이 이루어질 수 있는 위험성이 존재함.**
- ☞ **취약한 RDP가 존재한다면 백도어나 랜섬웨어 공격의 루트가 될 수 있음**

RAWDATA



공격대응

기업차원에서 보안상 아예 사용하지 않는 것이 좋음. RDP접근요청 시도시 IDS, IPS에서 탐지 및 차단할 수 있음.
필요에 따라 사용해야 한다면 접근이 허용된 계정 및 데스크톱을 두어야 하면 강력한 비밀번호 설정 등을 해야함.

5-8. 비정상 트래픽 티켓팅

디렉토리 비정상접근(Directory Traversal)

- ☞ **FortiOS SSL VPN Directory Traversal Vulnerability(CVE-2018-13379) /remote/fgt_lang? 페이지의 lang 매개변수의 필터링을 제대로 수행하지 못해 발생하는 취약점**
- ☞ **공격이 성공하면 해당 장비의 IP, Password를 알아내 장비에 접근 가능함.**

RAWDATA



공격대응

화이트리스트 방식으로 접근가능한 파일을 지정하는 것이 좋지만 서비스상 불가한 경우 블랙리스트 기반으로 문자열(./) 패턴을 차단하는 입력값 검증이 필요함.

공격을 우회하는 방식도 존재하므로 URL인코딩된 경우도 대비 해야함.

SK 쉴더스

5-8. 비정상 트래픽 티켓팅

SQL INJECTION

☞ 웹서버 영역의 DB로 전송되는 SQL쿼리문을 사용자가 임의로 조작할 수 있는 경우 발생

☞ 공격자는 이 취약점을 이용해 DB에 저장되어 있는 다른 사용자의 개인정보 등 허가되지 않은 정보에 접근하거나 데이터를 변조함

RAWDATA

```
GET /wwweng/cms/frCon/index.do?MENU_ID=50' OR 'x'='x HTTP/1.1
Host: [redacted]
Connection: keep-alive
Accept-Encoding: identity
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/80.0.3987.149 Safari/537.36
Cookie: WMONID=sny_NT1ljvR; JSESSIONID=yu4o58MYUnOWC1aE1mwL9wxv0qAFJvg1N1SozYSPwrP71QcQp2CZuYmsgMoCWkmy.amV1c19kb21haW4vaG9tZV93YXMy
```

공격문구

공격대응

입력된 값이 개발자가 의도한 값(유효값) 인지 검증함.
(union, select, drop, update, from, where, join, substr, user_tables 등)
저장된 프로시저를 사용하여 지정된 형식의 데이터가 아니면 Query가 실행되지 않게함.

5-8. 비정상 트래픽 티켓팅

실습 : 티켓팅(악성코드 감염 의심)에 따른 시스템(PC 또는 서버) 정보 요청

1. 시스템 정보 요청을 위해 포함되어야 할 내용들을 정리
2. 정리된 내용들을 수집하기 위한 Tool 작성(.bat 파일)
   - OS에서 지원하는 명령어 활용
   - 추가 필요시 활용 가능한 Tool download 사이트

     https://learn.microsoft.com/ko-kr/sysinternals/downloads/
3. PC 1대를 선정(가상 피해PC 또는 서버)
4. Tool을 이용하여 결과 파일 생성(txt 형식 파일)
5. 생성된 결과 파일의 Data를 분석하여 각 조별로 발표

5-8. 비정상 트래픽 티켓팅

실습 : 티켓팅에 따른 시스템(PC 또는 서버) 정보 요청

1. 시스템 정보 수집 시작/종료 일시 :
2. OS 및 네트워크, 윈도우 기본 정보 :
3. 사용자 정보 :
4. 공유 정보 :
5. 시스템 기본 보안설정 :
6. 실행중인 서비스 목록 :
7. 공유된 파일 실행 여부 :
8. 프로세스 정보 :
9. 네트워크 관련 정보 :
10. 파일 생성(C) / 수정(M) / 접근(A) 이력 :
11. 시작프로그램 목록 :

5-8. 비정상 트래픽 티켓팅

실습 : 티켓팅에 따른 시스템(PC 또는 서버) 정보 요청

☞ **MAC Time** 적용

구 분	만든시간 (C)	수정시간 (M)	접근시간 (A)
파일 생성	○	○	○
파일 이름변경	-	-	○
파일 내용수정	-	○	○
파일 복사	○	-	○
파일 이동	-	-	○
파일 다운로드	○	○	○
메신저에 의한 파일생성	○	○	○
파일 압축 해제	○	-	○

5-8. 비정상 트래픽 티켓팅

이벤트 분석 보고서(필요시 작성)

☞ 보안관제 시 탐지된 침해위협에 대해 중요도가 높거나 새로운 공격일 경우 보안관제 또는 침해대응 인력이 분석하여 작성하는 보고서

- 작성 주기 : 수시

☞ 이벤트 분석 보고서 포함내용(각 기관마다 보고서 내용은 상이)

- 개요 : 침해위협에 대한 간단한 설명
- 침해위협 탐지 일시 / 유형
- 피해 서버(장비) 정보 : OS, IP, 서버(장비) 용도 등
- 공격자 정보
- 침해위협 상세 분석
- 대응방안

5-8. 비정상 트래픽 티켓팅

침해대응 보고서

☞ 보안관제 시 탐지된 침해위협이 목표 서버(장비)에 성공여부를 파악하지 못하므로 해당 서버(장비) 담당자에게 이관하여 확인 및 조치를 요청하여 결과를 회신하는 내용임.

- 작성 주기 : 침해위협 발생 시

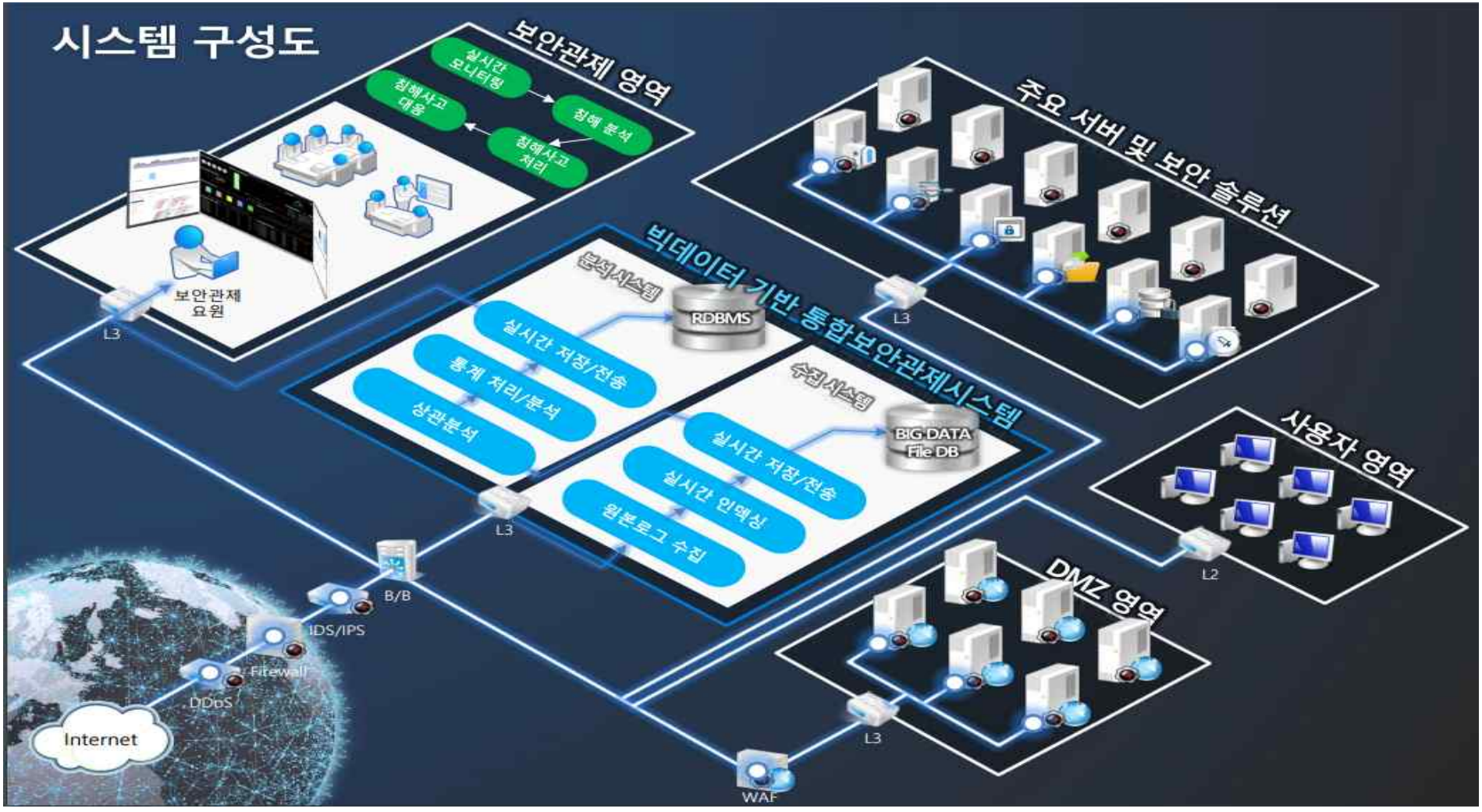
☞ 침해대응 보고서 포함내용(각 기관마다 보고서 내용은 상이)

- 개요 : 침해위협에 대한 간단한 설명
- 침해위협 탐지 일시 / 유형
- 피해 서버(장비) 정보 : OS, IP, 서버(장비) 용도 등
- 공격자 정보
- 피해여부
- 담당자 조치사항
- 대응방안

5-9. 통합보안관리시스템(ESM)

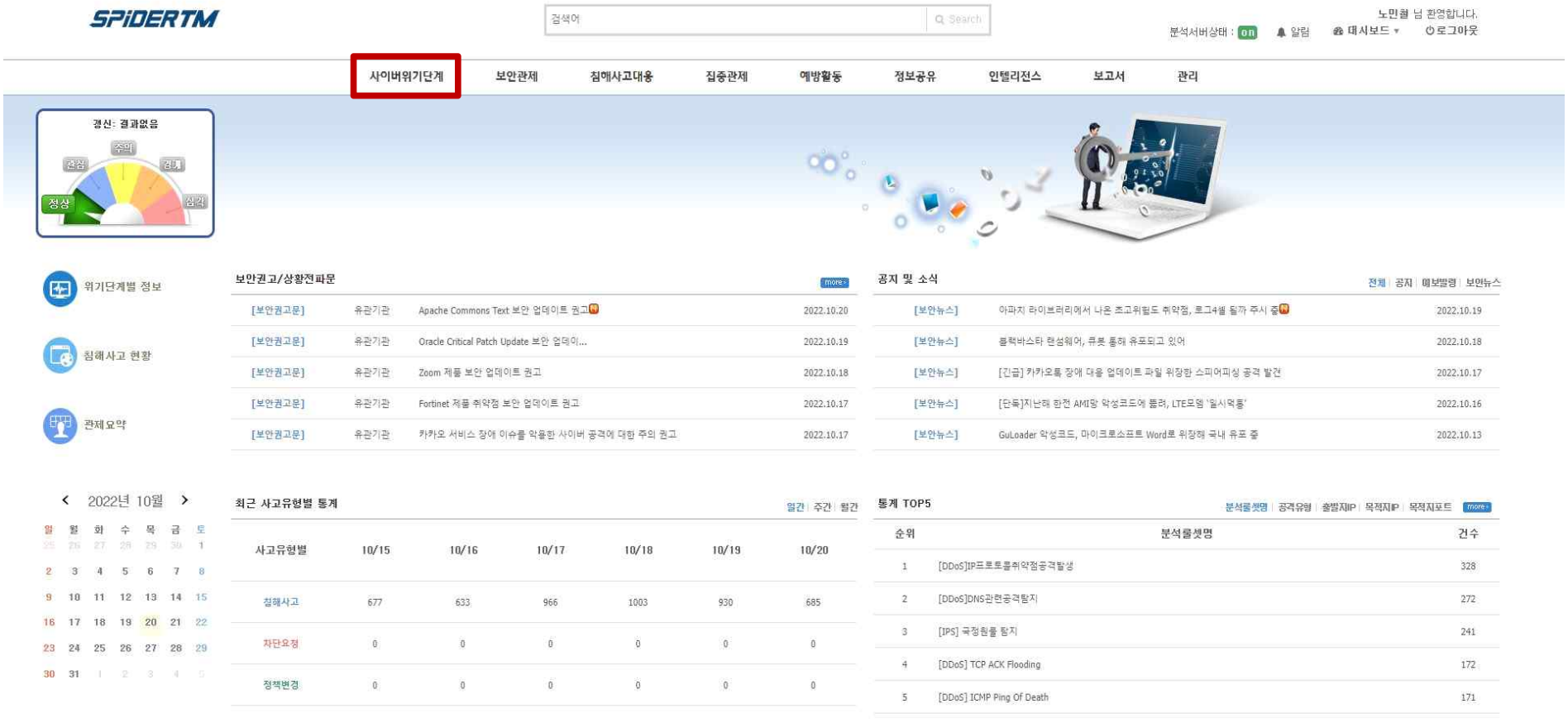


5-9. 통합보안관리시스템(ESM)



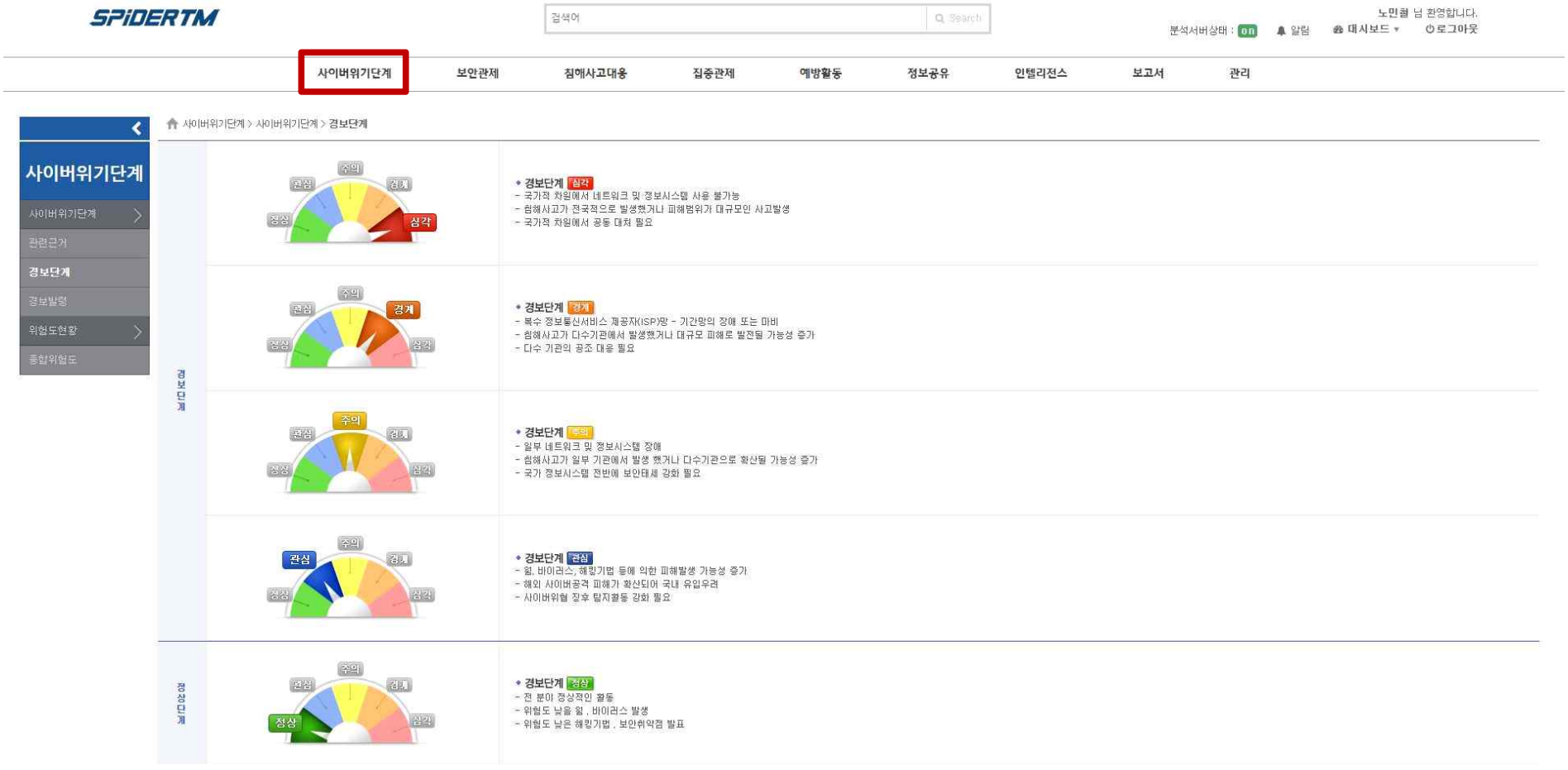
5-9. 통합보안관리시스템(ESM)

ESM 초기화면



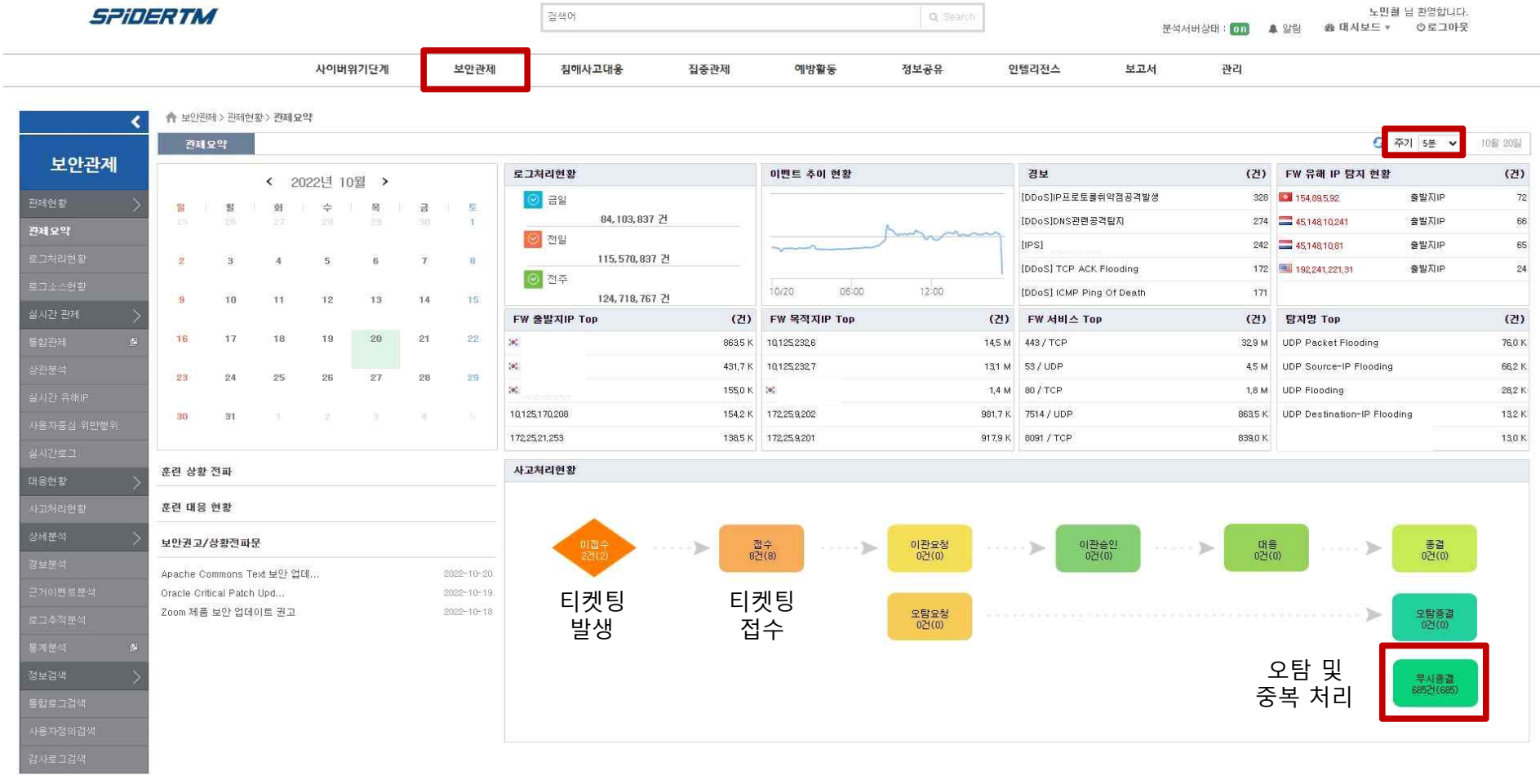
5-9. 통합보안관리시스템(ESM)

사이버위기단계 - 경보단계



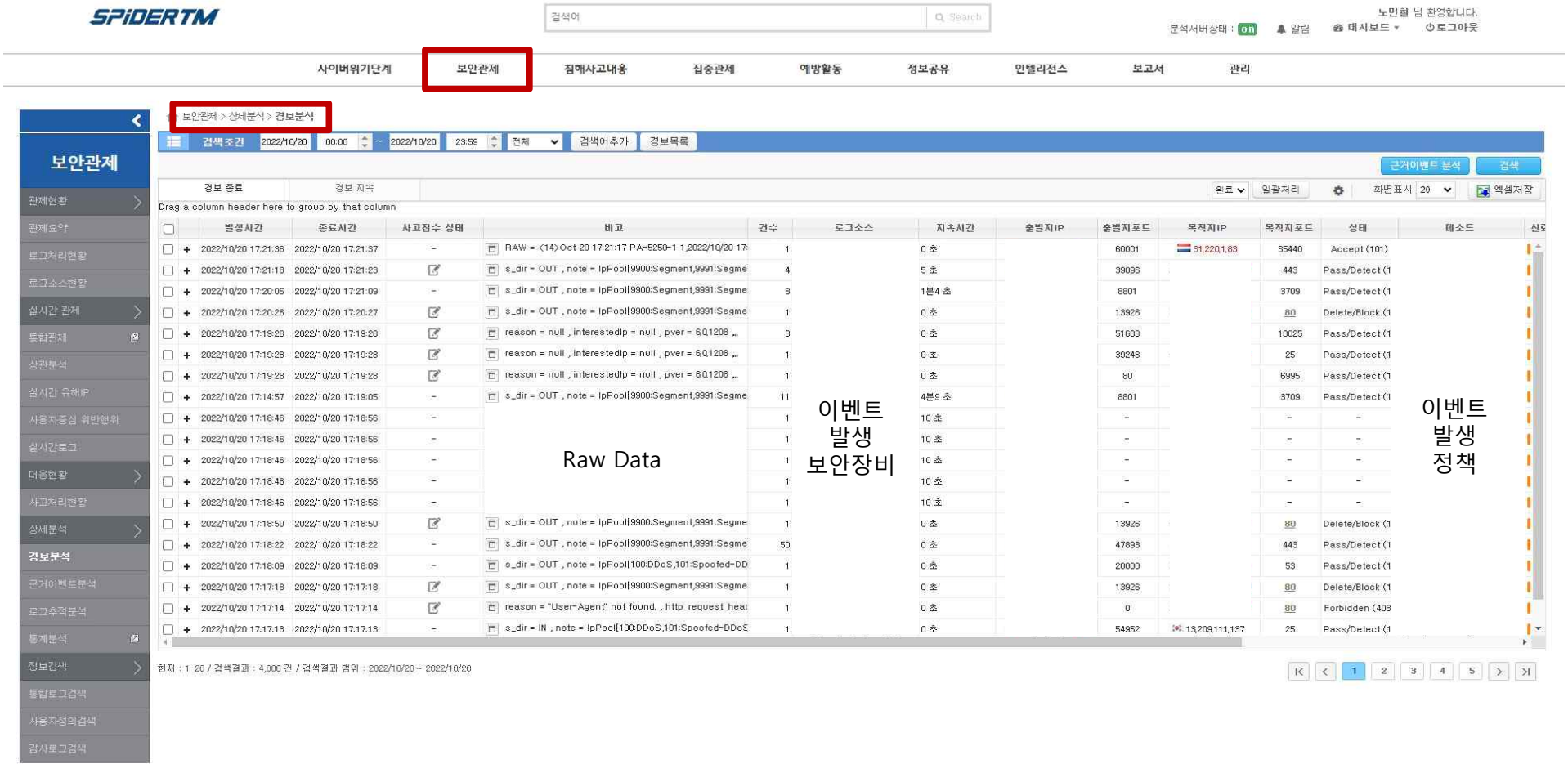
5-9. 통합보안관리시스템(ESM)

보안관제 화면



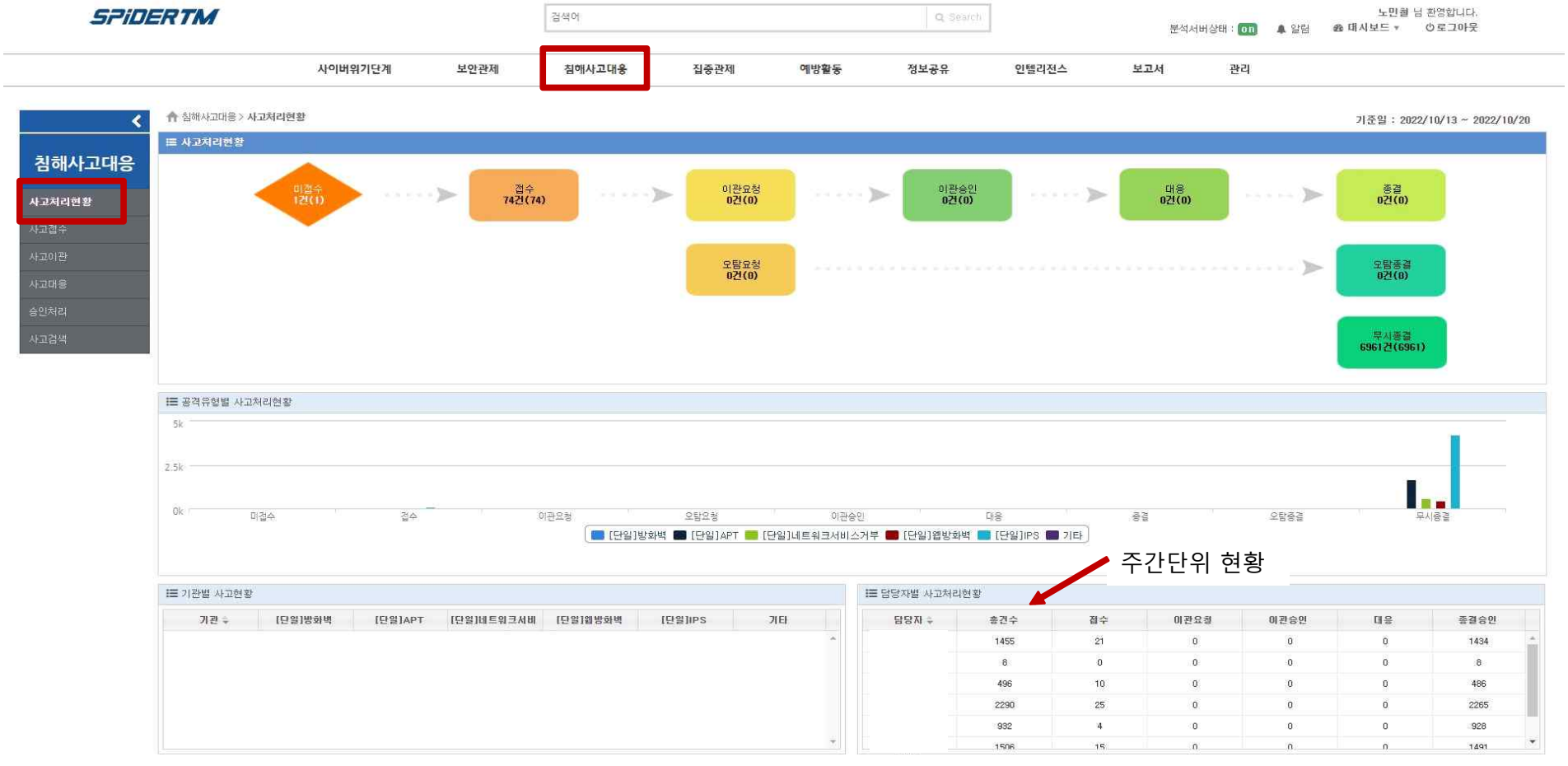
5-9. 통합보안관리시스템(ESM)

발생 이벤트 분석



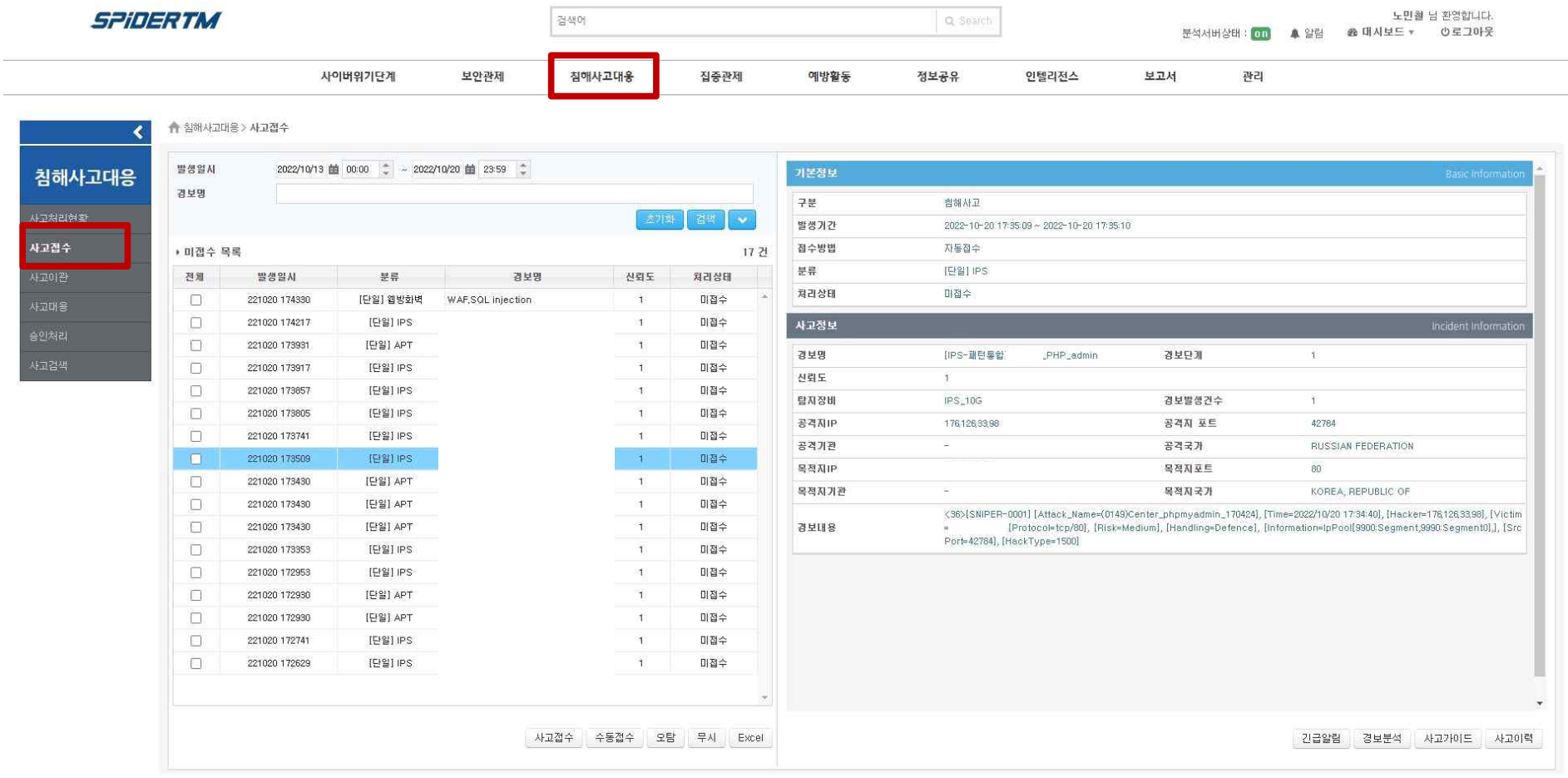
5-9. 통합보안관리시스템(ESM)

침해사고 대응



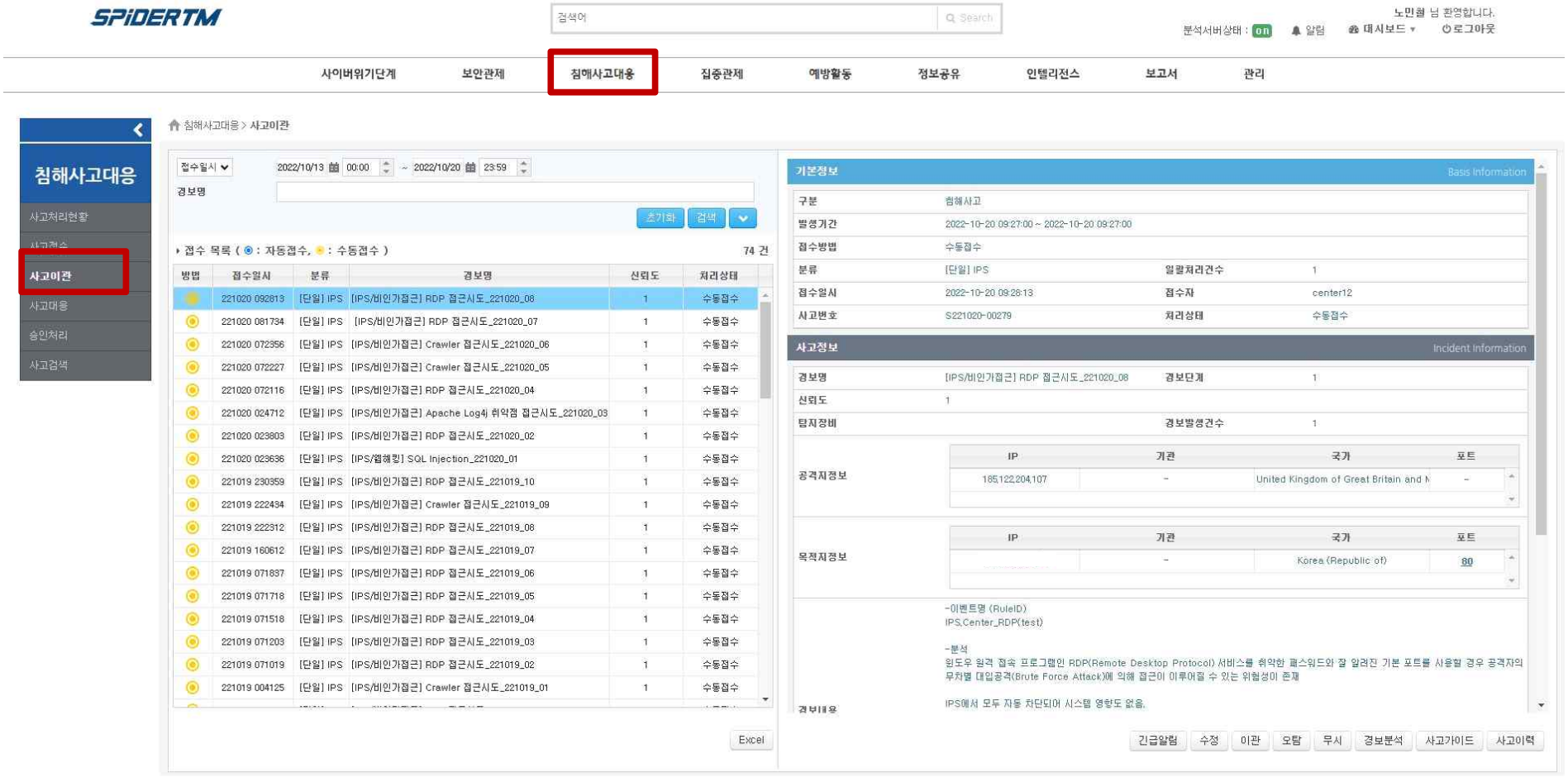
5-9. 통합보안관리시스템(ESM)

이벤트 사고접수



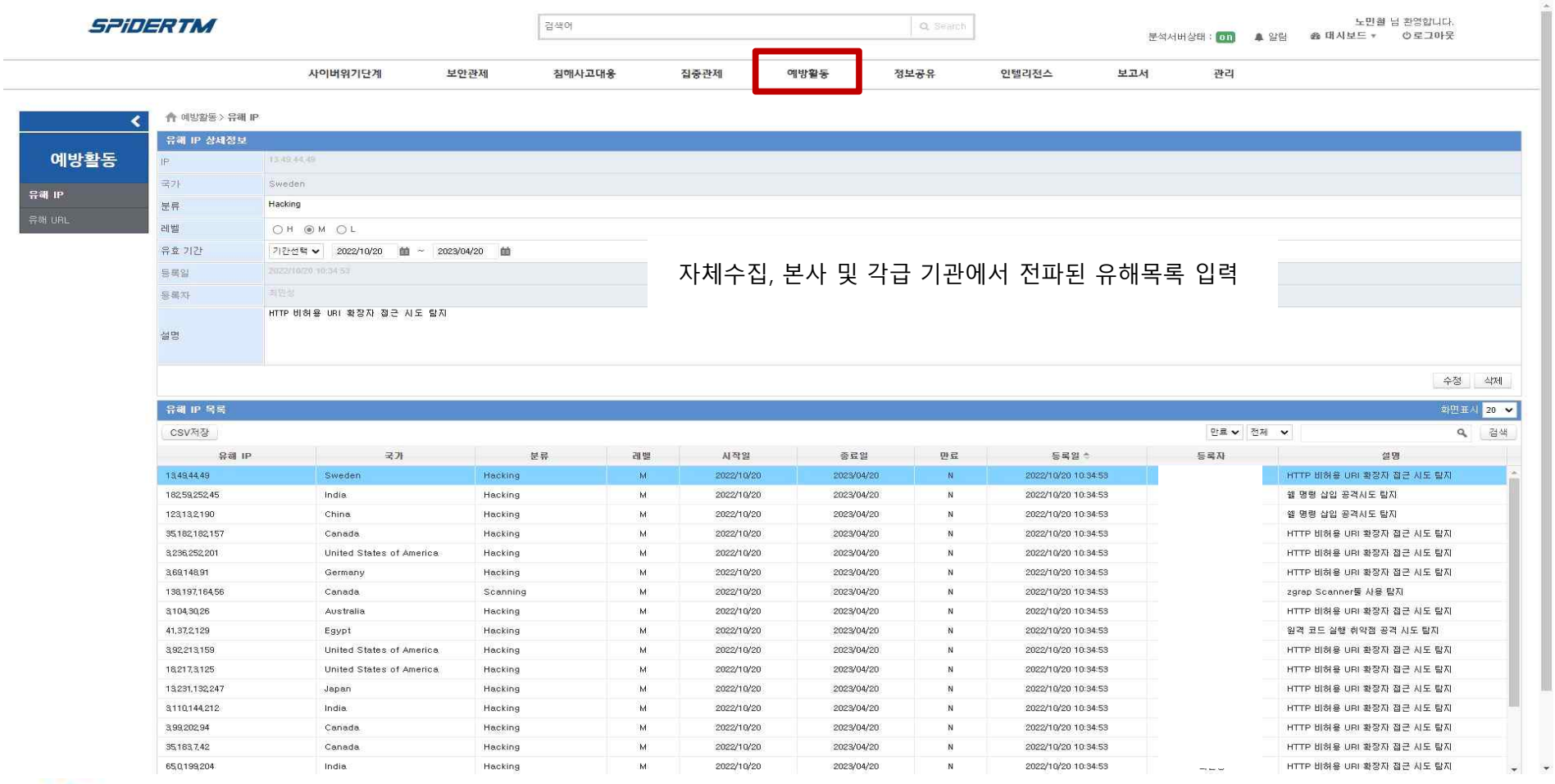
5-9. 통합보안관리시스템(ESM)

사고이관(사고접수 할당)



5-9. 통합보안관리시스템(ESM)

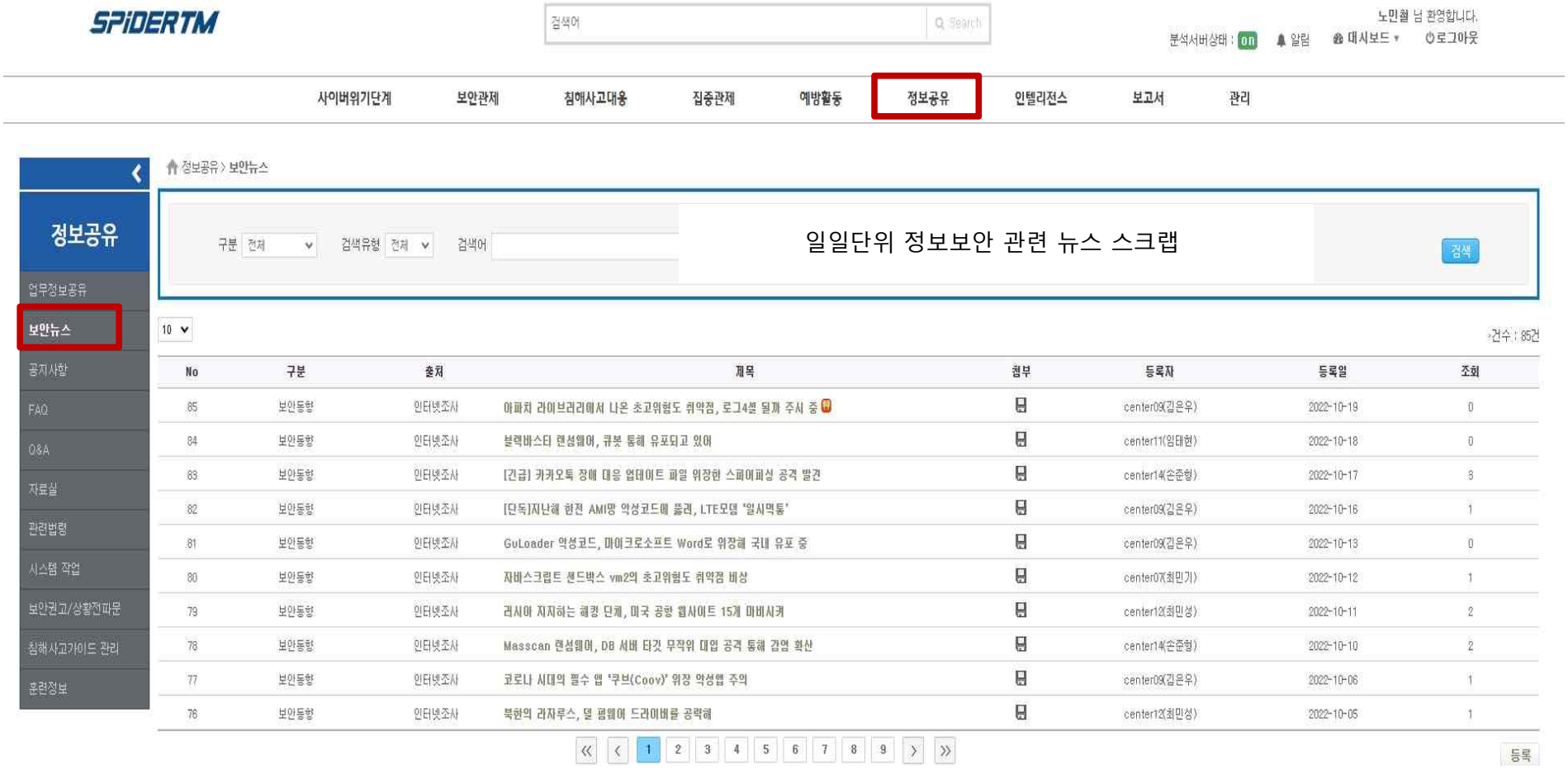
유해IP 및 URL 입력



자체수집, 본사 및 각급 기관에서 전파된 유해목록 입력

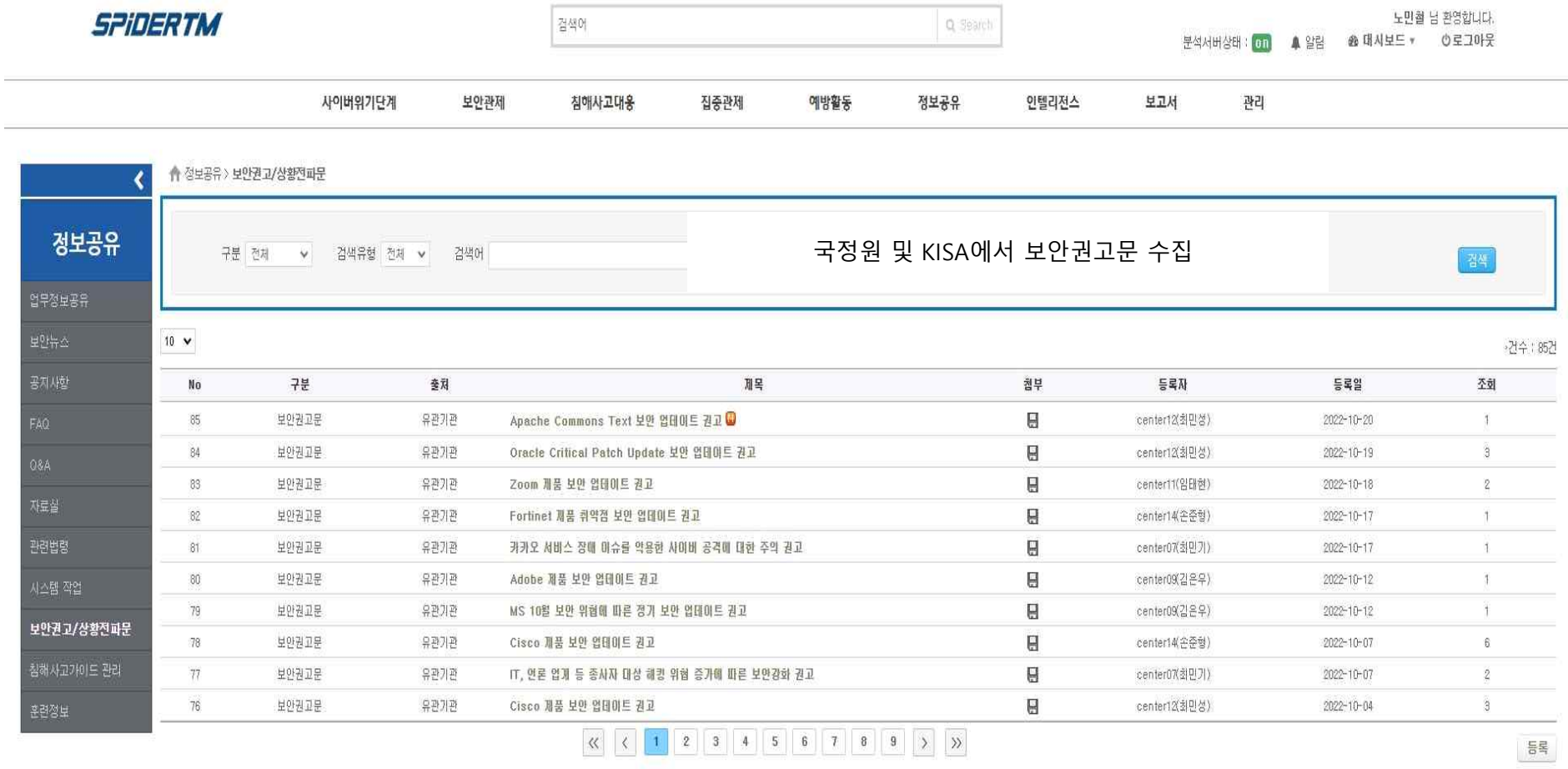
5-9. 통합보안관리시스템(ESM)

보안뉴스 입력



5-9. 통합보안관리시스템(ESM)

정보공유 입력



5-10. SIEM(Security Information & Event Management)

빅데이터(Big Data)

☞ 빅데이터란 디지털 환경에서 생성되는 데이터로 그 규모가 방대하고, 생성 주기도 짧고 형태도 수치 데이터 뿐만 아니라, 문자와 영상 데이터를 포함하는 대규모 데이터

☞ 빅데이터 환경은 과거에 비해 데이터의 양이 폭증했다는 점과 함께 데이터의 종류도 다양해져 사람들의 행동은 물론 위치정보와 SNS을 통해 생각과 의견까지 분석 하고 예측

구분	기준	빅데이터 환경
데이터	▪ 정형화된 수치자료 중심	▪ 비정형의 다양한 데이터 ▪ 문자데이터(SMS, 검색어) ▪ 영상데이터(CCTV, 동영상)
하드웨어	▪ 고가의 저장장치 ▪ 데이터베이스 ▪ 데이터-웨어 하우스(Data-ware House)	▪ 클라우드 컴퓨팅 등 비용 효율적인 장비 활용 가능
소프트웨어 / 분석방법	▪ 관계형 데이터베이스(RDBMS) ▪ 통계 패키지(SAS, SPSS) ▪ 데이터 마이닝(Data Mining) ▪ Machine Learning, Knowledge Discovery	▪ 오픈소스 형태의 무료 소프트웨어 ▪ 오픈소스 통계솔루션 ▪ 텍스트 마이닝(Text Mining) ▪ 온라인 버즈분석(Opinion Mining) ▪ 감성분석(Sentiment Analysis)

5-10. SIEM(Security Information & Event Management)

빅데이터(Big Data)

☞ 빅데이터 7요소

1. 규모(Volume) : 디지털 정보량이 기하급수적으로 급증 및 데이터 처리 수요 증가
2. 다양성(Variety) : 로그, SNS 소비 등 다양한 데이터에 대한 수용 및 처리 방법론 필요
3. 속도(Velocity) : IoT, 스트리밍 등 실시간 정보와 속도 증가로 빠르게 처리하고 분석하는 플랫폼 필요(수집 → 처리 → 분석/예측에 대한 Just-In-Time)
4. 정확성(Veracity) : 거대한 데이터는 신뢰성이 부족할 수 있어 다양한 품질에 대처하는 방법론의 필요성 제시
5. 가치(Value) : 트렌드, 감정, 진실성, 진정성, 개인의 취향 등 변화하는 대규모 데이터 시대에 가치의 필요성 증대
6. 가변성(Variability) : 맥락에 따라 의미가 변화하므로 데이터의 본래 의미를 찾기 위해 방법론 필요
7. 시각화(Visualization) : 데이터 분석으로 얻어낸 결론에 대해 사용자의 이해도를 고려한 효과적인 방법론 필요

5-10. SIEM(Security Information & Event Management)

빅데이터(Big Data)

☞ 보안 빅데이터

분석 대상 로그가 보안로그에서 어플리케이션 로그로 규모가 커지고 형태도 다양해지면서 기존 방법으로는 수집, 저장, 검색, 분석이 어려운 보안 로그 데이터

☞ 보안 빅데이터 의 성격

1. 규모(Volume) : 디지털 정보량이 기하급수적으로 급증 및 데이터 처리 수요 증가
2. 다양성(Variety) : 보안시스템 로그 → 정형/비정형 어플리케이션 로그, 패킷 및 트래픽 바이너리 형식의 데이터
3. 속도(Velocity) : 수집 → 처리 → 분석의 실시간 연관분석 Historical 연관분석

5-10. SIEM(Security Information & Event Management)

SIEM

☞ 보안정보 및 이벤트 관리

다양한 정보 시스템에 대한 로그 관리 및 분석을 강화되고 빅데이트 기술이 접목되어 정보 시스템 전반에 대한 신속한 위협탐지를 가능하게 하는 지능형 로그 관리 플랫폼

ESM

☞ ESM은 간단히 설명하면, 방화벽, 침입탐지 시스템(IDS), 가상사설망(VPN) 등 다양한 종류의 보안 솔루션을 하나로 모은 통합보안관리 시스템

☞ 보안솔루션 로그를 수집해 상호연관 관계를 분석하여 주로 외부 네트워크로부터의 공격 탐지에 중점

5-10. SIEM(Security Information & Event Management)

SIEM 시나리오

☞ **보안정보 및 이벤트 관리**

단일장비에서 크게 의미를 두지 않았던 이벤트를 여러 다양한 보안장비와 시스템 로그로부터 서로의 관계 시간, 양 등을 종합적으로 분석해 위협정보를 도출하는 일련의 과정

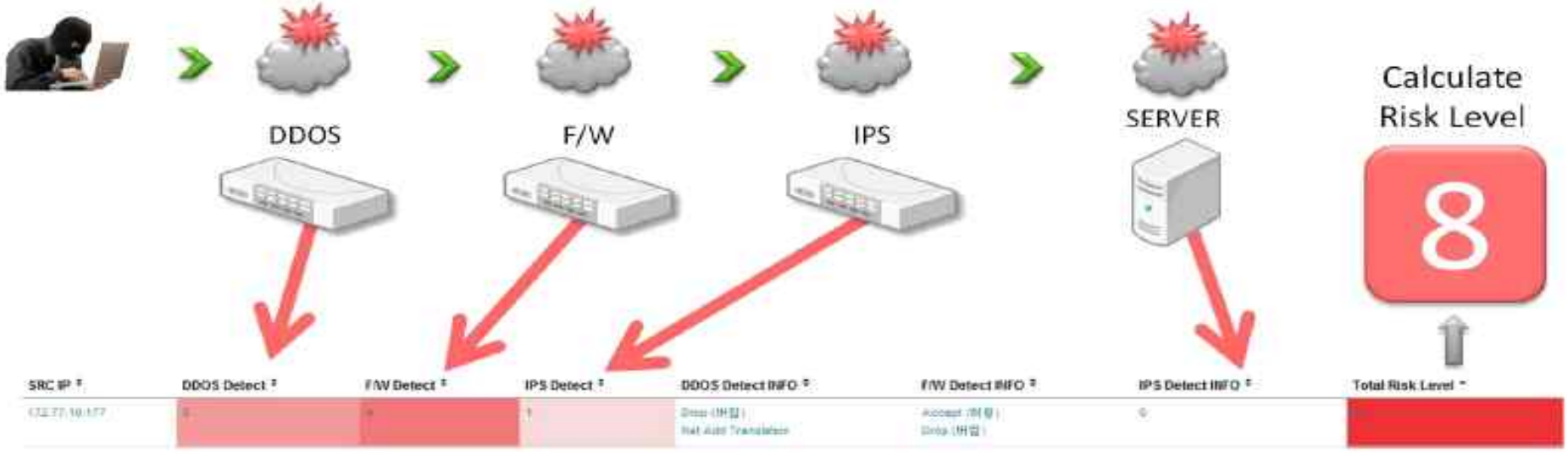
예) 신/변종 웜 및 악성코드에 감염되었을 경우 다수의 목적지를 대상으로 스팸메일 발송

- 단일 룰셋 : 하나의 IP에서 SMTP 서비스로 다량의 트래픽 발생, SMTP 목적지 IP**가 2개 이상인 경우 탐지**
- **종합 룰셋 : 동일한 Src IP에서 1분동안 SMTP 트래픽이 20건 이상 발생하고 목적지 분포가 2곳 이상인 경우 탐지**
- **탐지 조건 SMTP(25번 Port), 다량발생(20건/1분), 목적지 분포 2곳 이상**

5-10. SIEM(Security Information & Event Management)

SIEM 시나리오

데이터 상관분석을 통해서 방화벽, IPS, DDOS 장비에서 발견된 IP가 내부 웹서버, 파일서버 등으로 접속 했는지 추적하여 요주의 IP로 선정하여 관리하며, 요주의 IP가 특정 서버로 접속할 시에 접속을 차단



5-10. SIEM(Security Information & Event Management)

SIEM 시나리오

☞ SIEM과 네트워크 포렌식과 연동하여 이상행위 분석

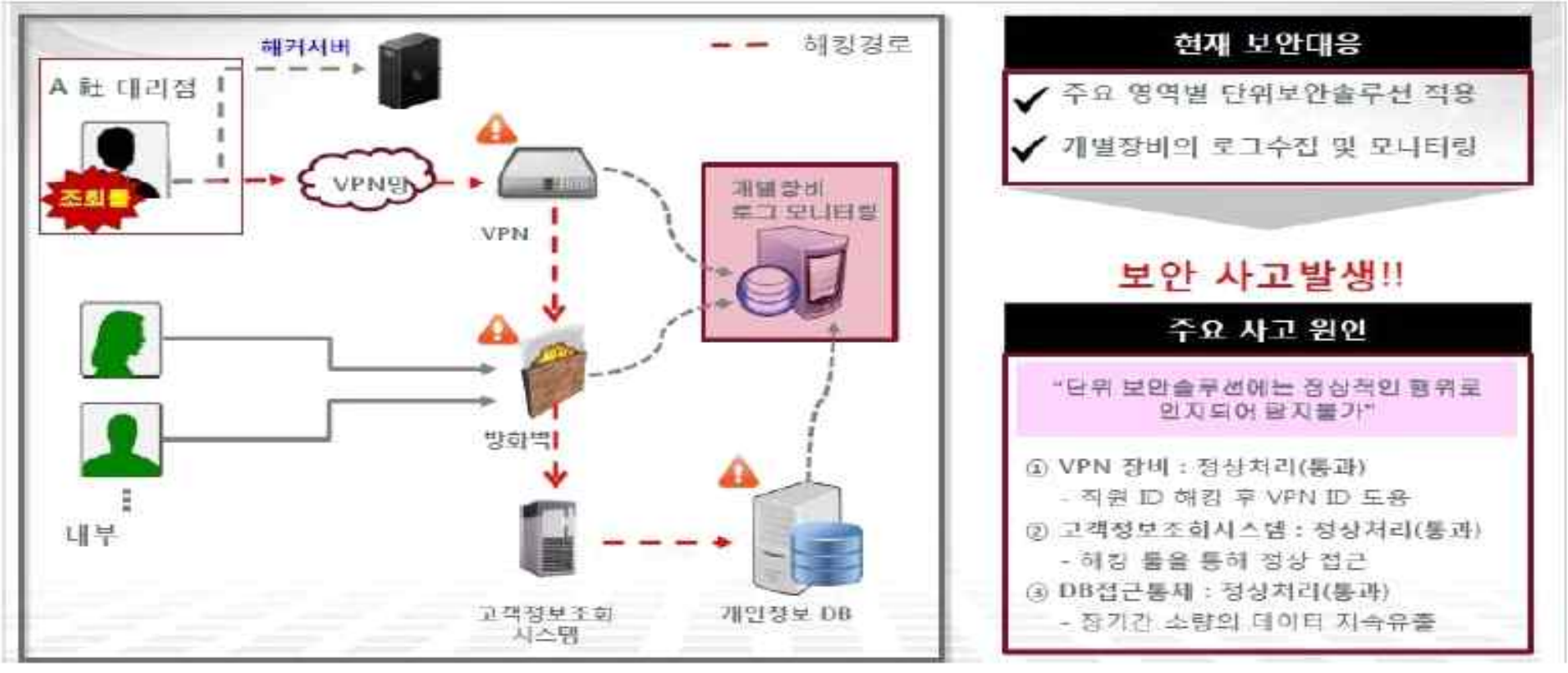
네트워크 포렌식은 모든 네트워크 트래픽을 분석해 침해 흔적을 찾아 공격이 어떻게 진행 됐는지 파악하기 용이

☞ 네트워크, 엔드포인트 포렌식, SIEM, 로그분석, 행위 분석 기술 등 모니터링에 필요한 모든 요수기술을 통합 연계하면 공격루트와 방법을 파악하고 공격패턴을 찾아내며, 공격자의 과거 행위를 분석해 향후 발생할 공격도 예측해 방어 할 수 있음

5-10. SIEM(Security Information & Event Management)

SIEM 시나리오

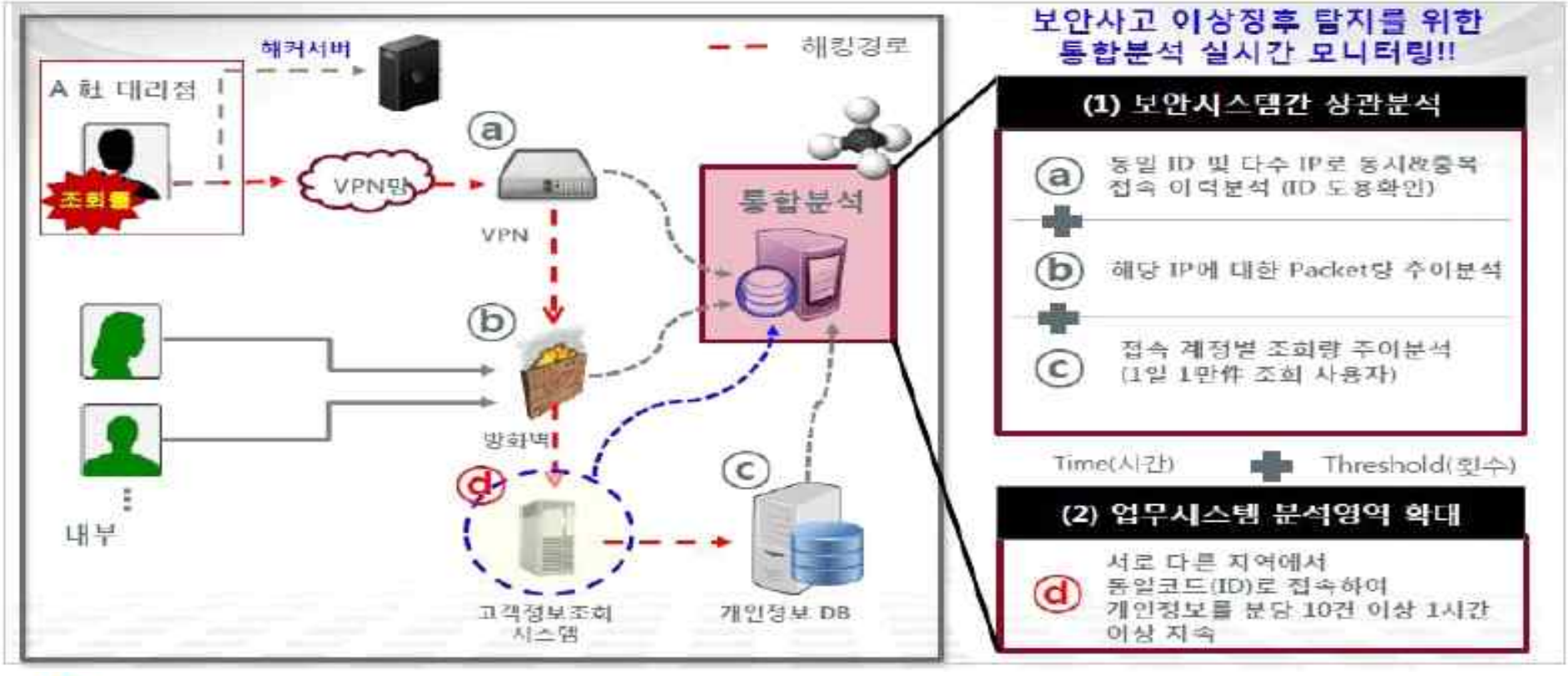
☞ **정보유출 사고 특징**



5-10. SIEM(Security Information & Event Management)

SIEM 시나리오

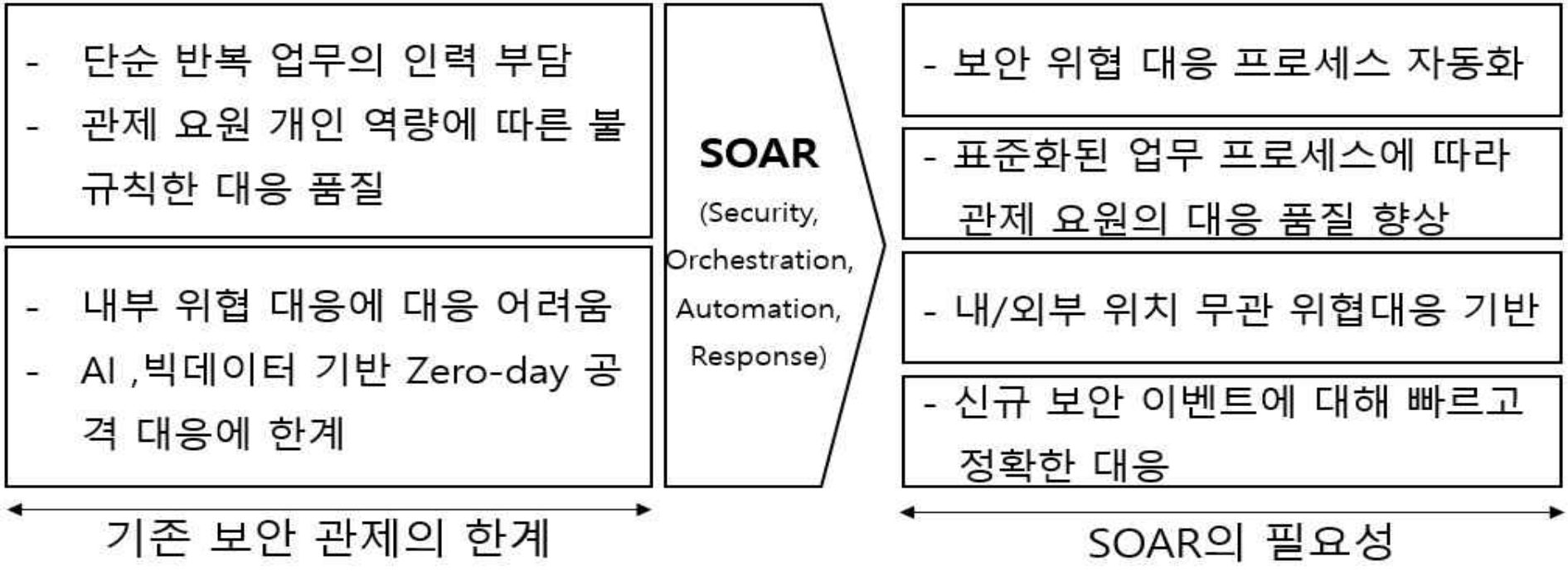
☞ 정보유출 사고 특징 – 보안시스템간 상관분석 / 분석영역 확대 및 통합 분석 필요



5-11. SOAR (Security Orchestration, Automation and Response)

개념

☞ **다양한 보안 위협 대응 프로세스를 자동화/조율하여 단순 반복 보안관제 업무 효율화와 다양한 보안 이벤트를 신속 정확하게 대응하는 보안 솔루션**



5-11. SOAR (Security Orchestration, Automation and Response)

다양한 사이버위협에 대해 대응수준을 자동으로 분류하고 표준화된 업무 프로세스에 따라 보안업무담당자와 솔루션이 유기적으로 협력할 수 있도록 지원하는 플랫폼(가트너 정의)



SOAR = SOA + SIR + TIP

SOA — Security Automation and Orchestration
한 조직이 보유한 여러 개의 Workflow를 관리하는 기법

SIRP — Security Incident Response Platform
SIEM에서 탐지된 위협 대응 지원 시스템 (티켓 처리 시스템)

TIP — Threat Intelligence Platform
위협 인텔리전스 중 관련 데이터를 찾아 환경에 맞는 최적의 Action 제시

Source: 2018 Gartner, Inc.

5-11. SOAR (Security Orchestration, Automation and Response)

SOA(Security Orchestration and Automation)

- ☞ Security Orchestration은 서로 다른 제품(Non-Security 제품 포함)들을 서로 통합하고, Workflow를 통해 제품 간 작업을 자동화시켜 최종 사용자에게 감독과 상호 작용을 허용하게 하는 개념
- ☞ 사람, 프로세스, 기술을 통합하여 조직의 보안 상태를 개선
- ☞ Security Automation은 인간이 수행하는 작업중심(Task-oriented) 작업을 기계가 수행하도록 하는 것

Threat Intelligence Platforms(TIP)

- ☞ Threat Intelligent 란 조직(Organization)이 “조직에 대한 위협(Threat)”을 이해하기 위해 사용하는 정보를 의미
- ☞ TIP란, 내·외부 위협 정보를 실시간으로 수집하고 상관 분석하는 프로세스를 자동화시켜, 신속하게 사이버 공격에 대한 분석과 대응을 지원하는 기능을 제공

5-11. SOAR (Security Orchestration, Automation and Response)

Security Incident Response Platforms(SIRP)

☞ SIRP는 보안 침해 사고 발생시 대응하는 시스템으로, 처리해야 하고 분석해야 할 정보들이 많지만, 수립된 대응 정책에 따라 즉각적으로 대응해야 하고 자동적으로 처리하는 기능을 제공

☞ 사람, 프로세스, 기술을 통합하여 조직의 보안 상태를 개선

☞ 이상적인 SIRP 기능

- SIEM을 포함한 다양한 Source로부터 경고(Alert) 와 보안 Event를 수집
- 보안 분석가는 보안 침해 사고 처리 기간 동안 발견한 정보, 관련된 로그, IOC(침해지표 : Indicator Of Compromise) 등을 “침해 사고 Case” 관리 시스템에 추가
- 악의적인 행위를 식별하기 위하여, 분석한 자료를 VirusTotal 같은 외부 위협 정보와 비교할 수 있어야 함.

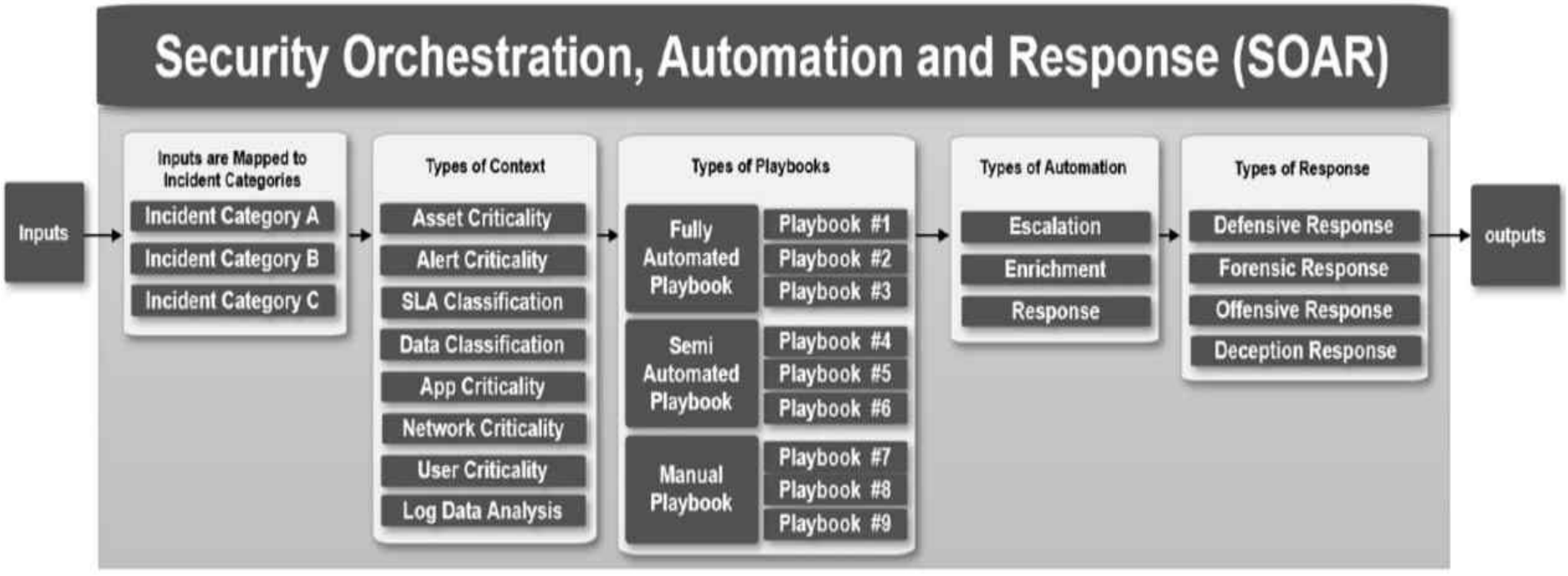
5-11. SOAR (Security Orchestration, Automation and Response)

주요 기능

구분	주요기능	설명
Orchestration	보안솔루션 연동	- 다양한 보안 솔루션 연동, 탐지된 이벤트 자동 분석 - 하나의 화면에서 현재 보안 상황 확인 및 운영
	가시성 제공	- 통합 보안 대시보드 제공 - 사이버 킬 체인 적용, 대응절차 시각화
Automation	업무 자동화	- 단순 반복 업무를 자동화, 편의성 제공 - 대응 시나리오 설계 등 고차원 업무 집중 환경 제공
	동적 플레이북	- 사전 정의된 플레이북으로 일관된 프로세스 작업 처리를 통해 품질 편차 최소화
	작업 및 스크립트	- 워크플로우에서 스크립트 기능을 추가하여 플랫폼 기능 자동화 운영
Response	사고대응 및 협업	- 사고대응 내역과 대응방식 등 의사결정 기록 - 보안 관제 센터 관리자 협업체계 지원
	리포팅	- 사고 대응에 대한 지표 관리, 의사결정 지원

5-11. SOAR (Security Orchestration, Automation and Response)

SOAR기반 위협대응 절차



☞ 발생한 인시던트를 구분하여 분석 후 palybook을 통해 대응 자동화 및 응답처리

☞ SOAR는 보안 위협 대응 지능화 관점에서 SIEM과 유사하지만 로그 및 경보처리, 위협 식별 방법 등 차이점이 존재

5-11. SOAR (Security Orchestration, Automation and Response)

SOAR와 SIEM 비교

구분	SOAR	SIEM
데이터집계	보안 경고 및 위협 지능화 집계	로그집계
경보처리	SIEM 및 다른 툴로부터 경보 수집	경보생성
위협식별	상관관계 분석 기반 위협 식별	데이터를 분석하여 잠재적 위협 식별
응답워크플로우	E2E 자동화 응답 워크플로우	제한된 응답 워크플로우
역할	통합 보안 솔루션 조율	사용자/분석가에게 의심 활동 알림

6. AI 보안

6-1 AI 보안

AI 보안의 정의

☞ AI를 사용하여 조직의 보안 태세를 강화하는 프로세스

☞ 조직은 AI 시스템을 통해 위협 탐지, 예방 및 치료를 자동화사이버 공격과 데이터 유출에 더 효과적으로 대처할 수 있다

AI 보안이 중요한 이유

☞ 클라우드 및 하이브리드 클라우드 환경으로 전환되며 데이터가 무분별하게 확산되고 공격 표면이 확대

☞ 위협 행위자(공격자)는 취약점을 악용할 새로운 방법을 찾아 공격

6. AI 보안

6-1 AI 보안

AI 관제 플랫폼과 전문인력으로 로그수집부터 사고 조치까지 완벽 대응

01 **수집** 로그 수집 및 모니터링



6. AI 보안

6-1 AI 보안

AI 관제 플랫폼과 전문인력으로 로그수집부터 사고 조치까지 완벽 대응

02 **탐지/대응** 이벤트 분석 및 처리



6. AI 보안

6-1 AI 보안

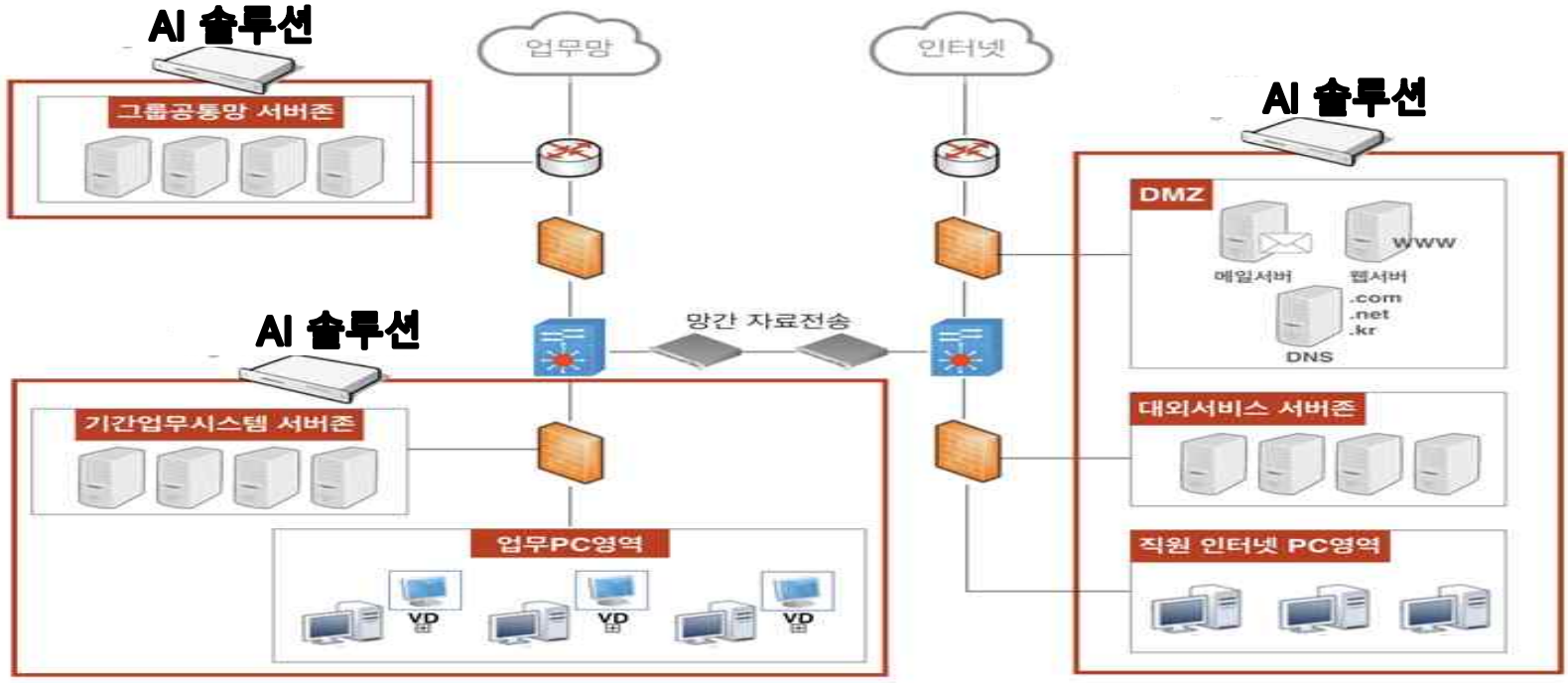
AI 관제 플랫폼과 전문인력으로 로그수집부터 사고 조치까지 완벽 대응

03 **조치** 전파 및 보고



6. AI 보안

6-1 AI 보안



구분	AI 솔루션	기존 솔루션
탐지 / 분석 방식	트래픽 메타 데이터 기반으로 한 머신러닝	패턴, 시그니처, 룰, 샌드박스 기반
탐지 / 분석 범위	모든 비정상적 이상행위 감지 (장비, 네트워크, 유저)	악성코드 및 알려진 외부로부터 공격
솔루션 적용 범위	네트워크 전 구간에 적용이 가능 (망분리 환경, 내부망 및 ICS 산업제어망 가능)	외부망 및 경계 구간

6. AI 보안

6-2 AI + SOAR



생성형 AI : ChatGPT 등장
인공지능 활용 급증

2023년 ChatGPT 및 LLM 기술의 도입으로 모든 산업분야에서 전반적으로 인공지능 채택 급증,
인공지능 덕분에 창의성,생산성 및 전반적 워크플로 개선



AI를 악용한 세부정보 수집

피싱에 사용할 이메일 계정 획득➔개인정보 찾기
무차별 암호 대입 공격 ➔기 유출된 비밀번호 DB



신규 보안 위협 증가

- 악성코드의 변종 만들기 쉬움
- 생성형AI 활용한 피싱 메일 ,랜섬웨어 (Worm GPT,FraudGPT) 증가세

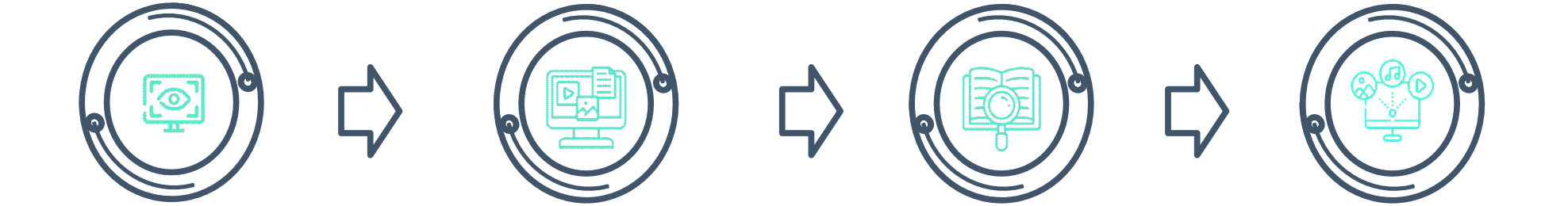
사이버 보안 대응 방법의 전환 필요

➔ **AI를 악용하는 보안 위협, 그리고 그것을 탐지하는 보안 관제 역시 AI를 활용**

6. AI 보안

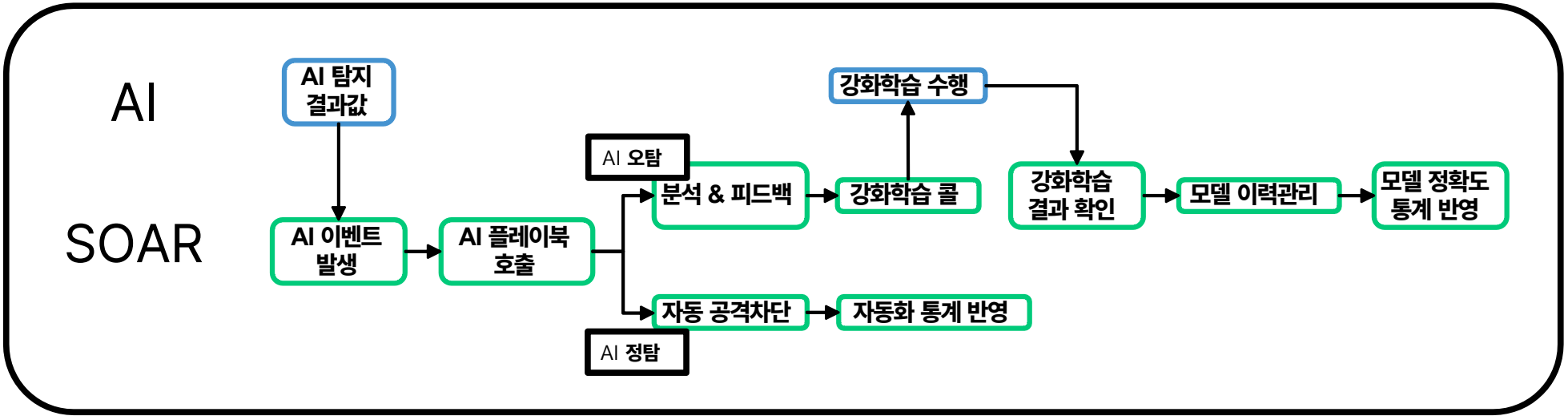
6-2 AI + SOAR

보안 관제 프로세스 (AI + SOAR)



6. AI 보안

6-2 AI + SOAR



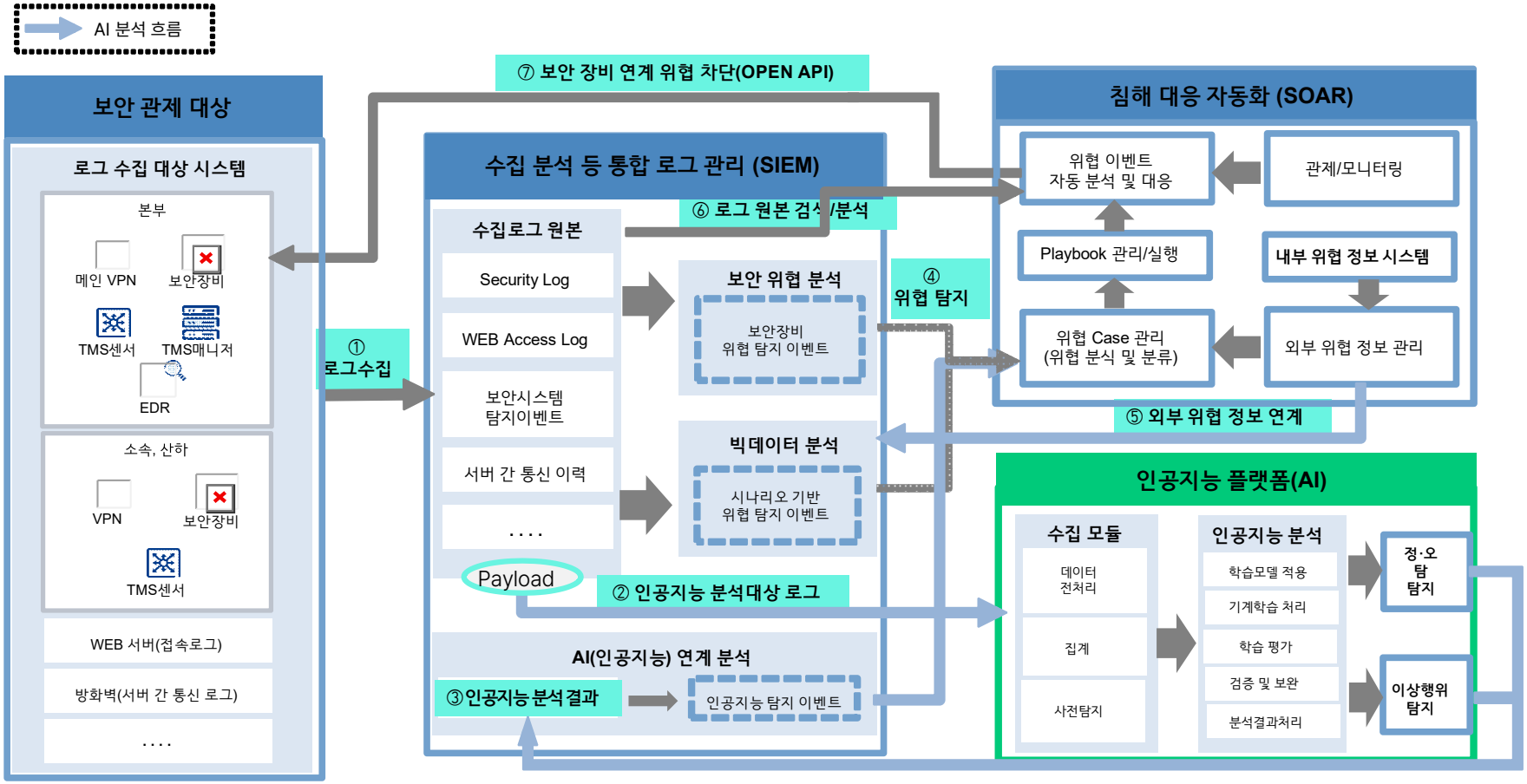
AI 정탐일 경우, SOAR 플레이북으로 자동 차단

AI 오탐일 경우, 이벤트 분석 및 강화 학습 프로세스 진행

AI 모델의 정량적 성과를 가시적으로 확인 할 통계

6. AI 보안

6-3 AI + SOAR 적용 예제

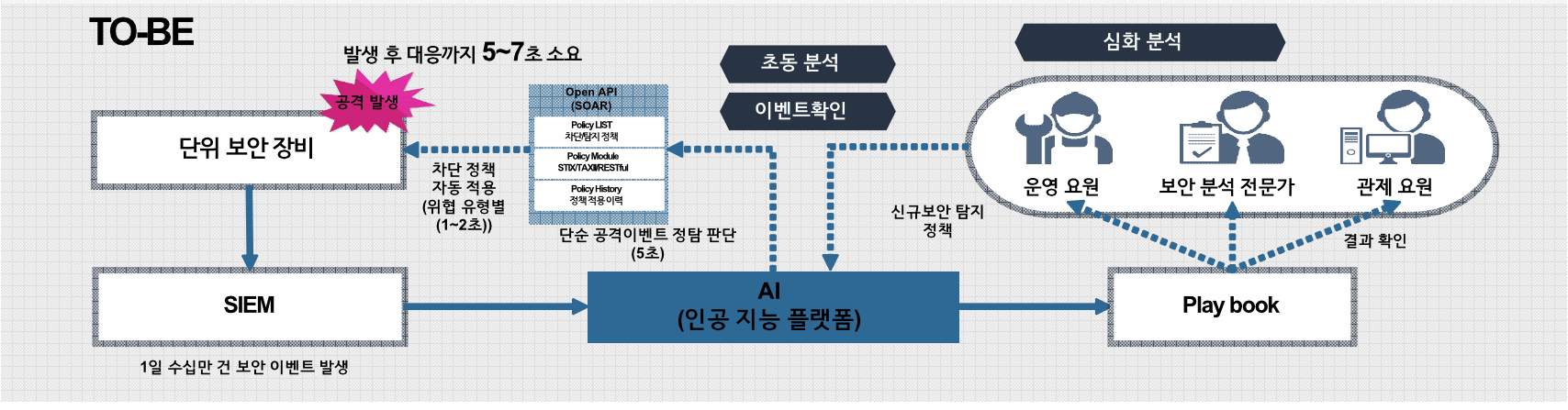


6. AI 보안

6-3 AI + SOAR 적용 예제

AI+SOAR 도입 '전(前)' 과 '후(後)' 비교





Q&A